

Dltec do Brasil®
www.dltec.com.br
info@dltec.com.br



DLTEC DO
BRASIL

TÓPICOS DE SEGURANÇA (TÓPICO 5.0 DO CCNA 200-301)

Tópicos de Segurança

Dltec do Brasil®

Todos os direitos reservados©

Copyright © 2024.

É expressamente proibida cópia, reprodução parcial, reprografia, fotocópia ou qualquer forma de extração de informações deste sem prévia autorização da DLteC do Brasil conforme legislação vigente.

O conteúdo dessa apostila é uma adaptação da matéria online do Curso Tópicos de Segurança.

Aviso Importante!

Esse material é de propriedade da DLteC do Brasil e é protegido pela lei de direitos autorais 9610/98.

Seu uso pessoal e intransferível é somente para os alunos devidamente matriculados no curso. A cópia e distribuição é expressamente proibida e seu descumprimento implica em processo cível de danos morais e material previstos na legislação contra quem copia e para quem distribui.

Para mais informação visite www.dltec.com.br

Seja muito bem-vindo(a) ao curso Tópicos de Segurança em Redes Cisco, o qual faz parte da trilha da certificação Cisco CCNA 200-301, da DlteC!

Aqui, você terá todo o background necessário para aprender sobre Segurança de Redes IP com foco no CCNA e ser aprovado(a) no exame 200-301 da Cisco ao final da trilha. O exame citado anteriormente é conhecido também como exame CCNA ou Cisco Certified Network Associate.

Os assuntos encontram-se distribuídos conforme o Blueprint do exame – sendo assim, esteja bastante atento(a) a todo o conteúdo que aqui será apresentado. Não perca de vista o peso de cada tópico – isso é importante para você ter uma noção de quanto investirá o seu tempo em cada um.

Busque praticar o máximo de exercícios possíveis e, além disso, busque compreender cada assunto de maneira objetiva. Não esqueça o propósito principal: ser aprovado(a).

A DlteC estará com você em todos os momentos dessa jornada!

Bons estudos!

Introdução

Olá!

Como parte integrante da Trilha para a Certificação **CCNA 200-301** da DlteC do Brasil, esta apostila representa uma adaptação textual do material disponibilizado online do **Curso Tópicos de Segurança**.

O conteúdo desse curso cobre o tópico 5.0 (Security Fundamentals) da certificação Cisco CCNA 200-301.

Por isso, recomendamos que você a utilize como um importante recurso offline. Combinando-a com o conteúdo online, você estará muito mais bem preparado(a) para realizar o exame **200-301 (CCNA: Cisco Certified Network Associate)**.

É de suma importância que você, além de participar dos fóruns, realize o máximo possível de exercícios e simulados (todos encontrados na trilha do 200-301 Online).

Lembre-se que o curso Fundamentos de Redes Cisco é Pré-requisito para esse curso.

Esperamos que você aproveite ao máximo este material, que foi idealizado com o intuito verdadeiro de fazê-lo(a) obter êxito no exame. Estamos torcendo pelo seu sucesso!

Bons estudos!

Tópicos de Segurança

Peso: 15%

Objetivos

Ao final desse curso você deverá ter conhecimentos sobre:

- Os principais conceitos de segurança, tais como ameaças, vulnerabilidades, exploits e mitigação
- Elementos de um programa de segurança, tais como user awareness, treinamento e controle do acesso físico
- Configurar o controle de acesso aos dispositivos através de senhas locais
- Políticas de segurança de senhas e seus elementos, assim como métodos alternativos (multifactor authentication, certificados digitais e biometria)
- VPNs site-to-site e de acesso remoto
- Configurar e verificar Listas de Controle de Acesso (Access Control Lists ou ACLs)
- Configurar recursos de segurança em camada-2 (DHCP snooping, dynamic ARP inspection e port security)
- Funcionamento do AAA (authentication, authorization e accounting)
- Descrever o funcionamento dos protocolos de segurança em redes sem fio: WPA, WPA2 e WPA3
- Configurar uma WLAN utilizando WPA2 PSK através da interface GUI

Sumário

1	Introdução	7
1.1	Introdução	7
1.2	Sobre a Cisco e o CCNA - Cisco Certified Network Associate	8
1.3	Plano de Estudos para o CCNA	9

1.4	Como Estudar com o Material da DlteC	10	6.3	Alternativas de Senhas	42
2	Tópicos do Curso vs Blueprint do CCNA 200-310 – Peso 15%	11	6.4	Reforçando as Políticas de Senhas no Cisco IOS.	44
2.1	Introdução	11	7	Conceitos sobre VPNs	47
3	Principais Conceitos de Segurança	12	7.1	Introdução	47
3.1	Introdução	12	7.2	Fundamentos de VPN – Requisitos de Segurança	49
3.2	Três Princípios Básicos de Segurança: CIA	13	7.3	Dispositivos e Softwares para VPN	51
3.3	Vulnerabilidades (Vulnerabilities)	14	7.4	Protocolo IPSec	52
3.4	Exploits	15	7.5	Criptografia IPSec	54
3.5	Ameaça, Risco e Ataque	17	7.6	Conceitos sobre de Túneis	55
3.6	Ataques Comuns às Redes de Computadores	18	7.7	DMVPN - Cisco Dynamic Multipoint VPN	59
3.7	Outros Tipos de Ameaças e Ataques	20	7.8	Considerações Finais sobre VPN	61
3.8	O Fator Humano	23	8	Access Control Lists	63
3.9	Técnicas de Mitigação (Mitigation Techniques)	25	8.1	Introdução	63
4	Elementos de um Programa de Segurança	26	8.2	Listas de Controle de Acesso (ACL) – Operação	64
4.1	Introdução	26	8.3	Entendendo e Criando as Regras	67
4.2	Política de Segurança	26	8.4	ACL IP Padrão Numerada	69
4.3	Treinamento e Conscientização dos Usuários	29	8.5	como Máscara Curinga	70
4.4	Controle Físico de Acesso	30	8.5.1	Máscara curinga para selecionar redes classful	71
5	Controle de Acesso com Senhas Locais	32	8.5.2	Máscara curinga para apenas um IP (máscara de host)	72
5.1	Introdução	32	8.5.3	Máscara curinga para permitir quaisquer redes (todas as redes)	72
5.2	Enable Secret: Senha para Acesso Privilegiado	33	8.5.4	Selecionando Sub-redes	73
5.3	Acesso Local e Remoto Sem Usuário Local	35	8.5.5	Selecionando Faixas de Endereços IP	74
5.4	Configurando um Usuário e Senha Local para Acesso Administrativo	36	8.5.6	Máscaras Curinga Esdrúxulas	76
5.5	Tipos de Senhas no Cisco IOS	37	8.6	ACL IP Estendida Numerada	77
6	Gerenciamento de Senhas	40	8.7	Exemplo de ACL Estendida Numerada	79
6.1	Introdução	40	8.8	Listas de Acesso Nomeadas	81
6.2	Política de Senhas	41	8.9	Verificando as ACLs Criadas	82
			8.10	Aplicando ACL nas Interfaces	83
			8.11	Limitando Acesso ao SSH e Telnet nos Roteadores	84
			8.12	Exemplos Práticos de ACLs	85
			8.12.1	Exemplo 1 – ACL Padrão	85
			8.12.2	Exemplo 2 – ACL Estendida	86

8.12.3	Exemplo 3 – ACL Nomeada Estendida	87	11.3	Configurando uma WLAN com WPA2 PSK via GUI	135
8.12.4	Exemplo 4 - ACLs Avançadas de Infraestrutura	88	12	Conclusão do Curso	136
8.13	Editando ACLs Numeradas	90	12.1	Conclusão	136
8.14	Editando ACLs Nomeadas	91			
8.15	Pacotes Gerados pelo Próprio Roteador	93			
8.16	Resumo sobre ACL's Padrões e Estendidas	94			
8.17	Listas de Controle de Acesso IPv6	96			
8.17.1	Configurando uma ACL IPV6	97			
8.17.2	Exemplo de ACL IPV6	99			
9	Segurança em Camada 2	101			
9.1	Introdução	101			
9.2	Mitigando Ataques Baseados no Endereço MAC	102			
9.3	Ativando o Port Security	104			
9.3.1	Verificando o Port Security	108			
9.3.2	Como Tratar Portas Restritas, Protegidas e em Error Disable	110			
9.4	Configurando o DHCP Snooping	111			
9.4.1	Exemplo de Configuração do DHCP Snooping	112			
9.4.2	DHCP Snooping Database Agent	114			
9.4.3	Restrições ao Ativar o DHCP Snooping	115			
9.5	Configurando o DAI – Dynamic ARP Inspection	116			
9.5.1	Ativando o DAI	117			
9.5.2	Exemplo de Configuração do DAI	118			
10	Conceitos de AAA (Authentication, Authorization, and Accounting)	120			
10.1	Introdução	120			
10.2	Protocolos TACAS+ e RADIUS	121			
11	Segurança em Redes Sem Fio	124			
11.1	Introdução	124			
11.2	WEP e Wi-Fi Protected Access 1, 2 e 3	126			
11.2.1	Visão Geral do WEP	127			
11.2.2	Funcionamento do WPA	129			
11.2.3	Funcionamento do WPA2	130			
11.2.4	Funcionamento do WPA3	132			
11.2.5	PSK, Personal e Enterprise	133			

1 Introdução

1.1 Introdução

Bem-vindo ao **Curso Tópicos de Segurança**, o qual também faz parte do conteúdo preparatório para a prova de certificação **CCNA 200-301**.

O curso **Tópicos de Segurança** possui como objetivo fornecer ao aluno uma visão abrangente sobre os principais componentes e tecnologias de segurança que um CCNA precisa no seu dia a dia.

Ao final do curso, você deverá ser capaz de:

- Descrever os principais conceitos de segurança, tais como ameaças, vulnerabilidades, exploits e mitigação.
- Descrever os elementos de um programa de segurança, tais como user awareness, treinamento e controle do acesso físico.
- Configurar o controle de acesso aos dispositivos através de senhas locais.
- Descrever as políticas de segurança de senhas e seus elementos, assim como métodos alternativos (multifactor authentication, certificados digitais e biometria).
- Descrever o funcionamento de VPNs site-to-site e de acesso remoto.
- Configurar e verificar Listas de Controle de Acesso (Access Control Lists ou ACLs).
- Configurar recursos de segurança em camada-2 (DHCP snooping, dynamic ARP inspection e port security).
- Descrever o funcionamento do AAA (authentication, authorization e accounting).
- Descrever o funcionamento dos protocolos de segurança em redes sem fio: WPA, WPA2 e WPA3.
- Configurar uma WLAN utilizando WPA2 PSK através da interface GUI.

Mesmo que você não esteja trilhando os estudos para a certificação CCNA 200-301 você pode sim fazer esse curso para aumentar seus conhecimentos no mundo de Redes e mais especificamente sobre os serviços de redes citados na lista acima.

Mas se você está na trilha da certificação, saiba que esse curso aborda o **Tópico 5.0 ou "Security Fundamentals"**, o qual corresponde a **15% das questões do exame CCNA 200-301**.

Como a nova prova terá aproximadamente entre 100 e 120 questões, podemos dizer que **devem cair de 15 a 18 questões** relacionadas ao conteúdo desse curso, dependendo da quantidade total de questões que forem sorteadas para seu exame específico.

Não esqueça que ao final do curso você poderá emitir o seu certificado!

1.2 Sobre a Cisco e o CCNA - Cisco Certified Network Associate

A Cisco é uma empresa líder mundial em TI e redes, tendo seus produtos e tecnologias utilizadas por diversas empresas dos mais variados segmentos de mercado no mundo todo.

Fundada em 1984 por Len Bosack e Sandy Lerner atua até os dias de hoje com tecnologia de ponta e inovações que auxiliam no crescimento do mercado de TI.

A Cisco atua na área de Redes (com os famosos Roteadores e Switches), Software, Internet das Coisas, Mobilidade e Comunicação sem fio, Segurança, Colaboração (Voz e Vídeo sobre IP), Data Center, Cloud, Pequenos e Médios Negócios e Provedores de Serviço.

Para garantir que os profissionais que atuam com seus produtos e tecnologias realmente tem os conhecimentos técnicos necessários para desempenhar um bom trabalho, a Cisco desenvolveu um programa de **Certificação** com **Três Níveis** no início:

- **Associate ou CCNA (Cisco Certified Network Associate)**
- Professional ou CCNP (Cisco Certified Network Professional)
- Expert ou CCIE (Cisco Certified Internetwork Expert)

Mais especificamente falando da certificação **CCNA ou Cisco Certified Network Associate** é uma das primeiras certificações lançadas pela Indústria de Redes e com certeza a mais famosa até os dias de hoje.

A primeira versão de CCNA data de 1998 chamada de 640-407, o qual foi atualizado sete vezes até a última mudança feita em 2016 com a versão 200-125 (CCNA Routing and Switching em uma prova) e as versões do 100-105 e 200-105 (Modelo em duas provas: CCENT/ICND-1 + ICND-2).

Em **julho de 2019** foi anunciada uma grande mudança em maioria das certificações Cisco e o CCNA volta ao que era no início, sendo uma certificação unificada para diversas áreas e englobando não somente assuntos de Roteamento e Switching, mas também segurança, redes sem fio e automação de Redes.

Esse curso que você está prestes a iniciar faz parte da nossa trilha para a certificação **CCNA 200-301**.

O que se espera de um CCNA no mercado de trabalho?

Um profissional certificado CCNA deve conhecer uma larga gama de tecnologias e configurações de diversos equipamentos Cisco, tais como Roteadores, Switches, Access Points e Wireless LAN Controllers.

Além disso, deve estar preparado para a nova geração da Infraestrutura de TI, a qual a automação e programabilidade será cada vez mais utilizada.

Não confunda programabilidade com a necessidade de ser um programador, pois um profissional CCNA no mercado faz a operação e manutenção da Rede, não necessariamente precisará ser um programador e sim entender como utilizar algumas ferramentas e interagir com APIs.

É o primeiro passo de uma carreira promissora e que tem muitas possibilidades de crescimento nas mais diversas áreas de tecnologia de rede.

A seguir vamos falar sobre como a preparação para o **CCNA** está dividida no **Portal da DlteC** e como você deverá utilizar nosso material para conquistar sua certificação.

1.3 Plano de Estudos para o CCNA

Nesse novo modelo de prova existe apenas um caminho para obtenção da certificação CCNA que é através do exame 200-301, ou seja, não existe mais opção em duas provas como na versão anterior.

O **plano de estudos** para você ter sucesso na **CCNA** é o seguinte:



1. Ativar a trilha do curso **CCNA 200-301** no Menu Cursos (somente se você ainda não ativou)
2. Estudar o conteúdo de cada Capítulo dentro da trilha (sequência de capítulos/cursos expressa a seguir)
3. Repetir os comandos e demonstrações práticas realizadas pelo Prof. Marcelo durante as vídeo aulas como laboratório
4. Fazer os simulados que estão dentro do curso "**CCNA 200-301**"
5. A qualquer momento tirar as dúvidas do conteúdo utilizando os fóruns correspondentes de cada capítulo (*)
6. Passar para o próximo capítulo
7. Realizar a prova Final para treinar e obter o certificado do curso CCNA 200-301 (média da aprovação igual ou acima a 70 pontos em um total de 100)
8. Fazer o preparatório Final com laboratórios e questionários (em inglês) específicos para a certificação
9. Agendar a prova e realizá-la

O exame CCNA 200-301 é composto por uma prova em computador que pode ter de 100 a 120 questões (depende do sorteio que é feito por candidato).

Essas questões devem ser resolvidas em 120 minutos no dia do exame.

Cada um dos capítulos do curso um **Peso** associado na prova e quanto maior o peso, maior será a quantidade de questões desse assunto no exame, sendo que seguimos as recomendações da Cisco na divisão de questões para que você treine em um ambiente o mais real possível.

Para ser aprovado(a), você deverá conseguir obter entre 800 e 850 pontos de um máximo 1000 pontos no exame.

Se você ativou esse curso com o objetivo de tirar a certificação então a partir de agora, foco total no objetivo: **OBTER A CERTIFICAÇÃO.**

Você será aprovado(a) – já coloque isso “na cabeça”.

Para isso, pratique os comandos, leia os tópicos com cautela e, de preferência, marque logo o dia do seu exame (para você já ter uma data limite).

Faça o seu cronograma, estipule as horas de estudo e, sinceramente, não tem erro.

Repita essa frase todos os dias: **Eu serei aprovado(a).**

Se você assumir esse compromisso com sinceridade e vontade de vencer, tudo **dará certo.**

Estamos ao seu lado! Bons estudos!

(*) Os fóruns do curso são exclusivos para TIRAR AS DÚVIDAS DO CURSO, caso você tenha dúvidas do dia a dia ou que não tenham correlação com o curso utilize os grupos do Facebook ou Telegram para troca de ideias.

1.4 Como Estudar com o Material da DLteC

Nesse curso você terá **vídeo aulas, material de leitura e laboratórios em simuladores** para o aprendizado do conteúdo.

Posso somente ler ou assistir aos vídeos? NÃO RECOMENDAMOS!

O ideal é você assistir aos vídeos e na sequência ler os conteúdos ou...

... se preferir leia os conteúdos e depois assistia aos vídeos, tanto faz.

POR QUE LER E ASSISTIR?

Simples, porque **um conteúdo complementa o outro.** Principalmente se você está se preparando para a prova de certificação é crucial que você tanto veja os vídeos como a matéria de leitura!

Os questionários ou simulados com questões de prova estão dentro da estrutura da trilha do CCNA 200-301.

Siga a sequência sugerida no plano de estudos e **faça os questionários apenas depois** de ter lido, assistido aos vídeos e feito os laboratórios em simulador. Assim você terá um aproveitamento muito melhor do curso.

2 Tópicos do Curso vs Blueprint do CCNA 200-310 – Peso 15%

2.1 Introdução

Na tabela abaixo seguem os itens do blueprint ou conteúdo do exame Cisco CCNA 200-301 relacionados ao conteúdo do curso. Os capítulos que não aparecem explicitamente aqui fazem parte da matéria e complementam o aprendizado. Estude TODO o conteúdo do curso.

Security Fundamentals	
Fundamentos de Segurança de Redes	Capítulos do Curso
5.1 Define key security concepts (threats, vulnerabilities, exploits, and mitigation techniques)	Principais Conceitos de Segurança
5.2 Describe security program elements (user awareness, training, and physical access control)	Elementos de um Programa de Segurança
5.3 Configure device access control using local passwords	Controle de Acesso com Senhas Locais
5.4 Describe security password policies elements, such as management, complexity, and password alternatives (multifactor authentication, certificates, and biometrics)	Gerenciamento de Senhas
5.5 Describe remote access and site-to-site VPNs	Conceitos sobre VPNs
5.6 Configure and verify access control lists	Access Control Lists
5.7 Configure Layer 2 security features (DHCP snooping, dynamic ARP inspection, and port security)	Segurança em Camada 2
5.8 Compare authentication, authorization, and accounting concepts	Conceitos de AAA (Authentication, Authorization, and Accounting)
5.9 Describe wireless security protocols (WPA, WPA2, and WPA3)	Segurança em Redes Sem Fio
5.10 Configure WLAN using WPA2 PSK using the GUI	Segurança em Redes Sem Fio

3 Principais Conceitos de Segurança

3.1 Introdução



Para qualquer administrador de rede na atualidade o grande desafio é “como fornecer serviços de redes de maneira segura, protegendo informações privadas, pessoais e comerciais estratégicas” quando os usuários podem acessar essas informações dos mais diversos lugares e dispositivos.

Manter uma rede segura significa garantir a segurança dos usuários da rede e proteger os interesses comerciais.

Porém, o conceito de “Rede” está cada vez mais estendido, assim como o conceito de endpoint (o dispositivo do usuário de rede).

Para manter uma rede segura é necessário vigilância por parte dos profissionais de segurança, os quais devem estar sempre cientes das novas ameaças e ataques a redes, e as vulnerabilidades dos dispositivos e aplicações.

Esta informação é usada para se adaptar, desenvolver e implementar técnicas de **mitigação**.

No entanto, a segurança da rede é, em última análise, responsabilidade de todos que a utilizam.

Por esta razão, é trabalho do profissional de segurança de rede garantir que todos os usuários recebam treinamento de conscientização de segurança, assim como manter a rede segura e protegida, proporcionando um ambiente mais estável e funcional para todos.

A seguir vamos estudar os três princípios básicos da segurança: CIA.

3.2 Três Princípios Básicos de Segurança: CIA



Os três principais objetivos da segurança são:

- **Confidentiality** ou Confidencialidade
- **Integrity** ou Integridade
- **Availability** ou Disponibilidade



Não tem nada a ver com a agência de inteligência Norte Americana CIA! (brincadeira...)

Entende-se por **Confidencialidade** a proteção da informação compartilhada contra acessos não autorizados. Podemos garantir a confidencialidade pelo controle de acesso (senhas) e controle das operações individuais de cada usuário (log). Abaixo seguem mais alguns exemplos:

- Uso de mecanismos de segurança de rede (por exemplo, firewalls e listas de controle de acesso) para impedir o acesso não autorizado aos recursos da rede.
- Exigir credenciais adequadas (por exemplo, nomes de usuário e senhas) para acesso a recursos específicos da rede.
- Criptografar o tráfego para que um atacante não consiga decifrar todo o tráfego que ele capturar a partir da rede.

A **Integridade** é a garantia da veracidade da informação, que não pode ser corrompida, seja por alterações acidentais ou não autorizadas. Segue abaixo exemplos de violações de integridade:

- Modificar a aparência de um site corporativo
- Interceptar e alterar uma transação de comércio eletrônico
- Modificar os registros financeiros que são armazenados eletronicamente

A **Disponibilidade** é a prevenção de interrupções na operação de todo o sistema, seja ele hardware e/ou software. Por exemplo, uma quebra do sistema não deve impedir o acesso aos dados. Abaixo seguem mais alguns exemplos de como um invasor pode comprometer a disponibilidade de uma rede:

- Ele poderia enviar indevidamente dados formatados para um dispositivo de rede, resultando em um erro de exceção que o dispositivo não saberia tratar, interrompendo o serviço.
- Ele pode inundar um sistema de rede com uma quantidade excessiva de tráfego ou requisições. Esta sobrecarga iria consumir recursos de processamento do sistema e impedir que o sistema responda às muitas solicitações legítimas, fazendo com que o serviço seja negado aos usuários que realmente necessitam desse serviço. Este tipo de ataque é chamado de negação de serviço (DoS – Denial of service).

3.3 Vulnerabilidades (Vulnerabilities)



Podemos dizer que as **Vulnerabilidades** são as fraquezas nos protocolos e “furos” de segurança em sistemas e equipamentos que podem ser exploradas de forma não autorizada por atacantes.



Isso inclui protocolos, aplicações, programas, roteadores, switches, sistemas operacionais, desktops, servidores e até mesmo os próprios dispositivos de segurança.

Portanto, todos os itens citados acima são os **ativos ou assets**, ou seja, quaisquer elementos que tenham valor para a empresa ou organização, por isso mesmo eles precisam ser classificados, pois nem todo **asset** tem o mesmo valor para diferentes organizações. Na prática é o que queremos proteger e reduzir suas vulnerabilidades.

Além disso, as vulnerabilidades podem ser geradas pela própria tecnologia (furos de segurança nos sistemas e aplicativos), por falhas na configuração dos sistemas, por problemas na política de segurança da corporação ou até mesmo pelas pessoas.

Por exemplo, através de uma pessoa um atacante pode obter acesso privilegiado a determinado sistema ou aplicação da empresa através da Engenharia Social, que são meios de levar membros de uma corporação ou até mesmo uma pessoa física a fornecerem informações importantes, como o local de arquivos ou senhas, facilitando o processo de invasão.

Ela pode incluir sensibilizações ao ego de um funcionário ou pode ser uma pessoa disfarçada, ou com documento falsificado, que leva uma pessoa a fornecer informações confidenciais.

3.4 Exploits



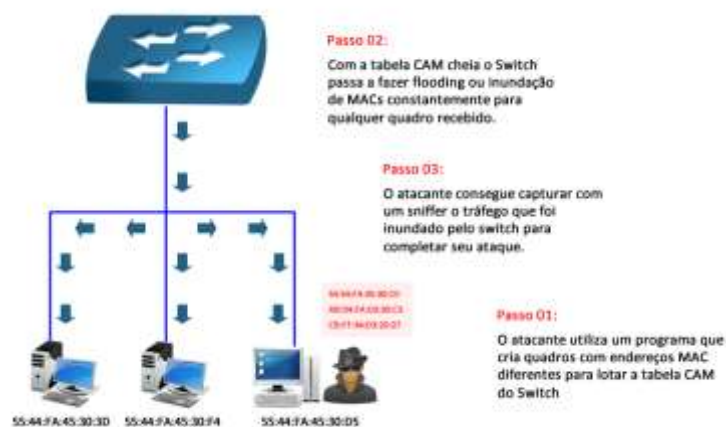
Uma vez descoberta uma vulnerabilidade ou fraqueza de um sistema, o que fazer para "explorar" essa fraqueza e facilitar um ataque? Uma boa maneira é utilizando um "Exploit".

Portanto, um exploit (em português explorar, ou seja, "usar algo para sua própria vantagem") geralmente é uma sequência de comandos, dados ou uma parte de um programa elaborado por atacantes que conseguem tirar proveito de um defeito ou **vulnerabilidade**.

Por exemplo, um switch tem cada porta separada em um domínio de colisão e, diferente de um Hub, cria um caminho único entre origem e destino. Isso é possível porque o switch guarda os endereços dos dispositivos conectados nas portas em uma tabela de endereços MAC.

Porém, essa tabela tem um limite e quando isso é atingido o switch "vira um hub", encaminhando os quadros para todas as portas e possibilitando a espionagem dentro de uma mesma VLAN.

Portanto, se alguém na mesma rede conseguir gerar endereços de camada-2 falsos em grande número e curto período, pode conseguir "espionar" o tráfego de todos os dispositivos em uma VLAN.



Essa é uma vulnerabilidade conhecida dos switches e pode ser explorada com o uso de um programa chamado Macof, o qual é um "exploit" bem conhecido para essa finalidade.

```

Konsole - root@localhost:~ - Konsole
File Sessions Settings Help
74412844(0) win 512
ed:85:61:21:52:39 23:d1:4c:26:6a:d8 0.0.0.0.57674 > 0.0.0.0.53397: S 1300147483:
1300147483(0) win 512
3d:34:3f:3a:95:3f a6:e7:34:17:e1:e6 0.0.0.0.5660 > 0.0.0.0.44476: S 1924679314:1
924679314(0) win 512
a:95:7e:11:ae:f8 12:fa:9b:69:ad:d2 0.0.0.0.54690 > 0.0.0.0.18370: S 691576310:691
576310(0) win 512
26:be:69:73:7d:6e a0:af:95:75:0:a9 0.0.0.0.50437 > 0.0.0.0.43058: S 1018604459:1
018604459(0) win 512
3a:68:e5:5e:3e:57 eb:15:49:69:fa:c5 0.0.0.0.49891 > 0.0.0.0.54332: S 577228608:5
77228608(0) win 512
77:40:75:7c:30:88 8d:c9:4f:2b:9a:a0 0.0.0.0.50485 > 0.0.0.0.45185: S 265027417:2
265027417(0) win 512
4f:95:16:17:b4:c0 6e:d7:3d:6d:9b:41 0.0.0.0.55695 > 0.0.0.0.11963: S 2100817091:2
100817091(0) win 512
e:41:4c:2d:1a:b1 e6:f4:20:24:8f:6d 0.0.0.0.12666 > 0.0.0.0.47609: S 2108239290:2
108239290(0) win 512
3e:27:e9:te:4f:te8 e4:c:6f:1e:4:2b 0.0.0.0.29287 > 0.0.0.0.19999: S 1932772224:193
2772224(0) win 512
da:dd:a8:7c:19:53 be:be:82:3:64:55 0.0.0.0.5933 > 0.0.0.0.60955: S 1590426598:15
30426598(0) win 512
4f:fb:95:34:dd:49 b7:d9:9b:58:ec:48 0.0.0.0.40979 > 0.0.0.0.59414: S 56985018:56
3885018(0) win 512

```

3.5 Ameaça, Risco e Ataque



As **Ameaças (Threat)** são os perigos em potencial contra a segurança da informação.

Por exemplo, uma ameaça clássica são os indivíduos que tem interesse em realizar ataques sempre estão procurando novos exploits e vulnerabilidades para o acesso não autorizado a redes e sistemas, ou então desejam informações privilegiadas para realizar delitos.

Essas ameaças podem ser tanto internas como externas à rede.

Além disso, podemos ter ameaças à infraestrutura física que podem incluir outros fatores que não sejam apenas de software ou configurações, tais como:

- **Ameaças ao hardware** – danos físicos à infraestrutura e equipamentos que fazem parte da rede.
- **Ameaças ao ambiente** – temperatura, umidade, sujeira, e outros motivos ambientais.
- **Ameaças elétricas** – sobretensão, picos de energia, descargas atmosféricas (raios), sistemas de proteção elétrica mal dimensionada, etc.
- **Ameaças à manutenção** – problemas de nomenclatura, ocasionando desligamento de equipamentos errados, janelas de manutenção mal dimensionadas, falta de manutenção preventiva, etc.

O **Ataque (Attack)** é a realização do que foi detectado como vulnerabilidade e colocado em prática por um atacante, por exemplo, através do uso de um exploit.

O **Risco (Risk)** à segurança da informação é a medida do impacto de vulnerabilidades e ameaças aos assets. É a probabilidade da realização de um ataque utilizando determinada vulnerabilidade.

Podemos classificar os riscos de segurança entre físico, lógico (das redes, por exemplo) e humano (engenharia social).

Portanto, cada asset tem vulnerabilidades (fraquezas) que podem ser exploradas (exploits) por atacantes visando acesso privilegiado, informações privilegiadas, destruição ou até mesmo uma negação de serviços (deixar o sistema indisponível temporariamente).

Esse conjunto representa as ameaças ou threats.

Qual a probabilidade dessa ameaça virar um ataque? Qual a consequência de um ataque realizado através dessa ameaça para a empresa? O que a perda ou até mesmo a destruição desse asset atacado pode gerar?

Esse é o risco ou risk!

3.6 Ataques Comuns às Redes de Computadores



Podemos dividir esses ataques em três classes: reconhecimento, acesso e negação de serviços.

Ataques de Reconhecimento (Reconnaissance) servem para a detecção não autorizada e o mapeamento de sistemas, serviços ou vulnerabilidades.

Ele também é conhecido como footprint ou coleta de informações e, é a fase inicial de uma invasão, onde o invasor está reconhecendo a rede e suas vulnerabilidades.

O invasor tenta com esses ataques descobrir uma forma mais fácil de invadir a rede, sejam equipamentos ou sistemas. Exemplos de ataques de reconhecimento:

- **Consultas de informações de Internet:** utilizando ferramentas como whois e nslookup para descobrir endereços de IP de entrada para a rede.
- **Varreduras de ping:** com os endereços IP's os atacantes podem enviar pings para determinar outros IP's de outras máquinas como opções de acesso para invasão.
- **Verificações de porta (port scan):** o port scan tem o objetivo de verificar quais portas TCP e UDP estão abertas na rede, ou seja, que o firewall permite acesso para identificação das vulnerabilidades a serem exploradas (exploits).
- **Sniffers de pacote:** permitem que o atacante analise a comunicação em busca de troca de pacotes TCP e UDP não seguras para capturar usuários, senhas e outras informações úteis ao ataque, utilizando um analisador de protocolos. Uma rede privativa ou um método de criptografia pode ajudar a evitar

Após o reconhecimento o **Ataque de Acesso (Access)** é a tentativa de entrada ou acesso utilizando normalmente um script ou uma ferramenta que explore uma fraqueza conhecida do sistema, aplicativo ou dispositivo que está sendo atacado para descobrir um usuário e senha válidos, por exemplo. Exemplo de ataque de acesso:

- **Ataque de senhas:** utilização de scripts e programas para descobrir usuários e senhas para acesso a um sistema ou dispositivo. Normalmente são tentativas repetidas de login em um recurso compartilhado, como um servidor ou roteador, para identificar uma conta de usuário, senha ou ambos, também conhecido como ataque de força bruta. Um exemplo é a ferramenta L0phtCrack.
- **Exploração de confiança (Trust Exploitation):** o objetivo desse ataque é invadir um host confiável, utilizando-o para preparar ataques em outros hosts de uma rede.
- **Redirecionamento de Porta (Port Redirection):** Um ataque de redirecionamento de porta é outro tipo de ataque baseado na exploração de confiança. O atacante usa um host comprometido para o acesso através de um firewall que seriam normalmente bloqueados para um micro não confiável.
- **Man-in-the-Middle ou Ataque de Intercepção:** O ataque "man in the middle" (literalmente "ataque do homem no meio" ou "ataques do interceptor"), às vezes chamado MITM, é um cenário de ataque no qual um invasor "ouve" uma comunicação (utilizando um sniffer) entre dois interlocutores e falsifica as trocas a fim de fazer se passar por uma das partes.
- **Spoofing de IP (Falsificação):** A principal característica do Spoofing é convencer alguém de que ele é algo que ele não é, conseguindo assim, autenticação para acessar alguma parte restrita à qual ele não tem permissão, através da falsificação do seu endereço de origem.

A **Negação de Serviços ou ataques DoS (Denial of Service)** são os mais temidos, é uma tentativa em tornar os recursos de um sistema indisponíveis para seus utilizadores ou clientes.

Alvos típicos são servidores web, e o ataque tenta tornar as páginas hospedadas indisponíveis na WWW.

Não se trata de uma invasão do sistema, mas sim da sua invalidação por sobrecarga. Exemplos de ataques de DoS:

- **DoS Distribuído (DDoS):** Em um ataque distribuído de negação de serviço (também conhecido como DDoS, um acrônimo em inglês para Distributed Denial of Service), um computador mestre (denominado "Master") pode ter sob seu comando até milhares de computadores ("Zombies" - zumbis), sendo que as tarefas de ataque de negação de serviço serão distribuídas a um "exército" de máquinas escravizadas.
- **TCP SYN Flood:** o atacante envia uma sequência de requisições SYN para um sistema-alvo visando uma sobrecarga direta na camada de transporte e indireta na camada de aplicação do modelo OSI.
- **Ataque de Smurf:** o invasor envia uma rápida sequência de solicitações de Ping (um teste para verificar se um servidor da Internet está acessível) para um endereço de broadcast. Usando spoofing (fazer passar por outro computador da rede para conseguir acesso a um sistema), o invasor faz com que o servidor de broadcast encaminhe as respostas não para o seu endereço, mas para o da vítima. Assim, o computador alvo é inundado pelo Ping.

Portanto, com um passo a passo bem estruturado e planejado, assim como lançando mão do uso de uma ou um conjunto de ferramentas conforme as citadas acima um atacante pode traçar seu plano e executar ataques tanto a redes domésticas ou corporativas.

3.7 Outros Tipos de Ameaças e Ataques



Os Buffers são áreas de memória criadas pelos programas para armazenar dados que estão sendo processados.

Cada buffer tem um certo tamanho, dependendo do tipo e quantidade de dados que ele irá armazenar.

O chamado “**estouro de buffer**” ou **Buffer Overflow**, falha muito comum até os dias atuais, ocorre quando o programa recebe mais dados do que está preparado para armazenar no buffer.

Se o programa não foi adequadamente escrito, este excesso de dados pode acabar sendo armazenado em áreas de memória próximas, corrompendo dados ou travando o programa, ou mesmo ser executado, que é a possibilidade mais perigosa.

Se um programa qualquer tivesse uma vulnerabilidade no sistema de login por exemplo, você poderia criar um programa que fornecesse caracteres de texto até completar o buffer e depois enviasse um executável, que acabaria rodando graças a essa vulnerabilidade de Buffer Overflow.

As **Botnets** são redes formadas por computadores infectados com Bots.

Estas redes podem ser compostas por centenas ou milhares de computadores, onde um invasor que tenha controle sobre uma Botnet pode utilizá-la para aumentar a potência de seus ataques, por exemplo, para enviar centenas de milhares de e-mails de Phishing ou Spam, desferir ataques de negação de serviço, etc.

De modo similar ao Worm, o Bot é um programa capaz de se propagar automaticamente, explorando vulnerabilidades existentes ou falhas na configuração de softwares instalados em um computador, o qual se torna um computador zumbi (zombie).

Além disso, temos outras ameaças como Keylogging, Virus, Trojan, Malware e Spyware são várias palavras para denominar uma série de “vilões” dos usuários, aqueles programas mal-intencionados cujo uso vai desde roubo de senhas e informações até o mais puro caos e destruição. Mesmo assim, muitos não sabem a diferença entre uma coisa e outra, chamando tudo de “vírus”, o que pode trazer algumas confusões na hora de se defender.

Os **MALWARES** são programas especificamente desenvolvidos para executar ações danosas em um computador. Exemplos: worm, bots, vírus, trojans...

Um **vírus** é uma sequência de código inserida em outro código executável, o qual tem as seguintes características:

- **Replicação:** os vírus se replicam para diversos arquivos da máquina a fim de garantir a sua sobrevivência dentro daquele sistema.
- **É ativado por uma ação externa:** por exemplo, um arquivo anexo de e-mail que está localizado na caixa de entrada do programa gerenciador de e-mails. Se este arquivo não for executado não há como a máquina ser infectada por esse vírus.

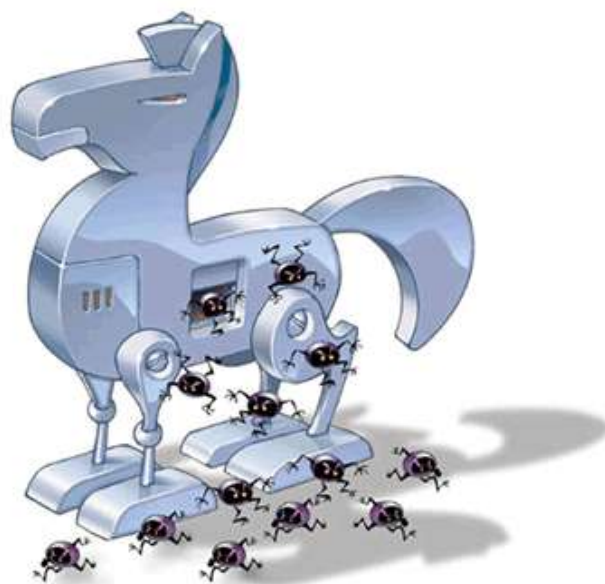
A infecção ocorre no momento que se executa o programa com código malicioso. A partir daí esse se espalha, ou seja, ele se multiplica danificando diversos arquivos e sistemas da máquina onde ele se encontra.



Pode-se citar também outro tipo de programa malicioso que é intitulado como trojan. Sua principal função é inserir um trecho de código em um programa aparentemente inofensivo, mas na verdade a intenção é colocar um hospedeiro na máquina invadida, deixando assim o invasor com o controle total da máquina.

Os **trojans** são um tipo de ferramenta que se popularizaram na Internet a partir de 1997, quando foi lançado o famoso Back Orifice (uma brincadeira com o nome Back Office da Microsoft). Um cavalo de tróia, ou trojan, é um programa que, quando instalado no sistema de alguém, geralmente abre uma porta TCP ou UDP para receber conexões externas, fornecendo normalmente o shell (prompt de comandos) daquele sistema para um possível invasor. Isso não é regra geral, já que alguns backdoors podem fazer também conexão reversa e outros tipos de técnicas. Um cavalo de Tróia nada mais é do que um backdoor disfarçado de um programa comum, como um jogo.

O termo "**cavalo de Tróia**" faz analogia ao cavalo de madeira que os gregos deram aos troianos, no famoso episódio da guerra de Tróia.



Um **worm**, assim como um vírus, cria cópias de si mesmo de um computador para outro, mas faz isso automaticamente. Primeiro, ele controla recursos no computador que permitem o transporte de arquivos ou informações. Depois que o worm contamina o sistema, ele se desloca sozinho. O grande perigo dos worms é a sua capacidade de se replicar em grande volume.



Por exemplo, um worm pode enviar cópias de si mesmo a todas as pessoas que constam no seu catálogo de endereços de e-mail, e os computadores dessas pessoas passam a fazer o mesmo, causando um efeito dominó de alto tráfego de rede que pode tornar mais lentas as redes corporativas e a Internet como um todo. Quando novos worms são lançados, eles se alastram muito rapidamente. Eles obstruem redes e provavelmente fazem com que você (e todos os outros) tenha de esperar um tempo maior para abrir páginas na Internet.

Na prática, todos os vírus e vários worms não podem se espalhar sem que você abra um arquivo ou execute um programa infectado.

Muitos dos vírus mais perigosos foram espalhados principalmente via anexos de e-mail, os arquivos que são enviados com as mensagens de e-mail.

Geralmente você tem como saber que um e-mail contém um anexo, pois este é exibido como um ícone de clipe de papel que representa o anexo e contém o seu nome.

Fotos, cartas escritas no Microsoft Word e até mesmo planilhas eletrônicas do Excel são apenas alguns dos tipos de arquivo que você pode receber através de e-mail a cada dia.

Um vírus é ativado quando você abre um arquivo anexo infectado.

Outro malware que ficou muito famoso é o **Ransomware**, o qual é um software malicioso que infecta um computador ou servidor e exibe mensagens exigindo o pagamento de uma taxa para fazer o sistema voltar a funcionar.

Essa classe de malware é um esquema de lucro criminoso, que pode ser instalado por meio de links enganosos em uma mensagem de e-mail, mensagens instantâneas ou sites.

Ele consegue bloquear a tela do computador ou criptografar com senha arquivos importantes predeterminados.

3.8 O Fator Humano



Uma das principais vulnerabilidades somos nós seres humanos utilizando os recursos de rede, dispositivos e aplicações em nosso dia a dia.

Essa é uma das principais vulnerabilidades e muitas vezes o elo mais fraco dessa corrente formada com mecanismos e dispositivos de segurança.

Abaixo segue uma lista de vulnerabilidades que podem ser exploradas contra os usuários dos serviços de redes e aplicativos de uma empresa ou até mesmo em sua vida pessoal.

- **Social engineering:** termo genérico de técnicas que visam explorar a confiança e comportamento social das pessoas para obtenção de vantagens, informações e até aplicar golpes.
- **Phishing:** disfarçar um convite malicioso como algo legítimo e confiável, normalmente realizado através de e-mails em massa.
- **Spear phishing:** ataque de phishing direcionado a um indivíduo, grupo específico de pessoas ou uma organização específica.
- **Whaling:** semelhante ao phishing, porém visando o alto escalão.
- **Vishing:** é um ataque de "phishing+voz" utilizando ligações telefônicas.
- **Smishing:** uso de mensagens de texto para fazer algo semelhante ao phishing, por isso o nome "Smishing=SMS+Phishing".
- **Pharming:** uma fusão das palavras "phishing" e "farming", é um tipo de crime virtual muito parecido com o phishing, em que o tráfego de um site é manipulado e informações confidenciais são roubadas.
- **Drive-by download:** é o nome genérico que se dá a qualquer página de internet maliciosa que tenta instalar programas sem a autorização dos visitantes. Isso é normalmente possibilitado por vulnerabilidades de segurança no navegador, que são exploradas por kits de ataque.
- **Watering hole:** É o nome de um golpe personalizado, em que os invasores atacam algum site que eles sabem que o alvo irá visitar. Uma vez no site em questão, o invasor coloca um código malicioso para realizar um "drive-by download".

Você recebe diversos e-mails de "phishing", mensagens que imitam comunicados corporativos, avisos de vencimentos de pagamentos, compras que você não fez aprovadas ou não aprovadas, ou seja, todos eles normalmente utilizados para direcionar nós internautas a sites falsos.

Nessa página de destino você ou o usuário da sua empresa vai encontrar uma infestação de "exploits", códigos que exploram falhas em programas instalados no próprio aparelho, para que algum deles consiga infectar o seu sistema ou do usuário de uma empresa.

Se você notou a lista de técnicas utilizadas para explorar os usuários de tecnologias de comunicação da atualidade em sua maioria derivam do Phishing.

Por exemplo, o spear phishing (pesca com arpão) trata-se de uma versão mais "personalizada" do phishing.

Por exemplo, enquanto o phishing é disparado para milhares ou até mesmo milhões de pessoas, o spear phishing é disparado para algumas poucas pessoas ou para uma única pessoa.

Por esse motivo, o texto do e-mail do spear phishing é altamente relacionado com as atividades diárias da vítima, o que facilita a aplicação do golpe e torna muito difícil que a vítima diferencie o golpe de algo normal do seu dia a dia.

3.9 Técnicas de Mitigação (Mitigation Techniques)



A palavra **mitigar** é muito comum quando começamos a estudar segurança, por isso mesmo veja a seguir o sentido da palavra no dicionário da língua portuguesa.

Mitigar: vtd 1 Amansar, tornar brando: Mitigar a indignação, a ira, o furor. vtd 2 Adoçar, aliviar, suavizar: Mitigar a dor. Com boas palavras procurei mitigar-lhe o desgosto. vtd 3 Acalmar, atenuar, diminuir: Mitigar a saudade. "...paramos à beira daquele olho-d'água, que nos mitigara a sede" (Gastão Cruls). vpr 4 Acalmar-se, tornar-se mais brando. "...nossa dor se mitigou para cuidarmos em brincar outra vez" (Joaquim Manuel de Macedo). Antôn: exasperar, aumentar.

Já sabemos que existem várias vulnerabilidades, as quais podem ser exploradas pelos atacantes através de "Exploits", os quais representam Riscos à Segurança.

As técnicas de mitigação são as medidas de segurança que os especialistas irão aplicar para resolver ou minimizar esses riscos.

Por exemplo, contra o ataque à switches e suas tabelas de endereço MAC, que estudamos durante a explicação do que é um exploit, podemos configurar um recurso simples de segurança presente nas portas dos switches Cisco que é o Port-Security.

Portanto, como mitigamos o ataque de MAC Table Overflow em um switch catalyst? Aplicando o recurso de port-security em suas portas de acesso.

Normalmente existem boas práticas ou best practices de segurança que devem ser seguidas para mitigar os principais problemas de configuração em dispositivos de infraestrutura de redes, vamos estudar algumas delas durante o curso.

Já no caso de malwares temos anti-vírus, anti-malwares e os próprios IPS's já estudados no curso de Fundamentos de Redes Cisco.

No final de tudo para mitigar problemas de segurança, vulnerabilidades e ataques serão utilizadas configurações, recomendações (boas práticas), dispositivos de segurança e muita monitoração.

4 Elementos de um Programa de Segurança

4.1 Introdução

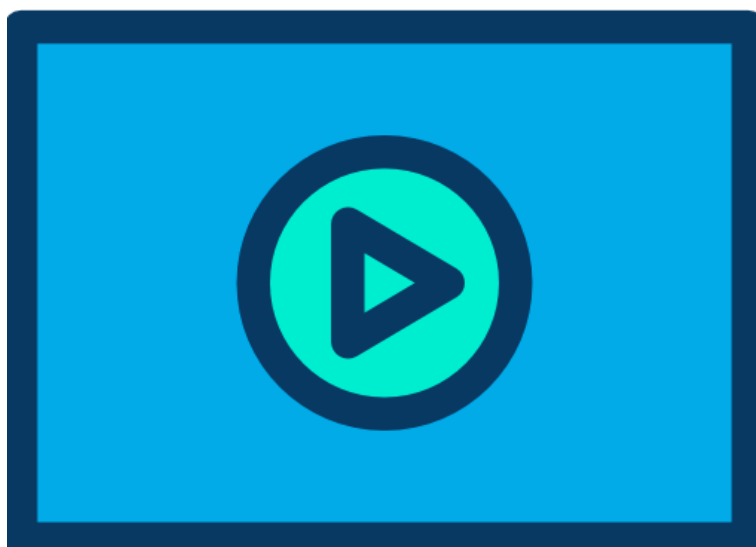


Para que um programa de segurança seja implementado e tenha sucesso é preciso muito esforço e constante aperfeiçoamento.

Os usuários, ou seja, a parte mais importante e elo mais fraco dessa cadeia deve estar ciente e bem preparado para enfrentar as diversas ameaças.

Para isso devemos garantir uma política de segurança clara e fazer com que esses conceitos sejam absorvidos por todos os envolvidos.

4.2 Política de Segurança



Uma Política de Segurança da Informação tem por objetivo possibilitar o gerenciamento da segurança em uma organização, estabelecendo regras e padrões para proteção da informação.

A política de segurança possibilita manter a confidencialidade, garantir que a informação não seja alterada ou perdida e permitir que a informação esteja disponível quando for necessário.

Os controles devem ser definidos levando em conta as características de cada empresa, definindo o que é permitido e o que é proibido.

A implantação, para ser bem sucedida, deve partir da diretoria da empresa para os demais funcionários (abordagem top down).

A política deve ser divulgada para todos os funcionários da organização, de forma a manter a segurança das informações.

O principal objetivo da política de segurança é para proteger os ativos de uma organização, os quais incluem mais do que apenas itens tangíveis.

Ativos implicar também coisas como a propriedade intelectual, processos e procedimentos, dados confidenciais de clientes e funções específicas de servidor (por exemplo, e-mail e aplicações web).

Além de proteger os ativos da organização, uma política de segurança serve para outros fins, tais como as seguintes:

- Manter os empregados cientes das suas obrigações, assim como das práticas de segurança;
- Identificar as soluções específicas de segurança necessárias para cumprir as metas da política de segurança;
- Atuar como uma base para monitoramento de segurança contínuo.

Uma política de uso apropriado (**Appropriate - ou Acceptable - Use Policy - AUP**) pode também ser parte de uma política de segurança.

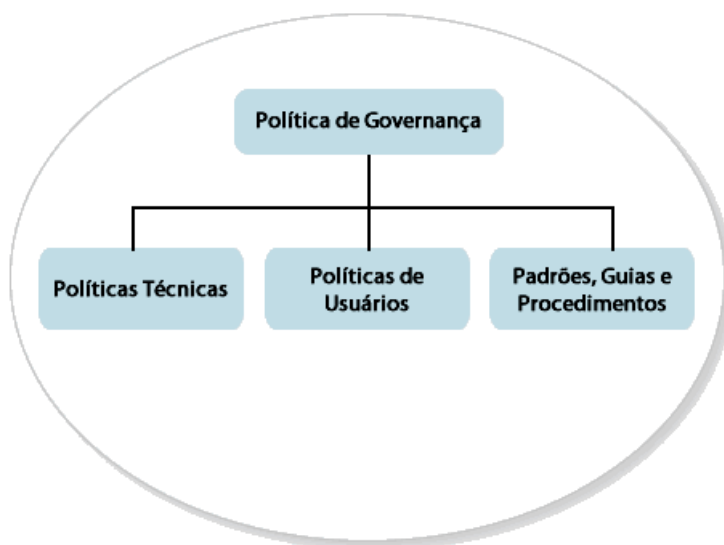
Ela deveria expressar o que os usuários devem e não devem fazer em relação aos diversos componentes do sistema, incluindo o tipo de tráfego permitido nas redes.

A AUP deve ser tão explícita quanto possível para evitar ambiguidades ou maus entendimentos.

Além disso, devido a uma empresa ter diversas áreas e cada uma delas com diversos níveis hierárquicos e diferentes preocupações, normalmente a política de segurança pode ser dividida em diversos documentos, porém todos devem seguir as mesmas diretrizes mesmo que separados.

Como mencionado anteriormente, uma política de segurança da organização normalmente é composta de vários documentos, cada um para um público específico.

Na figura a seguir você tem uma visão geral de alto nível destes documentos complementares.



Em um nível muito elevado, uma Política de Governança (Governing Policy) regula e aborda conceitos de segurança considerados importantes para uma organização.

A política de administração ou governança é dirigida principalmente a funcionários administrativos e técnicos. Abaixo estão listados os elementos típicos de uma política de governança:

- Identificar o tema abordado pela política
- Discutir a visão da organização sobre a questão
- Analisar a importância da política para o ambiente de trabalho
- Explicar como os funcionários cumprirão a política
- Enumerar as atividades, ações e processos adequados
- Explicar as consequências do descumprimento da política

Já as Políticas Técnicas (Technical Policy) fornecem um tratamento mais detalhado de uma política de segurança da organização.

O pessoal de segurança e de TI são os alvos dessas políticas técnicas, pois utilizam essas políticas no exercício das suas tarefas do dia a dia.

Os componentes típicos de políticas técnicas incluem tarefas específicas de segurança e pessoal de TI em áreas como as seguintes:

- E-mail
- Redes sem fio
- Acesso remoto
- Uso da Telefonia
- Uso dos recursos de TI como computadores e notebooks, etc.

Por último, as Políticas de Usuário tratam de questões de segurança e procedimentos relevantes para os usuários finais.

Por exemplo, um usuário final pode ser convidado a assinar uma política de uso aceitável (AUP) para acesso à Internet.

Essa AUP pode indicar que o acesso à Internet é somente para fins comerciais, caso um usuário final seja encontrado usando a Internet por razões pessoais, ele ou ela pode enfrentar as consequências previstas na política de governança.

Os demais documentos visam esclarecer mais aprofundadamente determinadas questões e especificar itens mais técnicos das políticas, podendo conter, por exemplo, as melhores práticas para uso do e-mail, etc.

São os documentos de apoio e detalhamento das políticas.

A responsabilidade final da política de segurança da empresa repousa sobre os ombros dos quadros superiores (por exemplo, o Chief Executive Officer - CEO).

No entanto, a gerência sênior de TI normalmente supervisiona o desenvolvimento de uma política de segurança, ao contrário de estar intimamente envolvido com a criação da política.

O pessoal de segurança ou TI Senior geralmente estão diretamente envolvidos com a criação da política de segurança.

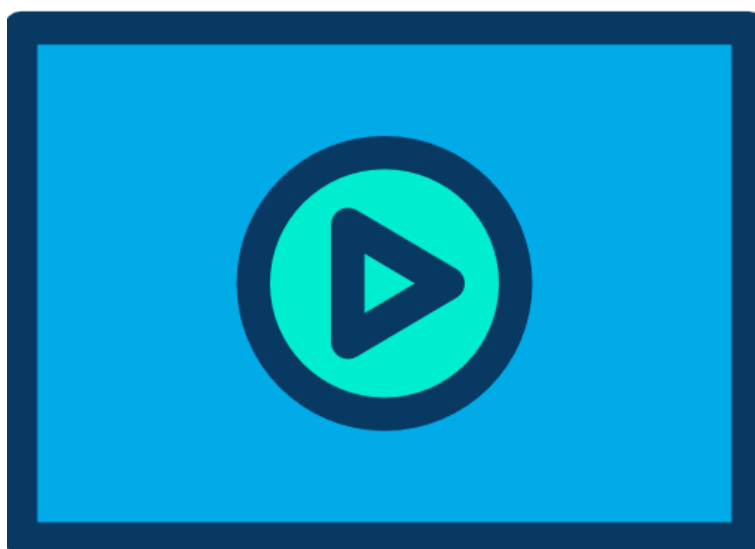
Esses indivíduos podem criar a política ou delegar a sua criação. Exemplos de segurança sênior ou pessoal de TI incluem:

- Chief Security Officer (CSO)
- Chief Information Officer ou Diretor de Informações (CIO)
- Chief Information Security Officer ou Diretor de Segurança da Informação (CISO)

Assim que uma política de segurança é criada, a segurança e a equipe de TI são responsáveis pela sua aplicação dentro da rede da organização.

Os usuários finais são responsáveis pelo cumprimento da política de segurança, por isso mesmo eles devem estar cientes dos riscos e como minimizá-los com o uso correto dos recursos de Tecnologia da Informação.

4.3 Treinamento e Conscientização dos Usuários



Mais importante que definir uma política de uso apropriado (**Appropriate - ou Acceptable - Use Policy - AUP**) é fazer com que os usuários estejam conscientes e bem treinados para o uso seguro das ferramentas de rede, serviços e aplicações de uma organização.

A conscientização, chamada de "**user awareness**", é trazer à tona os diversos riscos de segurança que o uso incorreto de ferramentas simples como e-mail e aplicativos de mensagem, por exemplo, podem trazer para seu dia a dia e para a empresa como um todo.

Por exemplo, a partir de um e-mail de phishing um usuário pode deixar entrar um malware que se replicará através dos diversos computadores conectados pela rede da empresa.

Esse malware pode ser um Ransomware, o qual invadirá um dos servidores e pode para uma operação da empresa por completo.

Por isso mesmo o processo de **treinamento dos usuários** é tão importante, sendo peça fundamental de qualquer programa de segurança que deseja ser bem sucedido.

Uma boa prática é implementar testes de campo periódicos com os usuários que participaram dos treinamentos.

Por exemplo, enviando e-mails simulando ataques de phishing ou outros ataques de engenharia social. Após a bateria de testes é importante reunir esse grupo de funcionários e mostrar o resultado dos testes, parabenizando aos que "passaram na prova de fogo" e incentivando os que "caíram" na armadilha a estarem melhor preparados numa próxima vez.

Nada melhor que envolver o time em um assunto tão importante de forma positiva, pois o resultado desse tipo de ação pode ajudar tanto na vida corporativa como na vida pessoal dos funcionários, uma vez que eles estarão menos propensos a cair em ciladas armadas pelos diversos atacantes do mundo virtual.

4.4 Controle Físico de Acesso



Muitas vezes nos preocupamos com senhas seguras, regras de firewall, assinaturas de IPS, porém o que adianta tudo isso se qualquer pessoa pode ter acesso aos dispositivos de infraestrutura de rede?

Por exemplo, com acesso físico a um roteador ou switch, por exemplo, uma pessoa pode realizar um "reset de senha" (password reset) e ter controle das informações, rotas e seja lá mais o que for preciso para fazer determinada ação "maliciosa". O "password reset" em dispositivos Cisco só pode ser feito tendo acesso local aos dispositivos.

Portanto, uma parte importante do programa de segurança é garantir que as pessoas corretas tenham o acesso devido a determinadas instalações da empresa.

Algumas medidas básicas para o ambiente físico devem ser consideradas nos projetos:

- Limitar acesso aos equipamentos de rede com trancas, isolando os equipamentos de rede;
- Utilizar controle de acesso via uso de credenciais, como crachás e biometria;
- Implantar sistema de monitoração por vídeo (vídeo surveillance) nos pontos de acesso à infraestrutura.

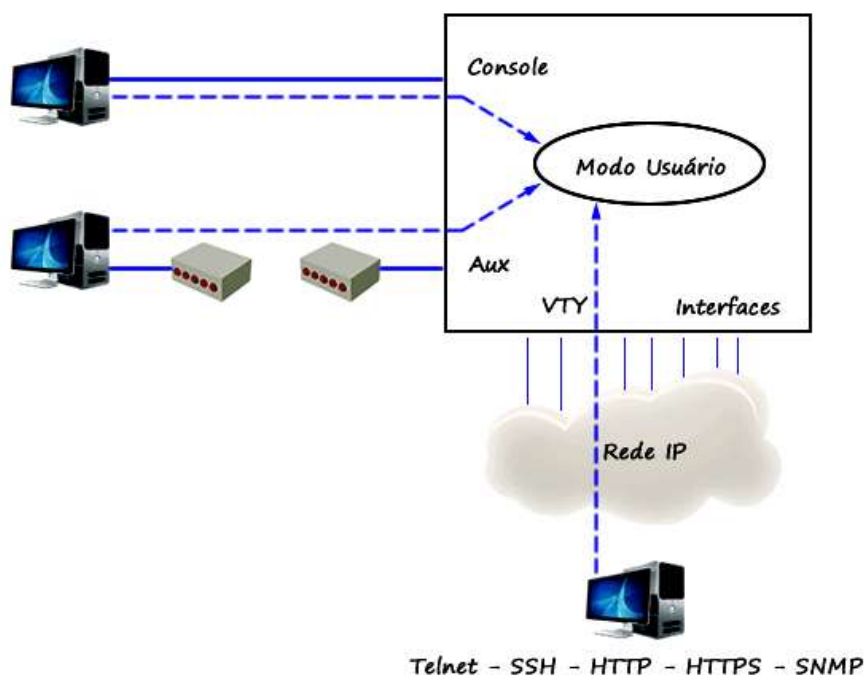
5 Controle de Acesso com Senhas Locais

5.1 Introdução



Como podemos acessar dispositivos como roteadores e switches Cisco? Simples, você já deve saber essa resposta:

1. Local via porta de console ou
2. Remoto através da rede IP via VTY (telnet ou SSH) ou porta auxiliar (Aux) utilizando um modem discado



Tanto para o acesso local como remoto você pode utilizar três tipos de **Autenticação**, pois é na autenticação que você utiliza uma "senha" (password):

- Sem usuário local com o comando "login"
- Com usuário local criado no próprio dispositivo com o comando "login local"
- Utilizando um servidor de autenticação remoto TACACS+ ou RADIUS (estudaremos em capítulos posteriores).

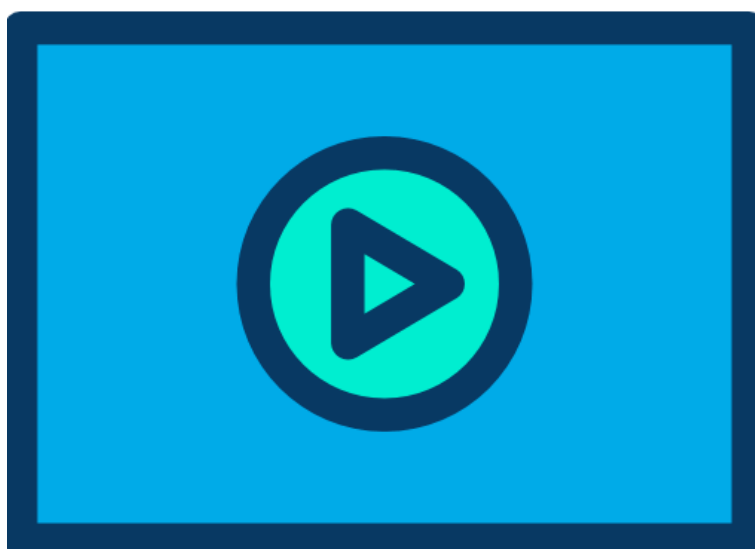


Por padrão, após acessar um dispositivo, seja de forma local ou remota, você entrará em um "prompt" de configuração com um nível de usuário sem privilégios (router>).

Para poder configurar o equipamento acessado você precisará entrar em modo privilegiado (router#) utilizando o comando "enable" e precisará de uma "senha de enable".

Portanto, estudaremos nesse capítulo ambas as etapas, ou seja, as senhas para acesso local/remoto e para acesso privilegiado.

5.2 Enable Secret: Senha para Acesso Privilegiado



A senha "**enable secret**" é um comando que deve ser executado em modo configuração global e tem o objetivo de restringir o acesso ao modo EXEC privilegiado.

No comando enable secret é utilizado um algoritmo de hash (criptografia) Message Digest 5 (MD5) para proteger a senha contra leitura no comando "show running-config" ou "show startup-config".

Se a senha de enable for perdida ou esquecida, ela deve ser trocada utilizando o processo de recuperação de senha. Veja a seguir um exemplo de aplicação.

```
Router>enable
Router#config term
Router(config)#enable secret dlt3c@!
Router(config)#end
Router#disable
Router>enable
Password:
```

Após configurada a senha de enable será necessário digitar a senha para ter acesso ao modo privilegiado. Veja no comando show running-config que a senha de enable secret vem criptografada.

```
Router#show running-config
Building configuration...

Current configuration : 499 bytes
!
version 12.4
no service timestamps log datetime msec
no service timestamps debug datetime msec
no service password-encryption
!
hostname Router
!
enable secret 5 $1$mERr$hx5rVt7rPNoS4wqbXKX7m0
!
```

O 5 que aparece na configuração significa que a criptografia é MD-5 e os caracteres \$1\$mERr\$hx5rVt7rPNoS4wqbXKX7m0 é a senha criptografada.

Existe ainda o **enable password**, porém esse comando não deve ser utilizado por não ser criptografado.

O enable password, apesar de não ser criptografado, foi mantido nas versões mais novas de IOS como uma forma de compatibilidade com versões mais antigas em caso de necessidade de um downgrade de versão, ou seja, necessidade de uma versão antiga de IOS que não suporte o comando "enable secret".

5.3 Acesso Local e Remoto Sem Usuário Local



Essa é a configuração mais simples para as linhas (lines) de console, VTY e Aux.

Basta definir a senha com o comando "password" e utilizar o comando "login" para que essa senha seja pedida quando o dispositivo receber uma tentativa de acesso.

Veja exemplo da configuração da linha de console a seguir.

```
Router#
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#line console 0
Router(config-line)#password D1t3c@!
Router(config-line)#login
Router(config-line)#end
Router#
%SYS-5-CONFIG_I: Configured from console by console
```

```
Router#
Router#show running-config | begin line con
line con 0
  password D1t3c@!
  login
line vty 0 4
  login
!
!
!
end
```

O sub-comando "**password**" define a senha como **D1t#c@!** e o "**login**" faz com que a senha seja solicitada ao conectar um laptop via cabo de console.

Note no show running-config que a senha definida é mostrada em texto claro, pois com exceção da senha secreta (enable secret) isso ocorrerá com todas as outras senhas.

Para resolver esse problema entre com o comando "**service password-encryption**", o qual criptografará todas as senhas em modo texto com um hash proprietário da Cisco de nível 7, porém saiba que essa criptografia é facilmente quebrada através de sites da Internet.

5.4 Configurando um Usuário e Senha Local para Acesso Administrativo



Outra maneira de configurar o acesso administrativo local e remoto é utilizando um usuário e uma senha local com o comando "**username**".

Existem algumas opções de configurar o usuário e a senha, veja as mais comuns:

1. **username** usuario **password** senha
2. **username** usuario **secret** senha

A diferença entre os dois é que o primeiro vem sem criptografia, necessitando do comando "**service password-encryption**" para ser criptografado.

Já a opção 2 é como o **enable secret**, o qual vem criptografado com MD-5.

Para ativar nas lines utilize o comando "**login local**", não sendo mais necessário configurar o comando "**password**".

Veja um exemplo de configuração a seguir.

```
R1#conf t
Enter configuration commands, one per line.  End with CNTL/Z.
R1(config)#username Admin secret ciscoooooo
R1(config)#username User password ciscoooooo
R1(config)#line cons 0
R1(config-line)#login local
R1(config-line)#line vty 0 4
R1(config-line)#login local
R1(config-line)#end
R1#
R1#sho run
Building configuration...

Current configuration : 1114 bytes
!
version 12.4
```

```
!  
... saida omitida  
!  
username Admin secret 5 $1$dbJB$2eahYM/Nx08dcDOjbEiHr1  
username User password 0 ciscoooooo  
!  
!  
... saida omitida  
!  
line con 0  
  login local  
line aux 0  
  login local  
line vty 0 4  
  login local  
!  
!  
End
```

Após a configuração veja um teste de acesso telnet como fica o prompt inicial.

```
R1#  
*Apr 21 16:41:27.303: %SYS-5-CONFIG_I: Configured from console by console  
R1#  
R1#telnet 192.168.1.110  
Trying 192.168.1.110 ... Open
```

User Access Verification

```
Username: Admin  
Password:  
R1>
```

Algumas versões de IOS tem o serviço de AAA ativado por padrão, nesse caso o comando **login local** não irá funcionar, para utilizar a configuração acima digite "**no aaa new-model**". O AAA será estudado no posteriormente.

5.5 Tipos de Senhas no Cisco IOS



Vamos nos aprofundar um pouco mais no assunto senhas no Cisco IOS.

No total temos seis tipos de senhas, das quais já estudamos quatro delas.

Para começar temos a senha **Type 0 ou Tipo 0**, o que significa que a senha será armazenada sem criptografia nos arquivos de configuração dos dispositivos, ou seja, em texto claro.

Como é o caso do "enable password cisco123", por exemplo, ao entrar com o comando "show run" você conseguirá ler "cisco123" na linha correspondente ao comando.

Depois podemos ter uma senha **Type 4 ou tipo 4**, que significa que ela será armazenada nos arquivos de configuração utilizando um hash SHA-256. Veja exemplo a seguir.

```
enable secret 4 Rv4kArhts7yA2xd8BD2YTVbts
```

Esse tipo de senha foi removido do Cisco IOS e não é mais utilizada.

Um outro tipo de senha que já até estudamos é a **"Type 5"**, ou seja, será armazenada na "running-config" e "startup-config" criptografada com um Hash MD5. Veja exemplo a seguir.

O comando "enable secret cisco123" vira no arquivo de configuração:

```
enable secret 5 00271A5307542A02D22842
```

A senha **"Type 7" ou tipo 7** é armazenada com a criptografia **Vigenere cipher** e é ativada com o comando "service password-encryption", a qual muitos websites permitem que você copie e cole a senha para quebra instantânea. Veja exemplo a seguir da senha tipo 7.

```
enable password cisco123
service password-encryption
```

Após um "show run" você verá a seguinte linha:

```
enable password 7 094F471A1A0A464058
```

O penúltimo tipo de senha é a **"Type 8"**, a qual utiliza o Password-Based Key Derivation Function 2 (PBKDF2) com o Secure Hash Algorithm de 26 bits (SHA-256) como algoritmo de hashing. Esse método pode ser utilizado tanto para senhas de enable como para criação de usuários e senhas mais seguras. Veja exemplo a seguir.

```
R1(config)#enable algorithm-type sha256 secret cisco
R1(config)#do sh run | include enable
```

```
enable secret 8 $8$mTj4RZG8N9ZD0k$e1Y/asfm8kD3iDmkBe3hD2r4xcA/0oWS5V3os.O91u.
```

```
R1(config)# username yasser algorithm-type sha256 secret cisco
R1# show running-config | include username
```

```
username yasser secret
$8$dsYGNam3K1SIJO$7nv/35M/qr6t.dVc7UY9zrJDWRVqncHub1PE9U1MQFs
```

8

Por último, a senha do tipo 9 ou Type 9 será criptografada utilizando scrypt como algoritmo de hashing. Ela iniciou a ser utilizada a partir do Cisco versão 15.3(3). Veja exemplo a seguir.

```
R1(config)#enable algorithm-type scrypt secret cisco
R1(config)#do sh run | include enable

enable secret 9 $9$WnArItcQHW/uuE$x5WTLbu7PbzGDuv0fSwGKS/KURsy5a3WCQckmJp0MbE

R1(config)# username demo9 algorithm-type scrypt secret cisco
R1# show running-config | include username

username demo9 secret 9
$9$nhEmQVczB7dqsO$X.HsgL6x1l10RxkOSSvyQYwucySCt7qFm4v7pqCxxKM
```

Se colocarmos em uma escala de "força" de criptografia temos: 9 > 8 > 4 > 5 > 7 > 0.

Tenha cuidado com o seguinte, se você configurar senhas tipo 8 ou 9 em dispositivos e depois precisar fazer um downgrade para uma versão de Cisco IOS que não suporte esses níveis de criptografia, será necessário antes de realizar o procedimento criar senhas nível 5.

Caso você não faça isso será necessário quebrar a senha do dispositivo em questão, pois você perderá acesso a esses usuários ou senhas tipo 8 e/ou 9.

Apesar de consideradas fortes, as senhas do tipo 4 e 5 podem ser quebradas com aplicações como o "Cain", essa quebra de criptografia poder levar um tempo considerável, mas é possível.

6 Gerenciamento de Senhas

6.1 Introdução



Quantas senhas pessoais você utiliza hoje no seu dia a dia? Você saberia dizer agora?

E no seu dia a dia como colaborador de uma empresa... Quantas senhas você utiliza atualmente? Quantos sistemas corporativos você acessa que necessitam de um usuário e senha diferentes?

Agora vamos pensar no outro lado: você como responsável por todos esses sistemas, aplicações, acessos aos diversos dispositivos de redes, etc.

Como você administra ou administraria essa quantidade de acessos necessários em sua empresa?

Quando trazemos essa questão à tona no mundo da Infraestrutura de TI normalmente é possível um certo nível de integração utilizando AAA e servidores de autenticação remotos, porém mesmo assim o gerenciamento de senhas é um assunto importante e vamos estudar mais sobre isso nesse capítulo do curso.

6.2 Política de Senhas



Uma parte importante no gerenciamento de senhas é ter uma política de senhas (password policies) formalmente descrita e conhecida por todos os usuários.

Nessa política de senhas é importante definir alguns itens, tais como:

- Quantidade de caracteres (**Length** ou comprimento)
- Complexidade (**Complexity**)
- Validade (**Age**: mínimo e máximo)
- Histórico (**History**) de senhas

A quantidade de caracteres varia de acordo com o sistema operacional ou aplicação, porém o recomendado é no mínimo entre 6 a 8 caracteres, pois quanto menor a senha mais fácil de ser quebrada.

A complexidade envolve o uso de caracteres maiúsculos/minúsculos, números e caracteres especiais. Quanto maior a variabilidade de caracteres em uma senha mais segura ela se torna, pois ela acaba ficando menos óbvia.

A validade ou idade (age) de uma senha também é fator importante, pois uma senha muito antiga pode acabar sendo descoberta por observação, por exemplo.

Quando falamos de idade de uma senha podemos definir um prazo máximo, por exemplo, a senha deve ser trocada a cada 30 dias, assim como ter um mínimo.

O histórico de senhas garante que o usuário não tente utilizar a mesma senha várias vezes.

Por exemplo, considerando uma validade de senha de 10 dias e também define para o sistema guardar um histórico de cinco senhas, portanto, o usuário só poderá usar uma senha antiga daqui a 60 dias.

Agora vamos explicar para que o tempo mínimo da troca de senhas serve.

O prazo mínimo para troca de senhas evita que o usuário troque rapidamente uma senha para voltar a um padrão antigo e bem conhecido, por exemplo, um usuário "esperto" ouve falar que o histórico da senha é igual a 5, então rapidamente ele faz as 5 alterações aleatórias para que na sexta ele volte ao padrão conhecido.

Com uma validade mínima você evita esse tipo de atitude, pois ele não conseguirá alterar a senha rapidamente.

Por último, quando falamos de senha temos que lembrar do "armazenamento" dessas senhas!

Não adianta ter uma senha forte anotada em um "sticker" colado na tela do PC.

É importante conscientizar os usuários com relação às boas práticas tanto para criar uma senha segura, assim como para armazená-la.

Uma boa alternativa para guardar senhas de forma segura são os gerenciadores de senha ou **Password Managers**.

Com o uso de **password managers** você pode encorajar aos usuários criarem senhas mais fortes, pois eles não precisarão guardar na sua própria memória essas senhas, além do que vários aplicativos já fornecem proteção extra contra gravação do teclado (keystroke logging) em dispositivos ou sites comprometidos.

Se você nunca ouviu falar, o Keystroke logging ou registro de batimento de teclas, muitas vezes referido como keylogging ou captura de teclado, é a ação de gravar as teclas digitadas em um teclado, tipicamente de forma escondida, de modo que a pessoa que usa o teclado não sabe que suas ações estão sendo monitoradas.

Esse é um recurso muito comum de espionagem para descobrir usuários, senhas e até mesmo as mensagens digitadas por usuários de um determinado sistema que foi comprometido com um **"Keylogger"**.

6.3 Alternativas de Senhas



Podemos também reforçar as senhas de acesso ou até mesmo ter alternativas de autenticação, tais como:

- Autenticação multifator (MFA - Multi-Factor Authentication)
- Certificados digitais
- Biometria

A autenticação multifator (MFA) é um sistema de segurança que verifica a identidade de um usuário exigindo várias credenciais. É um componente crítico de gerenciamento de identidade e acesso (IAM - identity and access management).

Em vez de apenas pedir um nome de usuário e senha, o MFA exige outras credenciais adicionais. Por exemplo, um código do smartphone do usuário, a resposta a uma pergunta de segurança, uma impressão digital ou reconhecimento facial.

Veja exemplo a seguir de MFA onde para o usuário acessar determinado sistema ele precisará inserir um usuário e senha, depois confirmar o recebimento de um código via SMS para seu celular cadastrado e por último provar que ele é "ele mesmo" com sua impressão digital.



Portanto, o MFA é uma forma eficaz de fornecer segurança aprimorada, pois nomes de usuário e senhas tradicionais podem ser roubados e estão cada vez mais vulneráveis a ataques de força bruta.

O MFA cria várias camadas de segurança para ajudar a aumentar a confiança de que o usuário que solicita acesso é realmente quem afirma ser.

Exemplos de autenticação multifator incluem o uso de uma combinação desses elementos para autenticar:

- Códigos gerados por aplicativos de smartphone
- Crachás, dispositivos USB ou outros dispositivos físicos
- Soft tokens, certificados digitais
- Impressões digitais (biometria)
- Códigos enviados para um endereço de e-mail ou SMS
- Reconhecimento facial
- Digitalização de retina ou íris
- Respostas a perguntas de segurança pessoal

Quando se trata de MFA, normalmente nos referimos a três tipos de fatores de autenticação:

- **Coisas que você sabe** (conhecimento ou knowledge), como uma senha ou PIN
- **Coisas que você tem** (posse ou possession), como um crachá ou smartphone
- **Coisas que você é** (herança ou inheritance), indicadas por biometria, como impressões digitais ou reconhecimento de voz

As soluções MFA mais recentes incorporam fatores adicionais, considerando o contexto e o comportamento durante a autenticação. Por exemplo:

- **Onde você está ao tentar obter acesso**, por exemplo, em uma cafeteria ou em casa?
- Quando você está tentando acessar, por exemplo, tarde da noite ou durante o dia de trabalho?
- **O dispositivo que você está usando**, por exemplo, um smartphone ao em vez de um laptop?
- **Que tipo de rede você está acessando**, por exemplo, uma rede privada ou pública?

Frequentemente chamado de Autenticação Adaptável (Adaptive MFA), esse tipo de MFA aproveita a inteligência artificial (IA) e o aprendizado de máquina para sinalizar logins fora do comum e ajustar a aplicação de MFA com base no nível de risco.

Quando um usuário exibe um comportamento atípico, como o login de um novo local ou hora incomum, a autenticação adaptável aumenta a segurança solicitando fatores de autenticação adicionais, como um código de verificação de e-mail ou verificação biométrica.

Por outro lado, também pode reduzir ou remover o requisito de MFA se o login exibir um comportamento típico do usuário.

Isso permite que os administradores habilitem o acesso rápido e reduzam os riscos de segurança adicionais quando os funcionários e executivos trabalham remotamente.

Por exemplo, se um usuário decidir fazer o login de um café durante o intervalo do almoço, e isso não é típico para esse usuário, a ferramenta MFA pode exigir que o usuário digite um código por mensagem de texto para o telefone do usuário para verificar se ele é quem diz ser mesmo.

Se isso se tornar uma ocorrência regular, o mecanismo de risco eventualmente aprenderá o comportamento do usuário e deixará de exigir o envio de um fator de autenticação adicional, se habilitado pelo administrador.

6.4 Reforçando as Políticas de Senhas no Cisco IOS.



Apesar de não cair na prova, vamos estudar alguns comandos para materializar o gerenciamento de senhas e alguns reforços que podemos implementar no Cisco IOS.

Para o Cisco IOS 12.3(1) ou acima um comando em modo de configuração global foi adicionado para definir o tamanho mínimo de caracteres para as senhas a serem configuradas.

Segue a sintaxe do comando a seguir.

```
R1(config)#security passwords min-length ?  
  <0-16>  Minimum length of all user/enable passwords  
  
R1(config)#security passwords min-length 10  
R1(config)#  
R1(config)#enable secret cisco  
% Password too short - must be at least 10 characters. Password configuration failed  
R1(config)#end
```

R1#

Perceba que após a configuração para um mínimo de 10 caracteres (security passwords min-length 10) foi tentado configurar a senha de enable com menos que o permitido (enable secret cisco) e uma mensagem de erro foi mostrada (% Password too short - must be at least 10 characters. Password configuration failed) indicando que a senha é muito curta e menor que 10 caracteres.

Você pode configurar para que a senha tenha no máximo 16 caracteres, o mínimo recomendado na maioria das documentações são 8 caracteres.

Além disso, para acesso remoto via rede IP você pode definir o máximo de tentativas de login e até bloqueios se essas tentativas forem excessivas, por exemplo, para proteger contra ataques de dicionário. Veja comandos abaixo.

Para habilitar a segurança avançada no processo de login você deverá configurar os seguintes parâmetros:

1. Atrasos entre sucessivas tentativas de login:

```
Router# configure terminal
!  
! item 1 - você determina o atraso (delay) em segundos sendo o padrão 1 seg  
!  
Router(config)# login delay segundos
```

2. Entrar em shutdown se um ataque de DoS está sob suspeita:

```
!item 2 - o primeiro comando determina o bloqueio e o segundo quem não deve  
passar por essa regra  
!  
Router(config)# login block-for segundos attempts tentativas within segundos  
Router(config)# login quiet-mode access-class {acl-name | acl-number}
```

3. Geração de mensagens de log do sistema para registrar as tentativas login:

```
! item 3 - faz o log das tentativas de login que falham e tem sucesso  
!  
Router(config)# login on-failure log [every login]  
Router(config)# login on-success log [every login]
```

Exemplo Prático: configure o roteador para que ele bloqueie o login por 3 minutos se forem realizadas 6 tentativas de acesso em um prazo de 30 segundos.

```
Router(config)# login block-for 180 attempts 6 within 30
```

Agora se houver uma quebra na regra de segurança o roteador bloqueará acesso por 180 segundos ou 3 minutos.

Para que não haja problemas de acesso aos PCs de gerenciamento que realmente são permitidos acesso você deve escolher os IP's permitidos com uma ACL e utilizar o comando "login quiet mode" para definir os micros que poderão fazer o login mesmo com o roteador ainda em bloqueio.

Existem dois momentos distintos nessa monitoração, o watch time ou tempo de vigília e o quiet mode ou modo de silêncio.

O primeiro é quando está tudo normal e o roteador está monitorando os acessos, caso ele contabilize uma quebra na regra o roteador entra no quiet mode, ou seja, em bloqueio do acesso remoto.

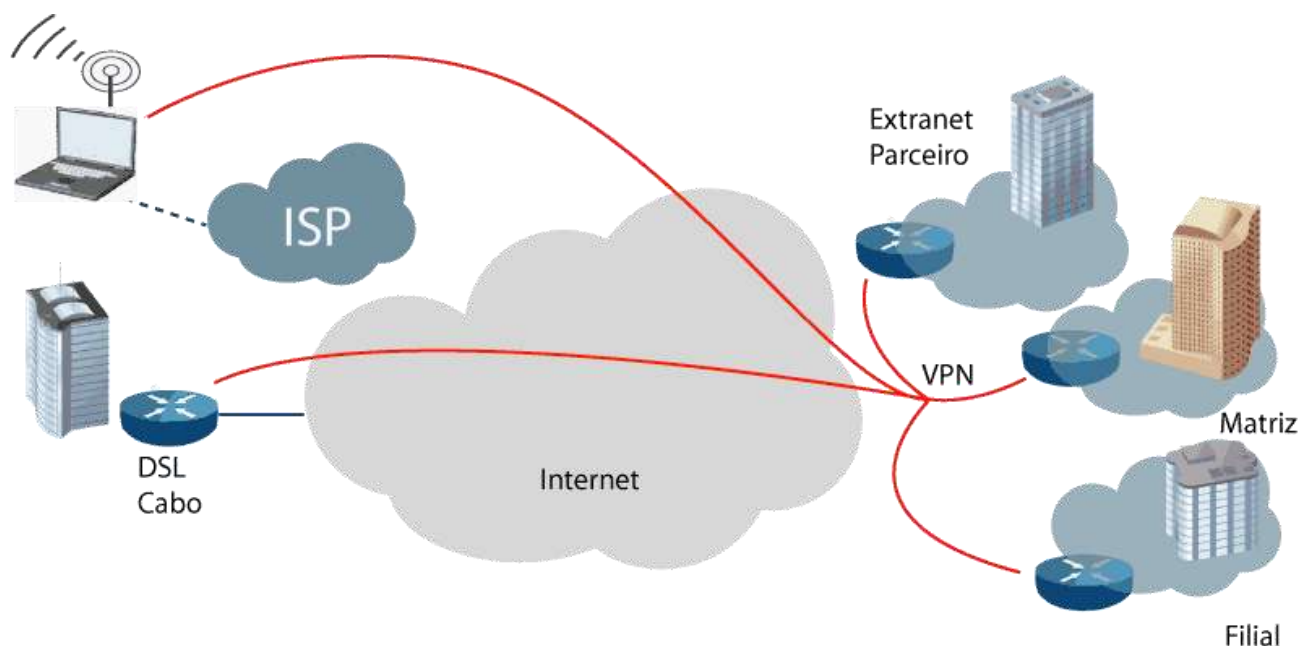
7 Conceitos sobre VPNs

7.1 Introdução



Uma Rede Virtual Privada ou Virtual Private Network (VPN) tem a função principal de permitir a criação de redes privadas através da Internet, permitindo privacidade e tunelamento de protocolos dentro TCP/IP, visando acesso remoto de usuários que trabalham em Home Office ou de Unidades Remotas através da Internet.

As VPNs são usadas diariamente para dar acesso corporativo à rede para usuários remotos, conectividade a escritórios remotos utilizando um meio público como a Internet, sendo uma opção mais barata que circuitos dedicados. Também podem ser uma opção para links de contingência utilizando tecnologias como ADSL ou Internet via cabo coaxial. Veja na figura uma topologia básica de aplicação de uma VPN em um ambiente corporativo.



Na construção de uma VPN são empregadas diversas técnicas combinadas como autenticação, criptografia e tunelamento.

Os protocolos mais comuns para realização de VPNs ou tunelamento via IP são:

- Layer 2 Forwarding (L2F)
- Point-to-Point Tunneling Protocol (PPTP)
- Layer 2 Tunneling Protocol (L2TP)
- Generic Routing Encapsulation (GRE)
- IPSec

Note que uma VPN é um protocolo encapsulado e criptografado passando dentro do pacote IP, o que gera um grande overhead (cabeçalho adicional) devido às técnicas de tunelamento e criptografia utilizadas.

Na realidade o GRE não é um recurso de VPN, ele faz um tunelamento sem segurança necessitando de um protocolo auxiliar para realizar a criptografia dos dados. A vantagem do GRE é o suporte simultâneo à segurança e roteamento.

7.2 Fundamentos de VPN – Requisitos de Segurança

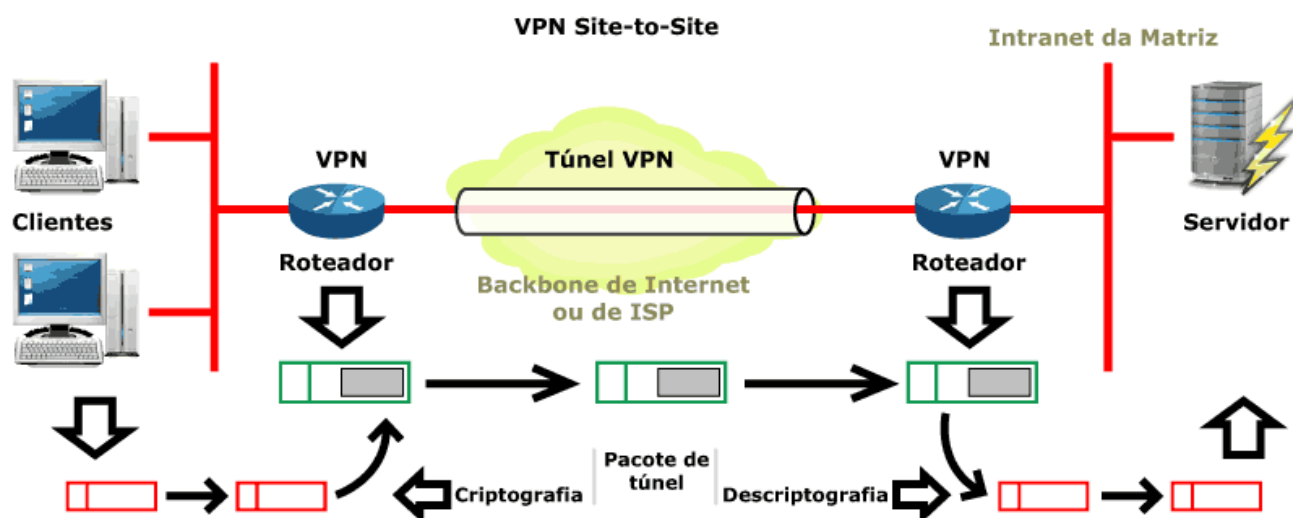


Se compararmos uma VPN com um link dedicado existem alguns pontos que precisamos tratar relacionados à segurança em uma VPN, pois o link dedicado por si só já garante a segurança da comunicação, porém uma VPN está passando os dados de uma pessoa ou empresa por um meio inseguro como a Internet, expondo esses dados a diversos riscos. Por isso, uma VPN deve contemplar os seguintes itens de segurança:

- **Confidencialidade:** A confidencialidade dos dados é fornecida através da criptografia dos dados e evita que, se um terceiro (hacker) interceptar os dados criptografados, ele não poderá interpretá-lo.
- **Integridade:** A integridade de dados garante que os dados não serão modificados em trânsito. Por exemplo, roteadores em cada extremidade de um túnel podem calcular um valor de checksum ou um valor de hash para os dados transmitidos. Se os dois roteadores na recepção recalcularem o valor e o resultado for o mesmo, significa que os dados muito provavelmente não tenham sido modificados em trânsito.
- **Autenticação:** autenticação de dados permite que as partes envolvidas na comunicação verifiquem se a outra parte é quem realmente diz ser.
- **Não Repúdio (Anti-replay):** O não repúdio juntamente com a autenticidade compreende o que poderia ser chamado de "responsabilidade final", ou seja, busca-se fazer a verificação da identidade e autenticidade de uma pessoa ou agente externo de um sistema a fim de assegurar a integridade de origem impedindo que um agente no meio do caminho capture pacotes e reenvie-os como se fossem pacotes legítimos.

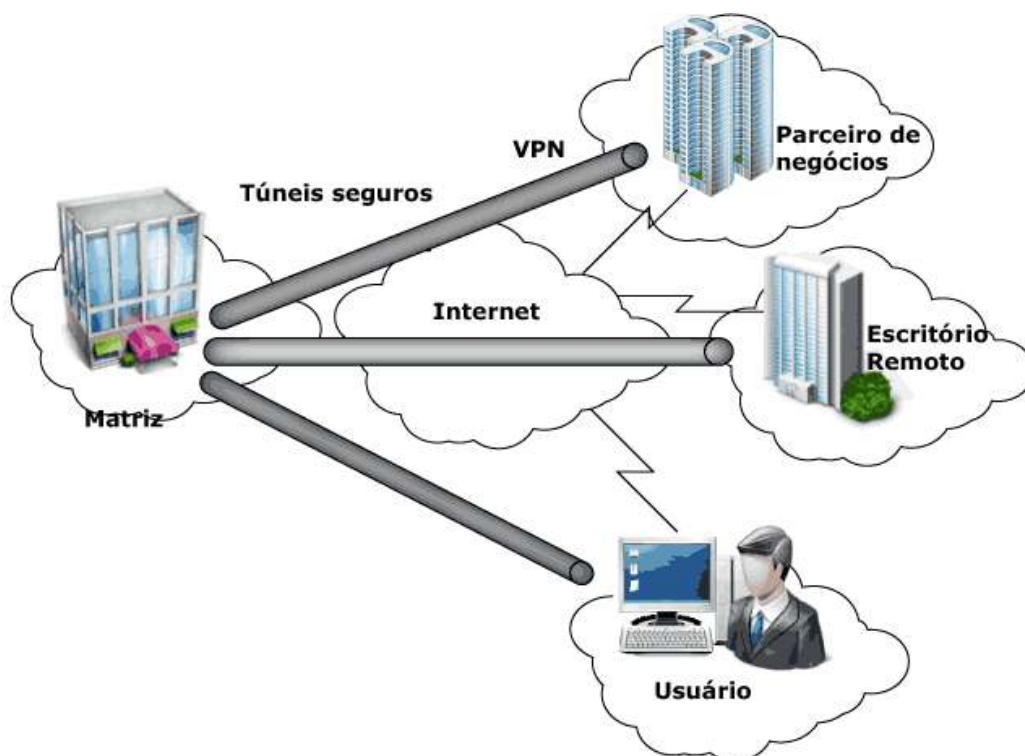
Portanto, um protocolo utilizado para fechar uma VPN entre dois pontos precisa conter diversos mecanismos para tratar cada um desses itens de segurança citados acima.

O funcionamento básico e mais comum de uma VPN segue o modelo da figura seguinte, onde é utilizado um túnel VPN. Tunelar significa que o pacote IP original a ser protegido será inteiramente criptografado e depois inserido como payload (dados) em um novo pacote IP. Portanto, quando o pacote passar pela rede pública, geralmente a Internet, seu conteúdo estará protegido. Ao chegar ao roteador de destino o cabeçalho do túnel IP é removido, seu payload será de criptografado e então enviado ao seu destino.



Podemos ainda dividir as VPNs em três conjuntos macro (veja a figura abaixo):

- **Intranet:** Conecta um escritório remoto a uma rede corporativa através da Internet, fazendo com que os computadores locais tenham acesso como se estivessem no mesmo ambiente de rede. Normalmente realizada entre dois roteadores ou dispositivos de segurança como o Cisco ASA (Adaptive Security Appliances). Esse tipo de VPN é também chamada de site-to-site.
- **Extranet:** Conecta dispositivos entre duas empresas via VPN através da Internet, porém são duas empresas diferentes, geralmente parceiros de negócio que definem regras e restrições de acesso aos recursos em ambas as localidades.
- **Acesso Remoto:** Conecta um dispositivo individual à rede corporativa normalmente através de um software cliente VPN. A Cisco possui o Cisco VPN Client, o qual permite os usuários conectarem-se com a rede corporativa e utilizarem seus recursos como se estivessem com o computador conectado a um ponto de rede local.



7.3 Dispositivos e Softwares para VPN



Para construir uma VPN você precisa de dispositivos que suportem esse recurso em ambas às pontas da conexão.

As duas topologias básicas VPN utilizadas em empresas são a **site-to-site** (que interliga duas unidades remotas ou uma unidade remota à sua Matriz via Internet) ou a **VPN de acesso** (que dá acesso a um usuário remoto aos recursos de rede como se ele estivesse sentado em uma mesa na empresa e conectado a um ponto de rede corporativo).

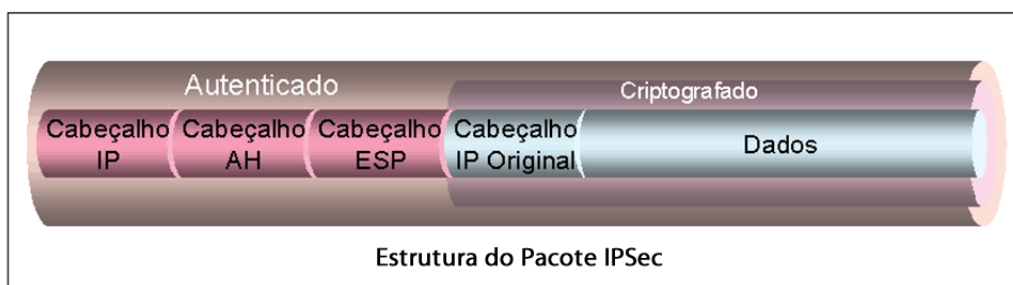
Falando mais especificamente de produtos Cisco, estes recursos estão disponíveis nos seguintes dispositivos e softwares:

- **Roteadores:** Além do encaminhamento de pacotes os roteadores podem fazer várias outras funções, desde voz até segurança, e uma delas é a VPN. Para que seja possível o roteador permitir conexões VPN o IOS utilizado deve suportar esse recurso e os requisitos de memória devem ser obedecidos. Além disso, existem algumas placas que podem ser adicionadas a alguns modelos de roteadores para melhorar o desempenho e fazer com que o processamento da parte de segurança das VPNs não interfira tanto no processamento do roteador, por exemplo, o módulo VPN AIM para a linha de roteadores ISR-G1.
- **ASA (Adaptive Security Appliances):** Trata-se de uma linha de equipamentos de segurança que são capazes de realizar diversas funções inclusive VPN site-to-site ou de acesso.
- **VPN Client:** normalmente um software utilizado nos computadores dos usuários remotos para permitir a criação de um túnel VPN de acesso. A Cisco possui o Cisco VPN Client.

7.4 Protocolo IPSec



O IPSec (Internet Protocol Security) é um framework padrão do IETF, definido pela RFC 4301, que proporciona confidencialidade, integridade e autenticação dos dados. Com o IPSec podemos criar um túnel entre dois pontos, por onde os “dados sensíveis” (dados que necessitam ser protegidos) são enviados. Veja a figura abaixo com um pacote protegido pelo IPSec.

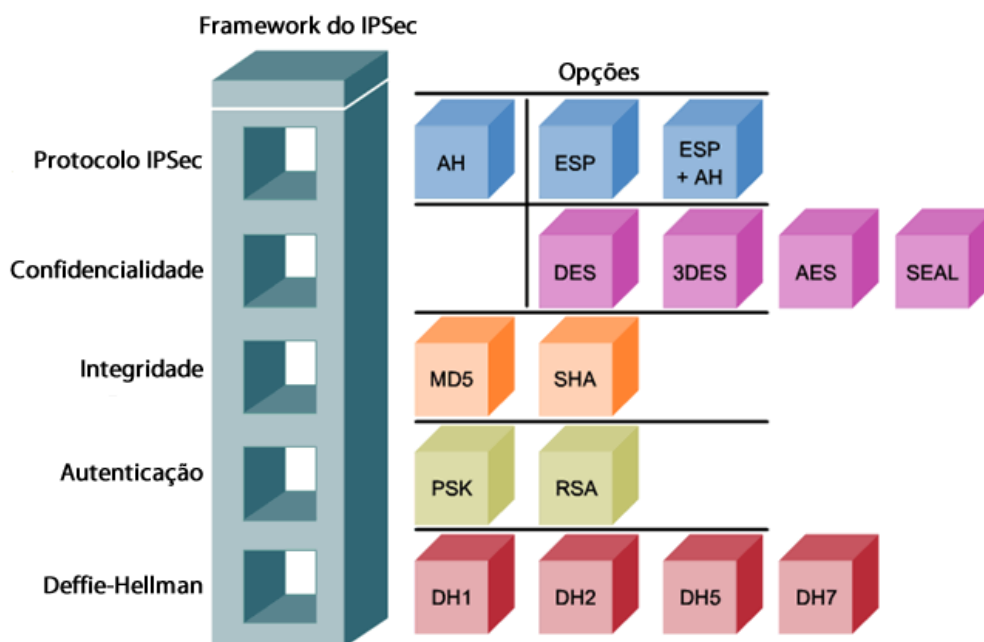


O **IPSec** pode transportar as informações em dois modos, **Transporte** ou **Túnel**. No modo transporte, somente a mensagem (payload) é criptografada, sendo que o cabeçalho IP permanece intacto.

Já no modo de tunelamento, o pacote IP é criptografado por inteiro. Deve, assim, encapsular um novo pacote IP para distribuí-lo.

O tunelamento é usado para comunicações da rede-a-rede (túneis seguros entre roteadores, chamadas de VPNs site-to-site) ou comunicações de host-a-rede e de host-a-host através da internet.

O framework IPSec, ou seja, sua estrutura, prevê dois tipos básicos de protocolos que podem ser utilizados dentro de um pacote IP: o **Authentication Header** (AH), que provê a autenticação e integridade dos dados, mas não a confidencialidade, e o **Encapsulating Security Payload** (ESP), que provê autenticação, confidencialidade dos dados e integridade da mensagem. Veja a figura abaixo.



Cada funcionalidade do IPSec está em um bloco com espaços que podem ser preenchidos com os protocolos ao lado, porém veja que a confidencialidade, que são os algoritmos de criptografia não são suportados pelo AH.

Para o IPSec fornecer a confidencialidade você terá que utilizar o protocolo ESP ou ESP trabalhando em conjunto com o AH.

O segundo espaço representa o tipo de **confidencialidade** implementado usando um algoritmo de criptografia como DES, 3DES (lê-se "triple DES"), AES ou SEAL.

A escolha depende do nível de segurança exigido, a qual a ordem de nível de segurança (da esquerda para a direita – menos seguro para o mais seguro) segue ao lado: DES -> 3DES -> AES -> SEAL. Normalmente utilizamos na prática o 3DES e o AES.

O terceiro espaço representa a **integridade** que pode ser implementada utilizando hash MD5 ou SHA. Essa garantia da integridade é realizada utilizando o Hashed Message Authentication Codes (HMAC), normalmente com o MD5 ou SHA-1.

O quarto é referente à **autenticação** e representa a forma como a chave secreta compartilhada é estabelecida.

Os dois métodos são: chaves pré-compartilhada (preshared key ou PSK) ou com certificados digitais RSA. O IPSec utiliza o protocolo Internet Key Exchange (IKE) para autenticação e troca das chaves.

O último grupo representa o **algoritmo Diffie-Hellman** ou DH utilizado para troca segura das chaves através da Internet.

Há quatro algoritmos distintos DH de troca de chaves para se escolher incluindo DH Grupo 1 (DH1), DH Grupo 2 (DH2), DH Grupo 5 (DH5) e DH Grupo 7 (DH7). O tipo de grupo selecionado depende das necessidades específicas de cada projeto.

Durante a configuração do túnel os pares VPN negociam como os túneis serão formados e o que irão utilizar em cada opção para completar os blocos da figura.

Essa negociação é configurada em políticas de segurança, por exemplo, poderíamos ter um tipo de política de segurança que utiliza o padrão ESP, com criptografia AES, integridade através de Hash MD5, autenticação com chaves pré-compartilhadas e DH grupo 2 para troca segura das chaves.

Portanto, se essa fosse a política de segurança de um roteador que aceita VPN de acesso, o mesmo deveria estar configurado nos clientes para que seja possível a conexão.

7.5 Criptografia IPSec



Vamos ignorar a parte matemática da criptografia, o que é cobrado nas certificações da carreira de segurança da Cisco, para entendermos o conceito de como o IPSec trata a confidencialidade dos dados.

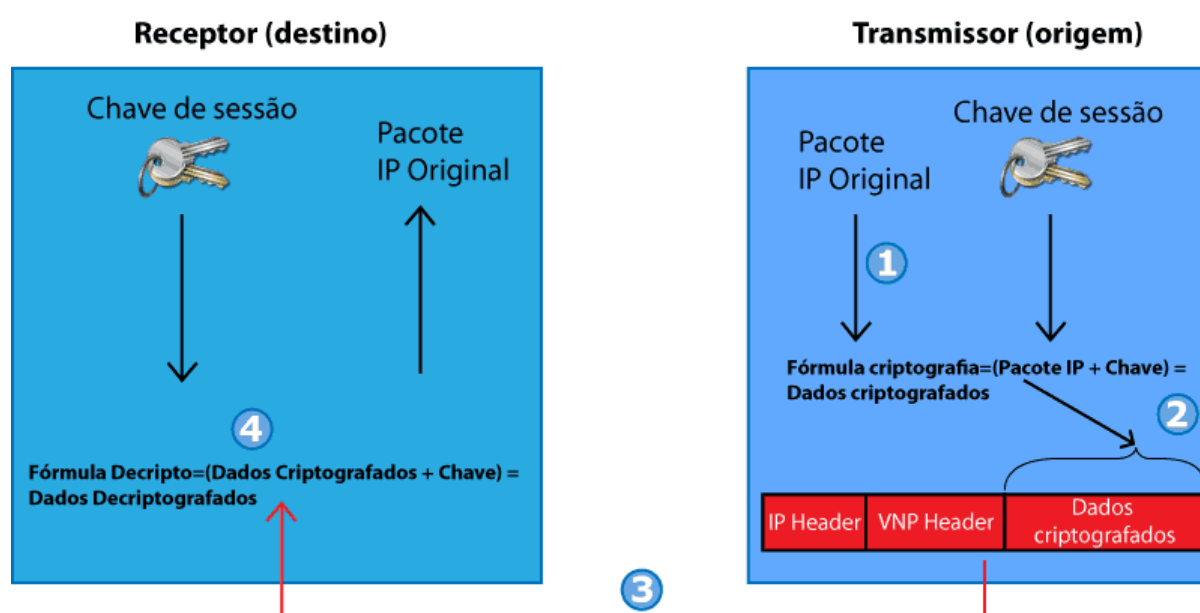
Portanto, o processo sem a parte matemática precisa de duas fórmulas: uma para criptografar os dados e outra para decriptografá-los, ou seja, traduzir os dados que foram modificados pela criptografia nos dados originais enviados.

A criptografia é feita com uma chave secreta, a qual mesmo que o pacote seja capturado seria muito difícil para que o atacante decifre a mensagem.

Além disso, decifrar a mensagem de um pacote não significa que o atacante já conhece a chave para decifrar todos os seguintes, pois normalmente a chave é fechada por sessão e muda ao longo da transmissão, dificultando mais ainda a vida de um hacker.

Na figura abaixo temos um esquema básico do sistema de criptografia utilizado pelo IPSec, veja os passos abaixo:

1. Na origem o pacote IP e a chave pré-compartilhada são utilizadas na fórmula de criptografia para geração dos dados criptografados.
2. O roteador ou ASA insere o cabeçalho da VPN (VPN Header) e o novo cabeçalho IP (IP Header) para transmissão via Internet.
3. Os dados são enviados para o destino de maneira segura através da Internet.
4. Quando recebidos no destino a fórmula de decryptografia é utilizada para decifrar a mensagem com o uso da sua chave de sessão e o pacote original é enviado ao IP de destino.



7.6 Conceitos sobre de Túneis

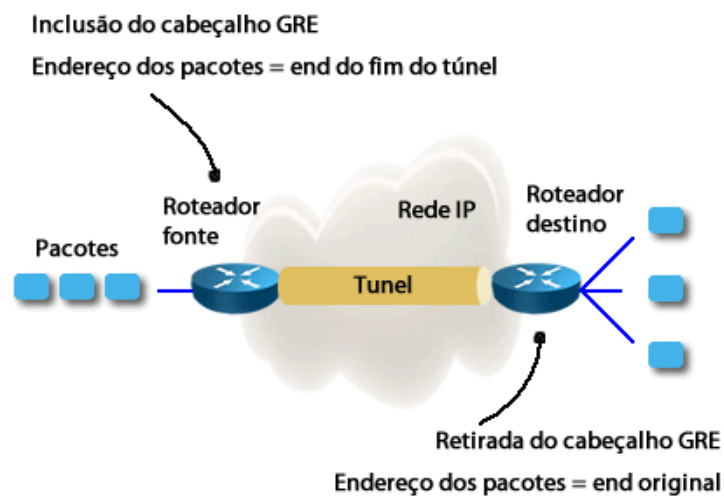


Túneis são geralmente configurados entre roteadores de origem e destino, ou seja, pacotes enviados ponto a ponto.

Um dos mais utilizados na prática são os túneis GRE.

Os pacotes designados para serem enviados através do túnel (já encapsulados com um cabeçalho de um protocolo como, por exemplo, o IP) são encapsulados por um novo cabeçalho (cabeçalho GRE) e colocados no túnel com o endereço de destino do final do túnel.

Ao chegar a este final, os pacotes são desencapsulados (retira-se o cabeçalho GRE) e continuam seu caminho para o destino determinado pelo cabeçalho original. Veja figura representando processo de tunelamento GRE abaixo.



Abaixo seguem as principais características do GRE:

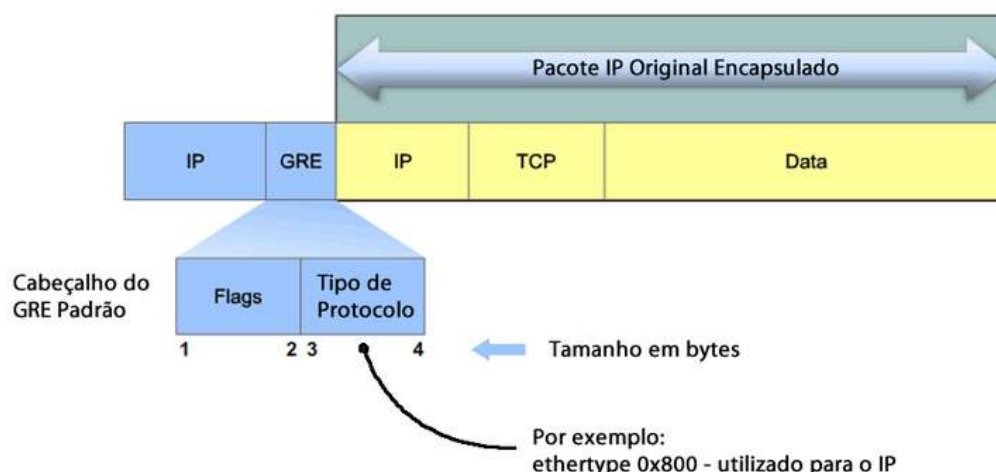
- Multiprotocolo: Encapsula uma grande variedade de tipos de protocolo de pacotes dentro de túneis IP.
- Cria um link virtual ponto a ponto para os roteadores Cisco em pontos remotos através de uma rede IP.
- Usa o IP para o transporte (camada 3) e suporta diversos protocolos de roteamento.
- Utiliza um cabeçalho adicional para suportar Multicasting e qualquer outro protocolo da camada-3 do modelo OSI como carga útil (payload ou dados).
- A grande vantagem do tunelamento GRE é permitir o tráfego de protocolos em cenários onde normalmente não seria possível, e por esta propriedade é muito utilizado em conjunto com protocolos de roteamento.

O GRE encapsula todo o pacote IP original com um cabeçalho IP padrão e um cabeçalho GRE, o qual contém pelo menos dois campos obrigatórios:

- Flag GRE
- Tipo de protocolo

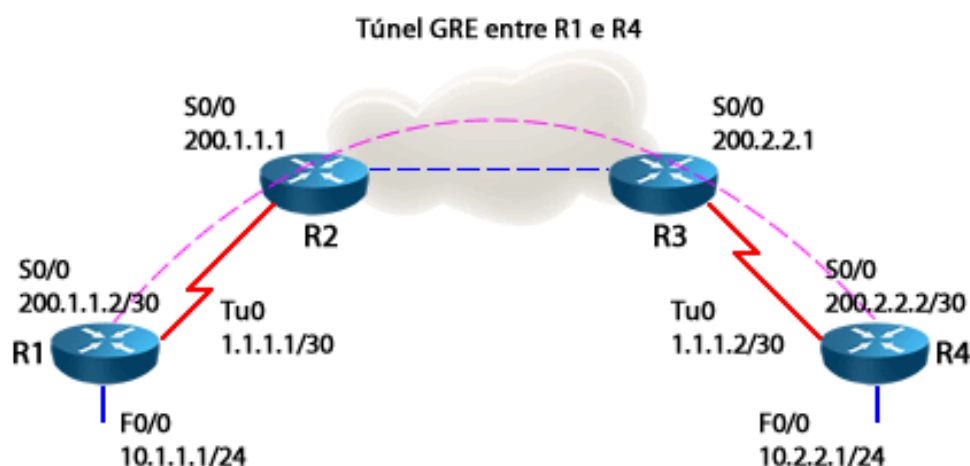
Ele utiliza um campo de tipo de protocolo no cabeçalho GRE para suportar o encapsulamento de diferentes protocolos de camada 3.

O cabeçalho GRE, juntamente com o cabeçalho IP de encapsulamento, cria pelo menos 24 bytes de overhead adicional para os pacotes encapsulados (bytes a mais quando comparado a um pacote IP normal).



Vamos a configuração utilizando como base a figura a seguir.

Nesse exemplo faremos a configuração de um túnel GRE entre os roteadores R1 e R4 para fazer a comunicação entre as redes 10.1.1.0/24 de R1 e 10.2.2.0/24 de R4 sem anunciá-las aos outros roteadores, utilizando o processo de tunelamento, porém ainda sem criptografia.



Os passos básicos a serem seguidos são:

- Passo 1:** Criar uma interface do túnel (comando "interface Tunnel x" – x é o número do túnel, como na criação de uma loopback);
- Passo 2:** Atribuir IP ao túnel (comando "IP address");
- Passo 3:** Configurar a interface de túnel de origem (comando "tunnel source Serialx/y");
- Passo 4:** Identificar o IP de destino do túnel (comando "tunnel destination x.x.x.x");
- Passo 5:** Configurar qual protocolo de camada-3 o GRE vai encapsular (comando "tunnel mode gre IP").

Vamos às configurações do R1:

```
R1#config term
R1(config)#interface Tunnel0
R1(config-if)#ip address 1.1.1.1 255.255.255.252
R1(config-if)#tunnel source Serial0/0
R1(config-if)#tunnel destination 200.2.2.2
R1(config-if)#tunnel mode gre ip
R1(config-if)#exit
R1(config)#ip route 10.2.2.0 255.255.255.0 1.1.1.2 - rota para a LAN de R2
R1(config)#end
R1#
```

A rota foi inserida porque os roteadores R2 e R3 não irão conhecer a rede LAN de R1 e R4, portanto você deve criar uma rota pelo GRE para que as LANs se comuniquem.

Abaixo segue a configuração de R4.

```
R4#config term
R4(config)#interface Tunnel0
R4(config-if)#ip address 1.1.1.2 255.255.255.252
R4(config-if)#tunnel source Serial0/0
R4(config-if)#tunnel destination 200.1.1.2
R4(config-if)#tunnel mode gre ip
R4(config-if)#exit
R4(config)#ip route 10.1.1.0 255.255.255.0 1.1.1.1 - rota para a LAN de R1
R4(config)#end
R4#
```

Com a configuração mostrada, quando um micro da LAN de R1 quiser se comunicar com outro micro remoto da LAN de R4, e vice versa, o pacote será encapsulado dentro de um túnel GRE e será desmontado apenas quando chegar a seu destino.

Com essa configuração os demais roteadores não precisam saber da existência das redes 10.1.1.0 e 10.2.2.0, precisando conhecer apenas as redes WAN dos roteadores em questão.

Lembre-se que no GRE é feito apenas o encapsulamento, de forma que não há nenhuma proteção aos dados trafegados. Para isso seria necessário a utilização do IPSEC ou qualquer outro protocolo para criptografar as informações.

Algumas condições devem estar estabelecidas para que o Túnel GRE fique "UP":

- Túnel de origem e de destino deve estar configurado.
- A rede IP do Túnel está na tabela de roteamento.
- Keepalives GRE são recebidos (se utilizado).
- GRE está configurado como modo padrão de túnel.

Você pode verificar se o túnel está funcionando com o "**show interfaces tunnel interface-number**", "**show ip interface brief**" e fazendo um traceroute para o destino verificando se o túnel está realmente sendo ativado e os dados estão passando. Veja exemplos das saídas dos comandos na sequência.

```
R1# show interfaces tunnel0
Tunnel0 is up, line protocol is up
Hardware is Tunnel
Internet address is 10.1.3.1/24
MTU 17916 bytes, BW 100 Kbit/sec, DLY 50000 usec,
reliability 255/255, txload 1/255, rxload 1/255
Encapsulation TUNNEL, loopback not set
Keepalive not set
Tunnel source 1.1.1.1 (Serial0/0/0), destination 2.2.2.2
Tunnel Subblocks:
src-track:
Tunnel0 source tracking subblock associated with Serial0/0/0
Set of tunnels with source Serial0/0/0, 1 member (includes iterators), on
interface <OK>
Tunnel protocol/transport GRE/IP
! saídas omitidas
```

7.7 DMVPN - Cisco Dynamic Multipoint VPN



Lembra do funcionamento do bom e velho Frame-relay hub-and-spoke? Então você já entende o princípio do DMVPN, onde vários sites remotos (spokes) tem uma conexão VPN com um site principal (hub).

Essa solução é mais simples que criar conexões full mesh utilizando VPNs IPsec site-to-site, que apesar de parecer mais completa seria mais cara e muito complexa de se manter, por isso ter a comunicação entre as unidades passando pelo roteador central é bem aceitável.

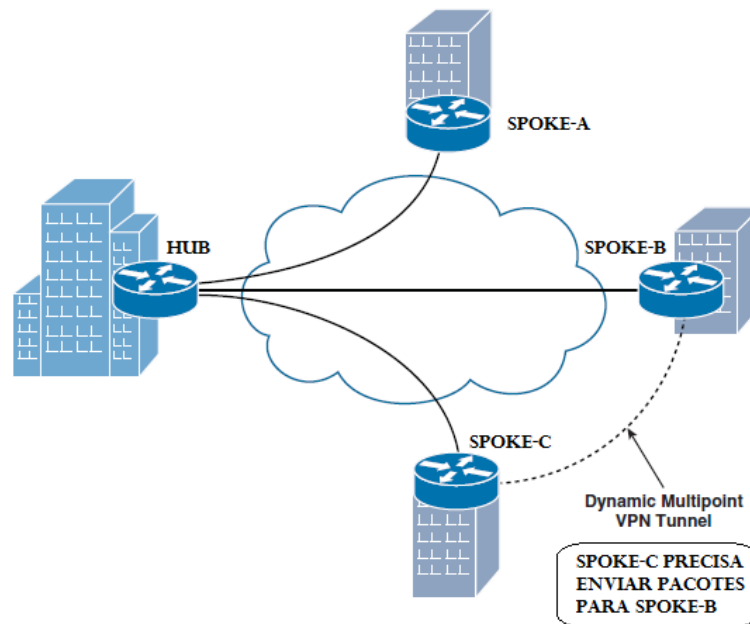
Além do **Dynamic Multipoint VPN (DMVPN)** manter uma conexão virtual permanente entre o hub e os spokes, como no caso do Frame-relay hub-and-spoke, ele também permite que um túnel VPN seja criado dinamicamente entre dois sites spokes conforme a necessidade utilizando o mGRE (GRE Multiponto) e o NHRP (Next Hop Resolution Protocol).

O DMVPN cria túneis VPN seguros permanentes utilizando o IPsec entre os spokes e os HUBs, porém, não entre os spokes como citamos anteriormente. À medida que um spoke precisa

enviar um pacote para outro spoke, ele realiza uma busca via NHRP (Next Hop Resolution Protocol) para encontrar o endereço público (roteável) do outro spoke em questão.

Uma vez encontrado, o túnel entre os spokes é estabelecido via interface mGRE (Multipoint GRE).

Portanto o DMVPN precisa dos protocolos **Multipoint GRE**, **Next Hop Resolution Protocol (NHRP)** e **IPSec** para funcionar corretamente, além disso ele tira vantagem do GRE suportar **protocolos de roteamento** e do **CEF** para melhor desempenho. Veja a figura a seguir com uma topologia que utiliza DMVPN.



Na prática o DMVPN também ajuda a economizar várias linhas de comando, facilitando a configuração e adição de novos spokes na VPN.

Imagine que você tem uma empresa com 100 unidades e precisa através do GRE puro fazer com que elas se comuniquem entre si. No mínimo no HUB você precisaria de 99 interfaces túneis mais um túnel criado em cada unidade remota, certo? Com o mGRE e o NHRP isso pode ser reduzido bastante.

Simplificando ao máximo, o **NHRP (Next Hop Resolution Protocol)** é um protocolo similar ao ARP para redes Ethernet, porém no caso de um túnel ele tem a capacidade de mapear o endereço IP de um túnel a um endereço IP Non-Broadcast Multi-Access (NBMA) em uma tabela.

Esse recurso permite que o **mGRE (GRE multiponto)** dinamicamente crie túneis entre roteadores descobertos via NHRP que precisam se comunicar.

Existem duas maneiras de configurar o mGRE no hub e deixar a configuração "normal" do GRE nos spokes. A primeira é fazer um mapeamento estático do NHRP no roteador que está atuando como HUB e a segunda é deixar que o NHRP faça o mapeamento dinâmico no roteador configurado como HUB.

O **DMVPN** usa o recurso do NHRP dinâmico para mapear as unidades remotas fazendo com que o HUB atue como servidor e os Spokes como clientes, assim cada vez que um Spoke é adicionado na rede ele informa ao HUB seu endereço físico e lógico que será utilizado para formação de túneis mGRE.

Quando o HUB está com sua tabela de vizinhos NHRP populada ele pode responder requisições de clientes que precisam se comunicar passando os endereços físico e lógico para formação do túnel dinâmico.

O comando "show ip nhrp [detail]" permite visualizar os vizinhos aprendidos. Veja exemplo abaixo.

```
Router#show ip nhrp detail
10.1.1.2/32 via 10.2.1.2, Tunnell created 00:00:12, expire 01:59:47
Type: dynamic, Flags: authoritative unique nat registered used
NBMA address: 10.12.1.2
```

Esse comando mostra os endereços IP e máscaras no cachê de endereços IP-para-NBMA. A máscara é /32 porque a implementação da Cisco do NHRP não suporta agregação de endereços nonbroadcast multiaccess (NBMA).

Na sequência temos o túnel e quando ele foi criado. Por último temos o "authoritative flag", que indica que quem forneceu essa informação foi um servidor NHRP de próximo salto (next-hop server) ou um roteador.

Se a entrada for estática (manual) no campo Type estaria escrito "static", nesse caso o dynamic indica que o NHRP resolveu o endereço.

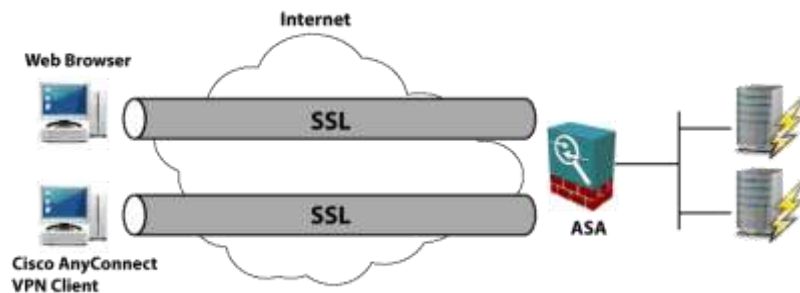
Normalmente quando um túnel DMVPN começa a subir e voltar (chamado em inglês de "flapping" ou "flap") é devido a problemas de vizinhança e o comando anterior pode ajudar a verificar qual vizinho está instável.

7.8 Considerações Finais sobre VPN



Para a implementação mais rápida e simples das VPNs a Cisco possui o conceito do Easy VPN, o qual é um framework para implementação de VPNs site-to-site ou de acesso.

Além disso, também é possível implementar o acesso seguro com VPNs SSL para acesso HTTPS em um servidor de rede. Por exemplo, a empresa utiliza um sistema WEB para registro de vendas e não quer fornecer acesso VPN completo ao usuário remoto, nesse caso uma VPN SSL permitiria a conexão segura desse usuário com somente um determinado servidor WEB interno com a devida autenticação.



Para o exame é importante saber distinguir os requisitos de segurança do IPSec (confidencialidade, autenticação e integridade), entender suas diferenças e cada técnica ou tecnologia utilizada para garantir esses requisitos.

A configuração e aplicação dos conceitos são tratadas no CCNP Security, além disso, você precisa diferenciar as VPNs site-to-site de uma DMVPN e VPNs de acesso (VPN Client).

As VPNs site-to-site são configuradas de forma estática entre duas unidades.

Se você precisar de uma arquitetura Hub-and-Spoke, com uma matriz e várias unidades remotas que se conectam a essa matriz via Internet e VPN, aí a melhor opção é uma DMVPN, pois com poucas linhas de comando podemos inserir e remover unidades da configuração, conforme já estudamos anteriormente.

As VPNs de acesso utilizam um software de VPN Client direto nas máquinas dos usuários remotos da empresa para que eles possam acessar recursos de rede pela Internet de maneira segura.

Esse acesso pode ser feito via VPN e um túnel IPSec ou então via SSL, via HTTPS.

A seguir vamos estudar outras opções de acesso WAN.

8 Access Control Lists

8.1 Introdução



As listas de controle de acesso (ACLs) são amplamente utilizadas em redes de computadores e em segurança de rede para mitigar os ataques e controlar o tráfego da rede.

Os administradores usam ACLs para definir e controlar o tráfego em classes de dispositivos de rede com base em vários parâmetros. Esses parâmetros são específicos para a camada do modelo OSI (2, 3, 4 e 7).

As ACLs podem ser numeradas (access-list) ou nomeadas (ip access-list), veja saída abaixo.

```
Dltec-FW-GW(config)#access-list ?
<1-99>          IP standard access list
<100-199>       IP extended access list
<1000-1099>     IPX SAP access list
<1100-1199>     Extended 48-bit MAC address access list
<1200-1299>     IPX summary address access list
<1300-1999>     IP standard access list (expanded range)
<200-299>       Protocol type-code access list
<2000-2699>     IP extended access list (expanded range)
<2700-2799>     MPLS access list
<300-399>       DECnet access list
<600-699>       Appletalk access list
<700-799>       48-bit MAC address access list
<800-899>       IPX standard access list
<900-999>       IPX extended access list
dynamic-extended Extend the dynamic ACL absolute timer
rate-limit       Simple rate-limit specific access list
```

```
Dltec-FW-GW(config)#
Dltec-FW-GW(config)#ip access-list ?
extended         Extended Access List
log-update       Control access list log updates
logging          Control access list logging
resequence       Resequence Access List
standard         Standard Access List
Dltec-FW-GW(config)#
```

Praticamente qualquer tipo de tráfego pode ser filtrado usando uma ACL. Por exemplo, no passado, o campo “tipo” do cabeçalho do quadro Ethernet foi utilizado para definir certos tipos de tráfego. Um “tipo” 0x8035 indicava a presença de um quadro do Reverse Address Resolution Protocol (RARP) e ACLs numeradas, com um intervalo de 200-299, eram utilizadas para controlar o tráfego pelo tipo do quadro Ethernet.

Outro exemplo comum do passado era a criação de ACLs com base em endereços MAC. Uma ACL numerada 700-799 filtra o tráfego com base em endereços MAC, possibilitando o controle através desse parâmetro. Após definir como filtrar (IP, MAC, Tipo de quadro ethernet, etc), uma ACL pode bloquear (deny) ou permitir (permit) o tráfego selecionado. Por exemplo, uma ACL numerada 700-799 poderia ser utilizada para bloquear um cliente com um endereço MAC específico de se conectar na rede via um AP (Access-point) pré-determinado.

Hoje os tipos mais comuns dos parâmetros utilizados nas ACLs são os endereços IPv4/IPv6 e números de porta TCP e UDP. Por exemplo, uma ACL pode permitir que todos os usuários com um determinado endereço IP de rede baixem arquivos da internet utilizando FTP seguro, assim como essa mesma ACL pode ser usado para negar (bloquear) todos os endereços IP acessarem ao FTP tradicional, garantindo que somente a versão segura seja utilizada.

Além das ACL’s numeradas podemos criar os mesmos tipos de ACL nomeadas, o que facilita a criação e estende o número de ACLs que podem ser criadas, pois como você pode notar as ACLs numeradas são limitadas por um range específico de valores.

Nesse capítulo faremos um estudo sobre a aplicação das ACLs para mitigar problemas de segurança.

8.2 Listas de Controle de Acesso (ACL) – Operação



Uma Lista de Controle de Acesso ou “**Access Control List**” (**ACL**) é um conjunto de instruções que diz ao roteador para aceitar (permit ou permitir) ou rejeitar (deny ou negar) determinados pacotes vindos de redes IP especificadas. Esse filtro pode atuar até na camada-4, onde é possível especificar portas TCP ou UDP que você deseja filtrar, selecionando assim quais aplicações podem ser acessadas na rede interna e quais podem acessar a rede externa.

Uma ACL pode ser utilizada como um “**Firewall**” básico, fornecendo recursos de filtragem básica, podendo ser aplicada como uma barreira de proteção com a finalidade de controlar o tráfego de dados entre sua rede interna e a Internet.

Essas listas devem ser criadas em modo de configuração global, como uma sequência de regras ou statements (declarações) e aplicadas em uma interface LAN, WAN ou em dentro da line VTY, para limitar acesso ao Telnet e SSH, conforme estudado no capítulo anterior.

Existem duas maneiras de criar uma ACL:

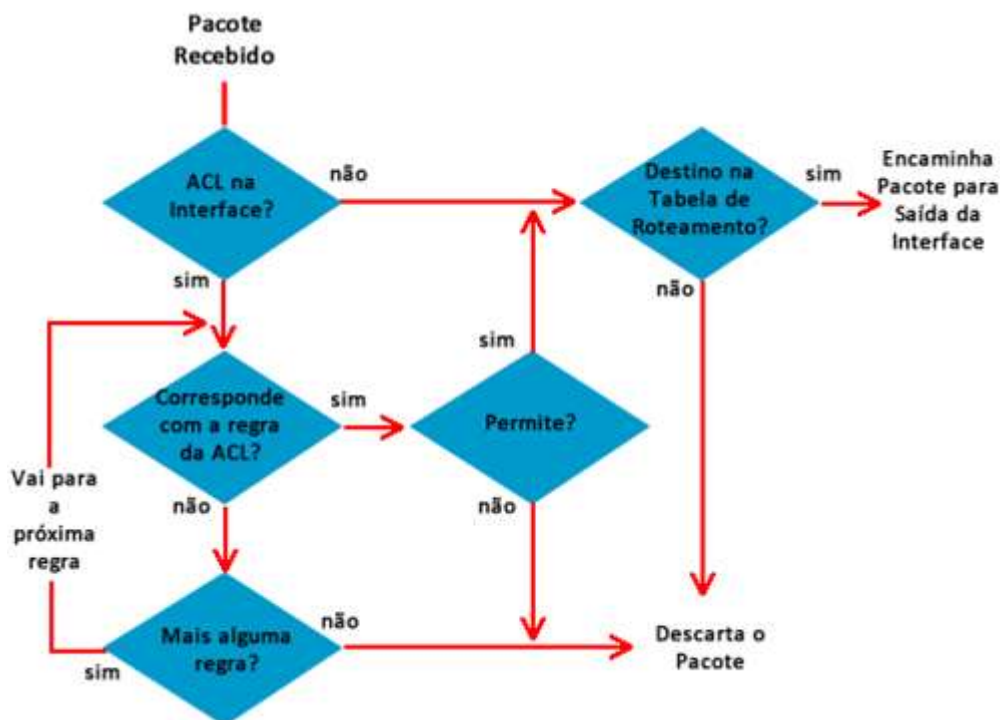
1. **ACL Numerada:** as quais podem ser **padrão** ou **estendida** ou
2. **ACL Nomeada:** também podem ser padrão (**standard**) ou estendidas (**extended**).

Uma ACL IP padrão pode filtrar o tráfego apenas baseado em pacotes IP através do endereço ou rede de origem, tanto na forma nomeada quanto na numerada.

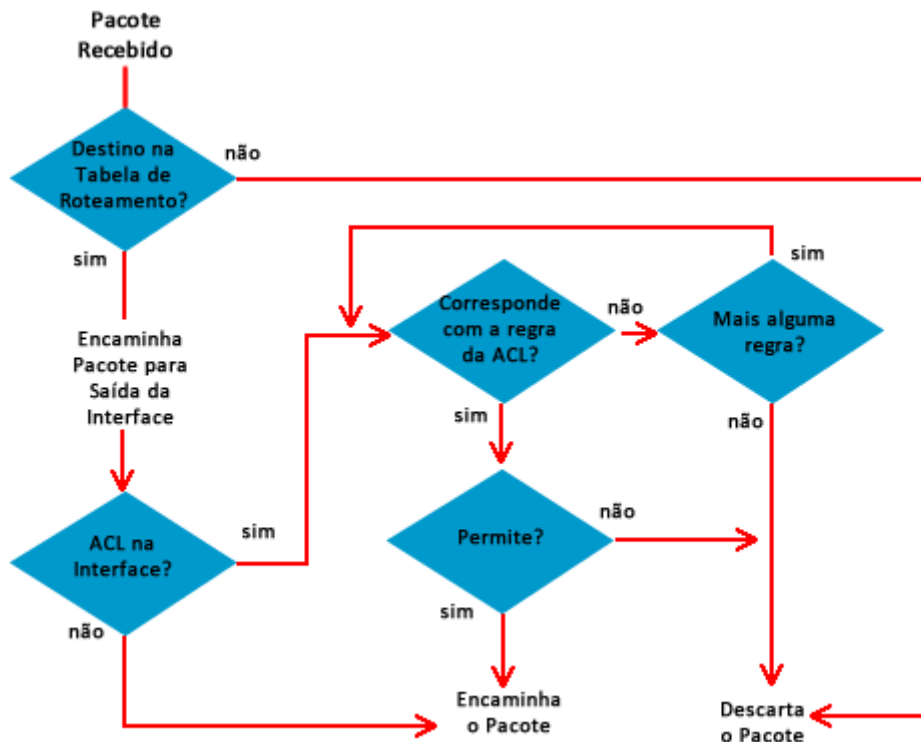
Para a ACL IP estendida o administrador de redes tem uma gama maior de opções de filtragem, como pacotes IP através do endereço de origem e destino, protocolos TCP e UDP, protocolo ICMP, outros protocolos como RIP, OSPF, EIGRP, GRE, pelo estado das conexões das portas TCP, etc.

Nas figuras a seguir você pode verificar como um pacote é processado quando o roteador tem uma lista de acesso aplicada. As listas são aplicadas nas interfaces em duas possíveis direções:

1. In: tráfego entrante



2. Out: tráfego de saída do roteador



Note que para a ACL colocada na direção de entrada da Interface ou Inbound (In), a ACL é processada antes do pacote ser roteado, ou seja, somente se ele for permitido pela ACL que o roteador fará o processo de roteamento.

Já para a direção de saída ou outbound (Out), o pacote já passou pelo processo de roteamento e após isso será processado pela ACL.

Além disso, você pode notar em ambos os diagramas que sempre no final, se você não criar uma regra com permissão o pacote será descartado, pois existe uma negação implícita no final de toda lista de acesso, ou seja, um "deny any" negando todos os pacotes. Portanto para as regras funcionarem deve existir no mínimo uma permissão ou então nenhum pacote será encaminhado.

Resumindo:

- ACL é um conjunto de regras de teste que se satisfeitos deixarão o pacote ser encaminhado ou filtrarão o pacote.
- Pode ser uma lista padrão, analisando apenas a rede IP de origem do pacote e decidindo se aquele pacote vai ou não ser encaminhado.
- Caso haja necessidade de maior granularidade, ou seja, filtrar utilizando outros parâmetros como: rede de destino, tipo de protocolo, porta TCP ou UDP, estado da conexão, uma lista de acesso estendida deve ser utilizada.
- As listas podem ser numeradas (1 a 99 – ACL IP Padrão / 100 a 199 – ACL IP estendida) ou nomeadas, as quais não tem limitação de listas por utilizarem nomes.
- As ACLs podem ser aplicadas nas Interfaces de LAN e WAN ou na linha de Telnet (VTY) dos roteadores e switches em duas direções: Entrada (In) e Saída (Out).
- Devem ser criadas em modo de configuração global e aplicadas nas Interfaces ou Lines.
- Os pacotes serão processados um a um, regra a regra, caso uma ele atenda a regra ele será permitido ou negado, caso não atenda passará para o próximo teste até o final das regras.

- As regras mais específicas devem ser posicionadas no início da ACL, assim você garante que não haverá atrasos em processamento pelos testes em regras anteriores até chegar à mais específica.
- Pacotes gerados pelo roteador não podem ser filtrados por ele mesmo no sentido de saída (outbound).
- Se uma ACL é aplicada a uma interface e não foi criada em modo global o tráfego irá passar normalmente, pois para se ter uma negação (deny) implícito pela regra deve ter sido criada.

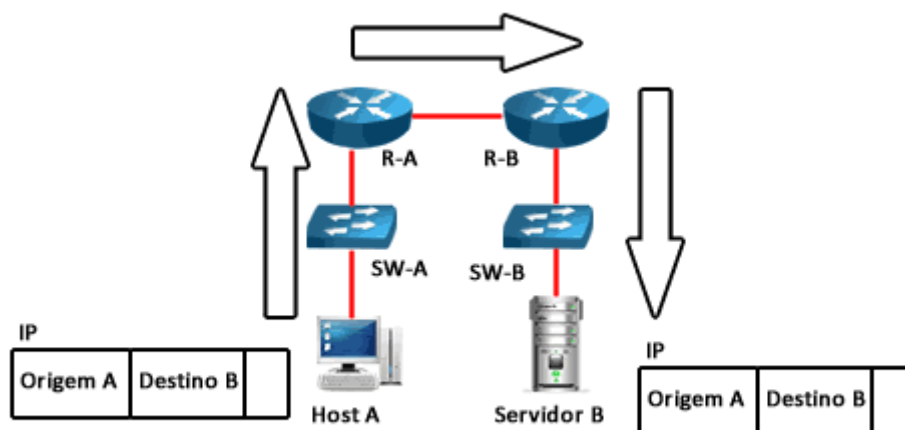
Agora vamos estudar como criar as regras, pois existe uma lógica de funcionamento que depende do entendimento da comunicação em rede e dos protocolos que desejamos filtrar ou proteger.

8.3 Entendendo e Criando as Regras



Basicamente em uma rede IP quando um PC deseja conversar com outro fora da sua rede, esse pacote atravessa a rede e o endereço ou rede IP de origem será a do PC que originou a comunicação. Já a rede IP de destino será a rede onde o IP do computador remoto está.

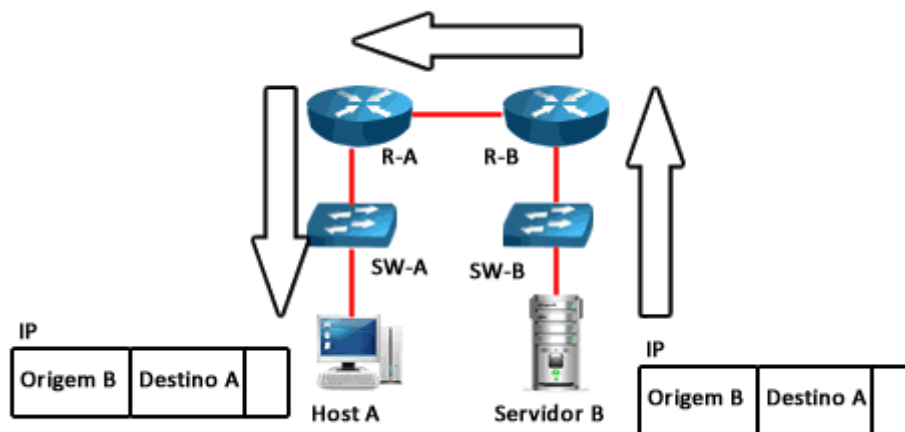
Na figura o PC da rede A deseja acessar uma página de Web do servidor que está na rede B. Portanto o a rede de origem é a rede do PC A e a de destino à rede do Servidor B.



Agora vamos analisar o cominho de volta, quando o servidor B responde a requisição do PC A, agora ele será a origem da comunicação e o PC A será o destino.

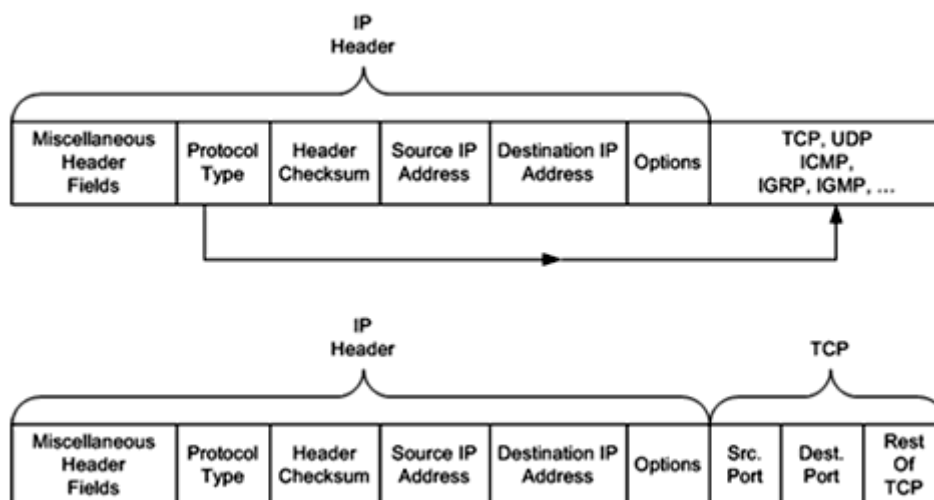
Para ACL padrão somente esse dado importa, quem é a rede IP de origem.

Utilizando a figura ao lado, você poderia criar uma regra para bloquear pacotes IP para o servidor que venham de uma determinada rede de origem, porém não pode especificar para que serviço ele esteja sendo bloqueado, porque a ACL padrão não tem essa granularidade. Ou a rede inteira ou parte dela passa ou é bloqueada.



Para a ACL estendida a regra do jogo muda bastante, pois ela pode ir além do endereço de origem, portanto você pode ir mais fundo na sua filtragem. A ACL estendida chega até a camada 4 do modelo OSI, ou seja, a camada de transporte, podendo filtrar portas TCP e UDP, consequentemente filtrando as aplicações que passam por aquela interface.

Agora veja a figura ao lado para termos um entendimento melhor do que a ACL estendida é capaz.



Você agora pode filtrar pelas redes IP de origem e destino, mais os protocolos de camada 3 e 4 suportados pelos roteadores, como ICMP, IGMP, TCP, UDP e outros.

No exemplo mostrado anteriormente, o PC A formaria um pacote com o IP do Servidor B e a porta TCP com destino 80, pois é a porta padrão do protocolo Web HTTP. A porta de origem do

PC depende do sistema operacional que ele está usando, mas normalmente é uma porta acima de 1024.

Quando o servidor responder, ele colocará sua porta de origem 80 e a porta de destino com o número da porta que ele recebeu originalmente do computador A.

Vale também lembrar que o TCP é orientado a conexão e faz um processo de handshake triplo para inicializar a conexão. Nesse processo ele inicia enviando o SYN setado em 1 e o Ack (reconhecimento) em "0". Nas ACLs existe um operando ou opção que identifica conexões estabelecidas, ao contrário do que aconteceu anteriormente com o ACK igual a 1, chamado established.

Para o protocolo UDP não existe esta opção, pois ele não tem conexão, ele sempre está pronto para receber e enviar, conforme as aplicações necessitarem.

Portanto, se um exercício pedir para você filtrar a comunicação do Telnet com a rede LAN do servidor você teria que determinar:

- Rede de origem e sua máscara
- Rede de destino e sua máscara (a rede da sua LAN)
- Pelo protocolo: qual a porta utilizada e se ela é TCP ou UDP
- Nesse caso a porta de destino é a 23 do protocolo TCP
- Como são clientes se conectando as portas de origem são variáveis

Lembrando que quando um pacote é formado ele possui os endereços:

- IP de origem e destino, conforme analisamos anteriormente.
- Portas TCP ou UDP de origem e destino, as quais sobre a direção têm as mesmas características.

Porém lembrem que as portas TCP e UDP representam os diversos serviços de redes que os aplicativos das camadas superiores ou aplicações podem utilizar. Aqui temos uma arquitetura cliente/servidor, onde o servidor normalmente tem uma porta bem conhecida e o cliente utiliza uma porta aleatória que inicia acima de um valor padrão.

Na continuação do curso veremos como criar as regras utilizando cada tipo de lista de acesso.

8.4 ACL IP Padrão Numerada



O início da configuração de uma ACL padrão e estendida é o mesmo, ou seja, você entra em modo de configuração global, digita o comando "access-list", escolhe o número da ACL e inclui o parâmetro "permit" (permitir) ou "deny" (negar), conforme mostrado abaixo.

```
Router(config)#access-list 1 ?  
  deny    Specify packets to reject  
  permit  Specify packets to forward
```

O “deny” especifica pacotes a serem rejeitados e o “permit” os que serão encaminhados.

Na configuração de uma ACL IP padrão, depois de definido se você vai permitir ou negar um pacote você deverá entrar com o IP ou rede de origem e a máscara curinga. Veja a seguir um exemplo onde o tráfego originado da rede 10.0.0.0/8 é permitido.

```
Router#conf t  
Enter configuration commands, one per line.  End with CNTL/Z.  
Router(config)#access-list 1 permit 10.0.0.0 0.255.255.255
```

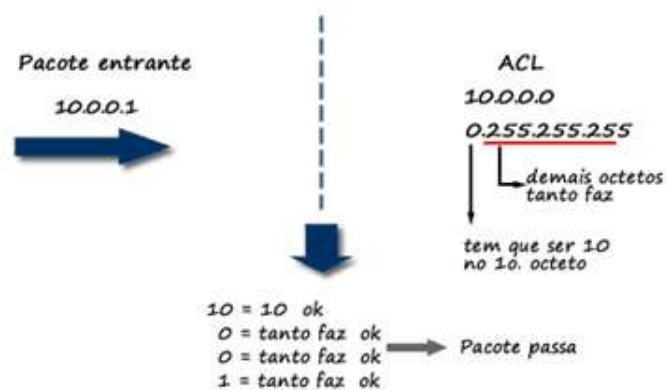
8.5 como Máscara Curinga



Note que a máscara curinga é formada, assim com a máscara de rede, por quatro octetos de oito bits, sendo que bit 0 na máscara curinga significa que deve haver correspondência e o bit 1 significa que você pode ignorar a correspondência entre o pacote a ser testado e a rede configurada na ACL. Veja o exemplo do item anterior:

```
Router#conf t  
Enter configuration commands, one per line.  End with CNTL/Z.  
Router(config)#access-list 1 permit 10.0.0.0 0.255.255.255
```

Um octeto com oito bits zeros (.0) significa que o octeto correspondente no endereço deve ser exatamente igual ao informado na ACL. Já um octeto com oito bits 1 (.255) significa que quaisquer valores são aceitos para aquela entrada.



Portanto a dupla - rede e máscara curinga - definem o range de IPs que serão testados na ACL.

Vamos a seguir aprender e rever alguns macetes para calcular a máscara curinga.

8.5.1 Máscara curinga para selecionar redes classful



A máscara curinga na prática muitas vezes é o contrário da máscara de sub-redes, ou seja, onde é zero na máscara de sub-rede é um na máscara curinga e vice-versa. Essa regra se aplica perfeitamente para redes classe cheia.

- **Classe A** – "10.0.0.0 0.255.255.255"

Em uma rede classe A o primeiro octeto é utilizado para a rede e os demais para o host, sendo assim somente o primeiro octeto tem que ser testado para garantir que a rede selecionada seja classe A, os demais octetos podem ser ignorados. Esse mesmo princípio pode ser utilizado para as classes B e C.

- **Classe B** – "130.0.0.0 0.0.255.255"

- **Classe C** – "200.200.100.0 0.0.0.255"

8.5.2 Máscara curinga para apenas um IP (máscara de host)



Nesse caso utilizamos a máscara com todos os bits zero, "End-IP 0.0.0.0" ou o mnemônico "host End-IP". Lembre-se que um octeto inteiro "0" significa que você deve testar todos os bits. Exemplo para permitir o PC 10.1.2.21:

- Router(config)#access-list 1 permit 10.1.2.21 0.0.0.0
- Router(config)#access-list 1 permit host 10.1.2.21

Usando o mesmo princípio que utilizamos para redes classe cheia, a máscara de sub-rede para um host é a /32 (255.255.255.255), portanto o inverso dela é uma /0 (0.0.0.0)

8.5.3 Máscara curinga para permitir quaisquer redes (todas as redes)



Nesse caso utilizamos a máscara com todos os bits em um "0.0.0.0 255.255.255.255" ou o mnemônico "any". Exemplo:

- Router(config)#access-list 1 permit any
- Router(config)#access-list 1 permit 0.0.0.0 255.255.255.255

Usando o mesmo princípio que utilizamos para redes classe cheia e de host, a rede que representa todos os IPs (Internet) é 0.0.0.0 0.0.0.0 ou 0.0.0.0/0, portanto sua máscara curinga é 0.0.0.0 255.255.255.255!

Lembre-se que esse é um “macete” prático, porque na realidade os bits da máscara curinga e de sub-rede tem significado diferentes!

8.5.4 Selecionando Sub-redes



Nesse caso basta diminuir a máscara /32 (255.255.255.255) da máscara de sub-rede que você está trabalhando. Por exemplo, selecione somente a subnet zero da rede 10.0.0.0/28 para ser permitido na ACL padrão 1:

$$\begin{array}{r} \text{— } 255.255.255.255 \\ \text{— } 255.255.255.240 \\ \hline 0.0.0.15 \end{array}$$

Portanto a rede e a máscara curinga são: “10.0.0.0 0.0.0.15”

```
Router(config)#Access-list 1 permit 10.0.0.0 0.0.0.15
```

Note que os três primeiros octetos devem ser iguais e o último octeto é 15 em decimal, ou seja, 00001111 em binário. Se você fizer a variação de 15 em binário você terá:

```
00000000 - 0
00000001 - 1
00000010 - 2
...
00001110 - 14
00001111 - 15
```

Portanto você terá dos IPs 10.0.0.0, 0+1, 0+2,..., 0+14 até 0+15.

Agora permitir a terceira sub-rede válida considerando a rede 10.0.0.0 com uma máscara /27 (255.255.255.224):

```
_ 255.255.255.255
  255.255.255.224
-----
    0. 0 . 0 . 31
```

A máscara curinga continua a mesma, porém a rede agora será: "10.0.0.96 0.0.0.31", pois o range inicia em 10.0.0.96 (terceira sub-rede válida).

```
Router(config)#Access-list 1 permit 10.0.0.96 0.0.0.31
```

Note que os três primeiros octetos devem ser iguais e o último octeto é 31 em decimal, ou seja, 00011111 em binário. Se você fizer a variação de 31 em binário você terá:

```
00000000 - 0
00000001 - 1
00000010 - 2
00000011 - 3
00000100 - 4
...
00011110 - 30
00011111 - 31
```

Portanto você terá dos IPs 10.0.0.96, 96+1, 96+2,..., 96+30 até 96+31. Ou seja, dos IPs 10.0.0.96 até 10.0.0.127. A próxima sub-rede começa em 10.0.0.128/27.

8.5.5 Selecionando Faixas de Endereços IP



Para selecionar um range (faixa) de IPs ou redes, não importando a sub-rede que ele esteja, você deverá lembrar que a seleção pode ser feita apenas por blocos de IP.

Os blocos podem ter tamanho de 2, 4, 8, 16, 32, 64, 128 ou 256 endereços ou redes selecionando 1, 2, 3, 4, 5, 6, 7 ou 8 bits da máscara curinga respectivamente. Para blocos com 4 IPs você poderá ter os IPs ou redes de 0 a 3, 4 a 7, 8 a 11 e assim por diante.

Outro exemplo, para blocos com 32 IPs você terá ranges de IP ou rede variando de 0 a 31, 32 a 63, 64 a 95 e assim por diante. Portanto não tem como selecionar exatamente os IPs de 10.0.0.20 a 10.0.0.50, por exemplo, pois estão fora dos blocos.

Exemplo: calcule a máscara curinga para permitir que as redes de 200.200.1.0 a 200.200.7.0 sejam negadas em uma ACL.

Resolução: as redes de 1 a 7 estão no bloco 8 IPs (de 0 a 7), escolhendo blocos de 4 bits a ACL será a:

```
Router(config)#Access-list 51 deny 200.200.0.0 0.0.7.255
```

Lembre-se que sempre que o exercício pedir para iniciar um range a partir de 1 você deverá iniciar a partir de 0.

Uma maneira de calcular é fazendo o seguinte, por exemplo, o exercício pede para você calcular uma máscara curinga que selecione as redes 172.16.32.0 a 172.16.63.0 com a máscara de sub-rede /24. Os octetos 172 e 16 nunca irão variar, portanto você colocará 0.0. para esses dois octetos. O octeto 0 pode variar de 0 a 255, pois são os IPs possíveis dessa rede com máscara /24. Agora basta calcular o range de 32 a 63, conforme esquema abaixo:

```
172.16.32.0
172.16.63.0
```

```
0. 0 . ? .255
```

Onde o range está indeterminado siga os seguintes passos:

converta o 32 em binário

converta o 63 em binário

compare os números em binário, onde for igual fica 0 e diferente fica 1:

```
32 -> 00100000
```

```
63 -> 00111111
```

```
31 -> 00011111
```

É o mesmo que diminuir 32 de 63, agora você deverá escolher o método que melhor se adapte a sua forma de estudo e guardar o conteúdo.

A máscara curinga é 0.0.31.255. Como rede utilize o IP de número menor (32). Portanto a ACL ficará:

```
Router(config)#Access-list 10 permit 172.16.32.0 0.0.31.255
```

Utilizando os exemplos acima, podemos escrever uma ACL que bloqueie o tráfego das redes 200.200.0.0 a 200.200.7.0 e permita a passagem dos pacotes das redes 172.16.32.0 a 172.16.63.0:

```
Router(config)#Access-list 10 deny 200.200.0.0 0.0.7.255
```

```
Router(config)#Access-list 10 permit 172.16.32.0 0.0.31.255
```

Ou aproveitando o deny implícito que o IOS coloca no final da lista poderíamos apenas permitir o tráfego referente à rede 172.16 que automaticamente todas as demais redes estariam bloqueadas:

```
Router(config)#Access-list 10 permit 172.16.32.0 0.0.31.255
Router(config)#Access-list 10 deny any (implícito)
```

Outro exemplo interessante é quando há solicitação de bloqueio de apenas algumas redes, pois você deverá lembrar-se de permitir alguma rede no final ou sua ACL bloqueará todo o tráfego que passar pela interface em que ela for aplicada. Por exemplo:

```
Router(config)#Access-list 10 deny 200.200.0.0 0.0.7.255
```

A ACL acima bloqueia as redes de 200.200.0.0 até 200.200.7.0, porém bloqueará todo o tráfego restante devido ao deny implícito colocado pelo IOS. Para solucionar o problema insira o comando:

```
Router(config)#Access-list 10 permit any
```

Assim as demais redes serão permitidas. Lembre-se que sempre que sua ACL iniciar com um "deny" você deve ter no mínimo um "permit".

8.5.6 Máscaras Curinga Esdrúxulas



Os casos que estudamos de máscaras curingas são os tradicionais, porém na prática podemos utilizar em ocasiões especiais máscaras que não parecem corretas, porém tem um certo significado, por isso são esdrúxulas ou diferentes, no popular "sinistras"...

Por exemplo, podemos fazer uma máscara que só deixe passar endereços pares, basta configurar o último bit da máscara curinga em zero que nenhum número ímpar será selecionado. Veja exemplo abaixo:

```
Router(config)#Access-list 10 permit 10.0.0.0 0.0.0.254
```

Nesse caso os IPs que serão selecionados devem ter os primeiros três octetos iguais a 10.0.0 e no último octeto temos 0 na rede e na máscara curinga 254, convertendo em binário 1111111**0**. Então esse octeto deixa passar tudo que tenha o último bit igual a zero, que é a característica de um número par em binário!

Esse exemplo foi dado porque não devemos ignorar máscaras diferentes do padrão que estamos acostumados, pois se o examinador quiser fazer uma questão de ACL mais complexa está aí onde ele consegue diferenciar “o joio do trigo”!

8.6 ACL IP Estendida Numerada



As Listas de Acesso estendidas são utilizadas quando você deseja permitir, por exemplo, tráfego http (web) e negar o FTP (File Transfer Protocol) ou telnet de redes que não sejam da empresa, ou seja, vão além do endereço IP de origem e testam também condições dentro da camada-4. As ACLs estendidas verificam os endereços IP de origem e destino dos pacotes, protocolos específicos, números de portas (TCP e UDP) e outros parâmetros.

As ACLs estendidas usam um número de intervalo de 100 a 199. Veja a seguir a sintaxe para configurar a ACL estendida.

```
Access-list <100-199> Permit/deny Protocolo Rede/IP-origem Máscara-curinga  
Opções-origem Rede/IP-destino Máscara-curinga Opções-destino Demais-opções
```

Os protocolos podem ser definidos pelo número de 0 a 255 (referente ao protocolo IP) ou através dos mnemônicos: ahp, eigrp, esp, gre, icmp, igmp, igmp, ip, ipinip, nos, ospf, pcp, pimm, tcp e udp. Os mais utilizados são “**ip**” o qual representa todos os protocolos, **icmp**, **tcp** e **udp**.

A rede de origem é analisada no campo “IP de origem” do cabeçalho do pacote IP, já o destino é analisado no campo “IP de destino” do cabeçalho do pacote IP.

Importante: Quando você estiver analisando um pacote que entra em sua rede, o IP de origem será um IP pertencente à rede remota e o de destino pertencente a sua própria rede. Agora, no caso de um pacote que está sendo enviado da rede interna para um roteador externo (exemplo: acesso à Internet) o IP de origem será da sua própria rede e o de destino será da rede externa. Essa análise deve ser bem entendida para resolver os problemas relativos a ACL.

As opções para origem e destino são: eq, gt, lt, neq e range. O mais utilizado é o “eq”, que significa equal ou igual, serve para selecionar uma porta TCP ou UDP por exemplo.

A opção “gt” é maior que (greater than), por exemplo, você quer escolher portas maior que 1024, ou seja, acima das portas bem definidas seria “gt 1024”. O “lt” é o “less than” ou menor que, portanto, pode ser utilizadas para faixa de portas menor que um certo valor.

A opção "neq" é o contrário do "eq", ou seja, portas que não sejam iguais a que você selecionou na opção. Por último o range é para selecionar uma faixa, você utiliza range coloca o valor inicial e depois o valor final, por exemplo, você quer uma regra que pegue das portas 1000 a 2000 então será "range 1000 2000".

As demais opções podem ser: ack, dscp, established, fin, log, log-input, precedence, psh, rst, syn, time-range, tos e urg. As mais utilizadas são:

- **"log"** - envia uma informação quando a instrução for casada, ou seja, houve correspondência para aquela instrução da ACL, para um servidor de "syslog".
- **"established"** - testa se a conexão TCP já está aberta (bit ack do protocolo TCP diferente de zero).

O cálculo da máscara curinga é o mesmo realizado para ACL padrão.

Exemplo de ACL Estendida Numerada

Para melhor ilustrar o uso de uma ACL estendida vamos a um exemplo. Você deve criar uma ACL que permita a entrada de quaisquer redes externas no caso de acesso a Web (http), FTP. Para o telnet permitir acesso apenas aos Ips da rede 10.0.0.0/24. Para os demais serviços negar acesso.

A resolução você pode verificar a seguir e logo após temos uma explicação mais detalhada de como chegamos nesse resultado.

```
Router(config)#access-list 100 permit tcp any any eq 80
Router(config)#access-list 100 permit tcp any any eq ftp
Router(config)#access-list 100 permit tcp any any eq ftp-data
Router(config)#access-list 100 permit tcp 10.0.0.0 0.0.0.255 any eq 23
```

O primeiro statement ou instrução indica que você permitiu acesso ao protocolo TCP ("access-list 100 permit tcp"), para quaisquer redes de origem e destino ("any any") para porta 80 ("eq 80"), a qual é a porta referente ao serviço http.

Na segunda e terceira instrução foi permitido acesso ao FTP, que possui dois canais TCP, um para dados e outro para controle. Note que ao invés do número da porta foram utilizados mnemônicos, porém somente algumas portas o possuem. Abaixo segue a lista dos mnemônicos, sendo que os mais importantes estão em negrito:

```
Dltec-FW-GW(config)#access-list 100 permit tcp any any eq ?
<0-65535>      Port number
bgp             Border Gateway Protocol (179)
chargen         Character generator (19)
cmd             Remote commands (rcmd, 514)
daytime         Daytime (13)
discard         Discard (9)
domain          Domain Name Service (53)
drip            Dynamic Routing Information Protocol (3949)
echo            Echo (7)
exec            Exec (rsh, 512)
finger          Finger (79)
ftp             File Transfer Protocol (21)
ftp-data        FTP data connections (20)
gopher          Gopher (70)
hostname        NIC hostname server (101)
ident           Ident Protocol (113)
irc             Internet Relay Chat (194)
klogin          Kerberos login (543)
```

kshell	Kerberos shell (544)
login	Login (rlogin, 513)
lpd	Printer service (515)
nntp	Network News Transport Protocol (119)
pim-auto-rp	PIM Auto-RP (496)
pop2	Post Office Protocol v2 (109)
pop3	Post Office Protocol v3 (110)
smtp	Simple Mail Transport Protocol (25)
sunrpc	Sun Remote Procedure Call (111)
tacacs	TAC Access Control System (49)
talk	Talk (517)
telnet	Telnet (23)
time	Time (37)
uucp	Unix-to-Unix Copy Program (540)
whois	Nickname (43)
www	World Wide Web (HTTP, 80)

Na última linha de instruções foi inserido o comando para permitir acesso ao protocolo TCP ("access-list 100 permit tcp"), para a rede de origem 10.0.0.0/24 ("10.0.0.0 0.0.0.255"), para quaisquer redes de destino (any) quando o tráfego for direcionado ao telnet (eq 23 ou eq telnet).

O comando para bloquear o restante do tráfego não precisa ser inserido, pois o IOS colocará para você a linha "access-list 100 deny ip any any" no final da sua configuração, porém ela não aparecerá no comando "show running-config" por ser um comando implícito. O parâmetro "ip" inserido no campo do protocolo seleciona todos os protocolos possíveis.

8.7 Exemplo de ACL Estendida Numerada



Para melhor ilustrar o uso de uma ACL estendida vamos a um exemplo. Você deve criar uma ACL que permita a entrada de quaisquer redes externas no caso de acesso a Web (http), FTP. Para o telnet permitir acesso apenas aos Ips da rede 10.0.0.0/24. Para os demais serviços negar acesso.

A resolução você pode verificar a seguir e logo após temos uma explicação mais detalhada de como chegamos nesse resultado.

```
Router(config)#access-list 100 permit tcp any any eq 80
Router(config)#access-list 100 permit tcp any any eq ftp
Router(config)#access-list 100 permit tcp any any eq ftp-data
Router(config)#access-list 100 permit tcp 10.0.0.0 0.0.0.255 any eq 23
```

O primeiro statement ou instrução indica que você permitiu acesso ao protocolo TCP ("access-list 100 permit tcp"), para quaisquer redes de origem e destino ("any any") para porta 80 ("eq 80"), a qual é a porta referente ao serviço http.

Na segunda e terceira instrução foi permitido acesso ao FTP, que possui dois canais TCP, um para dados e outro para controle. Note que ao invés do número da porta foram utilizados mnemônicos, porém somente algumas portas o possuem. Abaixo segue a lista dos mnemônicos, sendo que os mais importantes estão em negrito:

```
Dltec-FW-GW(config)#access-list 100 permit tcp any any eq ?
<0-65535>      Port number
bgp             Border Gateway Protocol (179)
chargen         Character generator (19)
cmd             Remote commands (rcmd, 514)
daytime         Daytime (13)
discard         Discard (9)
domain         Domain Name Service (53)
drip            Dynamic Routing Information Protocol (3949)
echo           Echo (7)
exec           Exec (rsh, 512)
finger         Finger (79)
ftp            File Transfer Protocol (21)
ftp-data       FTP data connections (20)
gopher         Gopher (70)
hostname       NIC hostname server (101)
ident          Ident Protocol (113)
irc            Internet Relay Chat (194)
klogin         Kerberos login (543)
kshell         Kerberos shell (544)
login          Login (rlogin, 513)
lpd            Printer service (515)
nntp           Network News Transport Protocol (119)
pim-auto-rp    PIM Auto-RP (496)
pop2           Post Office Protocol v2 (109)
pop3           Post Office Protocol v3 (110)
smtp           Simple Mail Transport Protocol (25)
sunrpc         Sun Remote Procedure Call (111)
tacacs         TAC Access Control System (49)
talk           Talk (517)
telnet         Telnet (23)
time           Time (37)
uucp           Unix-to-Unix Copy Program (540)
whois          Nicname (43)
www            World Wide Web (HTTP, 80)
```

Na última linha de instruções foi inserido o comando para permitir acesso ao protocolo TCP ("access-list 100 permit tcp"), para a rede de origem 10.0.0.0/24 ("10.0.0.0 0.0.0.255"), para quaisquer redes de destino (any) quando o tráfego for direcionado ao telnet (eq 23 ou eq telnet).

O comando para bloquear o restante do tráfego não precisa ser inserido, pois o IOS colocará para você a linha "access-list 100 deny ip any any" no final da sua configuração, porém ela não aparecerá no comando "show running-config" por ser um comando implícito. O parâmetro "ip" inserido no campo do protocolo seleciona todos os protocolos possíveis.

8.8 Listas de Acesso Nomeadas



As listas de acesso estudadas acima foram a padrão e a estendida numeradas. Você pode configurar uma ACL padrão e estendida com uma ACL nomeada também. A vantagem de uma ACL nomeada é que você pode utilizar um nome sugestivo para guardar a ACL e lembrar para que fim essa ACL foi criada. Além disso ela estende o range de ACLs que podem ser criadas.

Veja o exemplo a seguir para a criação da ACL padrão com o nome de "bloqueiarede". Note que a configuração feita foi para bloquear o acesso à rede 172.16.20.0/24 e permitir quaisquer outras redes.

```
Lab_A#config t
Enter configuration commands, one per line. End with CNTL/Z.
Lab_A(config)#ip access-list ?
extended Extended Acc (ACL estendida)
logging Control access list logging
Standard Standard Access List (ACL padrão)
```

```
Lab_A(config)#ip access-list standard ?
<1-99> Standard IP access-list number
WORD Access-list name
```

```
Lab_A(config)#ip access-list standard bloqueiarede
Lab_A(config-std-nacl)#?
Standard Access List configuration commands:
default Set a command to its defaults
deny Specify packets to reject
exit Exit from access-list configuration mode
no Negate a command or set its defaults
permit Specify packets to forward
```

```
Lab_A(config-std-nacl)#deny 172.16.20.0 0.0.0.255
Lab_A(config-std-nacl)#permit any
Lab_A(config-std-nacl)#exit
```

Lab_A(config)#^Z

8.9 Verificando as ACLs Criadas



Para verificar as ACLs padrão e estendida você pode utilizar os comandos:

- **"show run"** – mostra as ACLs configuradas e onde elas foram aplicadas (em que interfaces)
- **"show access-lists"** – Mostra todas as ACLs
- **"show ip access-lists"** – Mostra apenas as ACLs IP

Nos comandos "show Access-list" e "show ip Access-list" você pode ainda colocar o número da ACL para verificar somente ela.

Para verificar onde uma ACL foi aplicada (em que interface) e se ela é de entrada ou saída entre com o comando **"show ip interface"**, somente esse comando mostra o posicionamento de uma ACL.

```
Router#sho ip access-lists
```

```
Standard IP access list 1
  permit 10.1.2.21
  permit 10.0.0.0, wildcard bits 0.255.255.255
  permit any
Extended IP access list 100
  permit ip 10.0.0.0 0.0.0.255 11.0.0.0 0.0.0.255
  permit tcp any any eq www
  permit tcp any any eq ftp
  permit tcp any any eq ftp-data
  permit tcp 10.0.0.0 0.0.0.255 any eq telnet
```

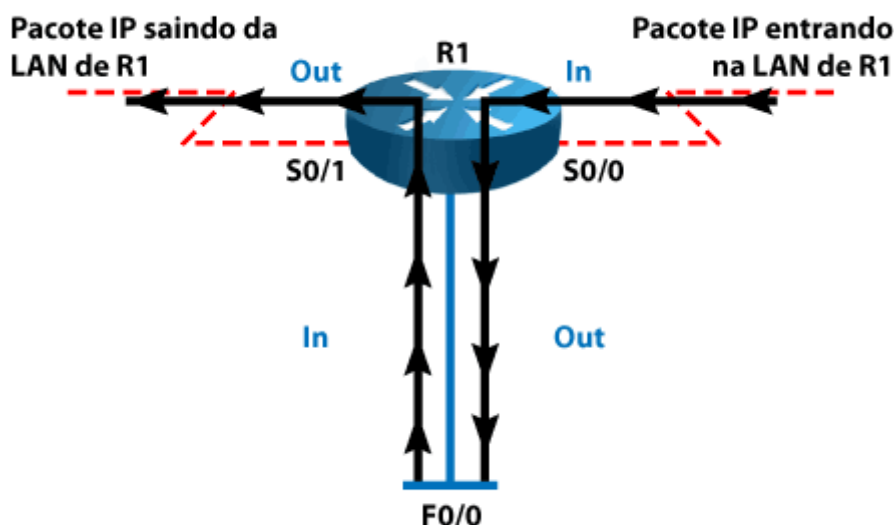
```
Router#show access-lists
```

```
Standard IP access list 1
  permit 10.1.2.21
  permit 10.0.0.0, wildcard bits 0.255.255.255
  permit any
Extended IP access list 100
  permit ip 10.0.0.0 0.0.0.255 11.0.0.0 0.0.0.255
  permit tcp any any eq www
  permit tcp any any eq ftp
  permit tcp any any eq ftp-data
  permit tcp 10.0.0.0 0.0.0.255 any eq telnet
```

8.10 Aplicando ACL nas Interfaces



Após criar a ACL em modo de configuração global, você deve aplicá-la em uma interface. É importante lembrar que a ACL pode ser de entrada (inbound – in) ou de saída (outbound – out). A figura a seguir ilustra o sentido de aplicação de uma ACL em relação ao tráfego IP.



No sentido de entrada (in) os pacotes são processados pela lista de acesso antes de serem encaminhados pela interface de saída. Já no sentido de saída (out) os pacotes são primeiro encaminhados para a saída para depois serem processados pela lista de acesso.

Note que para bloquear um pacote IP que vem pela interface s0/0 em direção a LAN de R1 (f0/0), você pode utilizar uma ACL de entrada na s0/0 ou uma de saída na f0/0. Agora para bloquear um pacote que sai da LAN de R1 em direção a outras redes pode ser filtrado por uma ACL de entrada na interface f0/0 ou de saída na s0/1.

O comando para aplicar a ACL em uma interface é o "ip access-group" em modo de configuração de interface, veja o exemplo a seguir, onde a lista 101 é aplicada no sentido de saída da interface serial 0 do roteador.

```
Router#conf t
```

Enter configuration commands, one per line. End with CNTL/Z.

```
Router(config)#int s0
Router(config-if)#ip access-group 101 out
Router(config-if)#^Z
Router#
```

No caso de aplicar uma lista nomeada ao invés de numerada basta colocar o nome criado ao invés do número, o restante é o mesmo conceito.

```
Router#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#int s0
Router(config-if)#ip access-group bloqueiarede out
Router(config-if)#^Z
Router#
```

8.11 Limitando Acesso ao SSH e Telnet nos Roteadores



Você também pode limitar o acesso ao telnet via VTY utilizando o comando **“access-class”**, dentro da line vty, conforme mostrado a seguir.

```
Router(config)#access-list 10 permit 10.0.0.0 0.0.0.255
Router(config)#line vty 0 15
Router(config-line)#access-class 10 in
Router(config-line)#^Z
Router#
```

No exemplo a lista de acesso 10 que é aplicada na line vty do roteador (comando “access-class”) limita a entrada via telnet apenas para os micros 10.0.0.1 até 10.0.0.254. Os demais IPs não terão acesso ao telnet do roteador via VTY devido ao deny implícito.

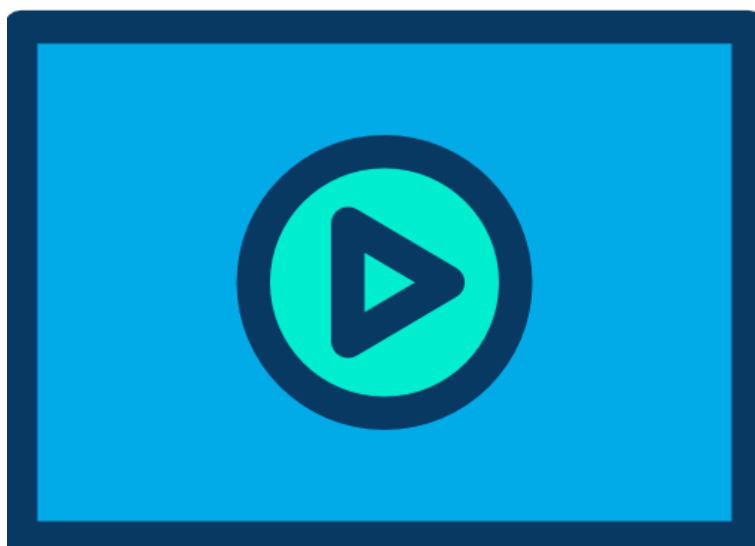
A configuração mostrada é a mesma para roteadores ou switches Cisco. O mesmo comando pode limitar acesso via Telnet ou SSH quando micros remotos tentarem se conectar aos roteadores e/ou switches.

Portanto, uma ACL deve ser aplicada em todas as portas vty na direção que previna um usuário não permitido acessar essa porta desprotegida, através do comando “access-class”.

8.12 Exemplos Práticos de ACLs



8.12.1 Exemplo 1 – ACL Padrão



A empresa ABC Inc tem a política interna de liberar o acesso remoto aos equipamentos de rede somente para os micros de gerenciamento inseridos na rede 192.168.1.0/28. Sua tarefa é criar uma ACL que limite acesso remoto apenas aos micros pertencentes a essa rede.

Para resolver a solicitação acima temos primeiro que criar a lista padrão escolhendo a rede 192.168.1.0/28 (255.255.255.240).

Qual a máscara curinga? Lembre-se de subtrair o broadcast da máscara em questão.
Será "255.255.255.255 - 255.255.255.240 = 0.0.0.15"

Criando a lista:

```
Router#conf t
Router(config)#access-list 10 permit 192.168.1.0 0.0.0.15
```

Como existe um deny (negação) implícito no final de uma ACL somente o comando acima é o suficiente para criar a lista, pois ele deixará passar apenas os IP's da rede 192.168.1.0/24 e os demais serão bloqueados.

Agora vamos aplicar a regra na entrada line vty:

```
Router(config)#line vty 0 15
Router(config-line)#access-class 1 in
Router(config-line)#end
Router#copy run start
```

Com essa config os equipamentos estarão protegidos de acesso não autorizado pelos micros fora da rede de gerenciamento.

8.12.2 Exemplo 2 – ACL Estendida



Agora você deve configurar em um roteador, que tem a sub-rede 192.168.1.0/26 em sua LAN (Fast 0/0) que está entroncada com um Switch de acesso e possui várias sub-redes na mesma interface, para que a rede 192.168.1.128/26 seja bloqueada quando tentar acessar os serviços de FTP e TFTP em quaisquer micros e servidores dentro dessa sub-rede específica. Todas as demais sub-redes devem ser permitidas para todos os serviços.

O primeiro passo é verificar as portas e protocolos dos serviços a serem bloqueados:

FTP: portas 20 e 21 do TCP

TFTP: porta 69 do UDP

Note que os pacotes serão originados na sub-rede 192.168.1.128 e chegarão na rede de destino 192.168.1.0, ou seja, os micros da sub-rede 192.168.1.128 estão em um roteador remoto.

Após isso vamos selecionar a sub-rede de origem a ser bloqueada (ponta remota):
192.168.1.128 /26 ou 255.255.255.192 -> Máscara curinga = 255.255.255.255 - 255.255.255.192 = 0.0.0.63.

A sub-rede do roteador de destino (rede do roteador): 192.168.1.0 /26 ou 255.255.255.192 -> Máscara curinga = 255.255.255.255 - 255.255.255.192 = 0.0.0.63.

Agora vamos criar a lista considerando:

1. Bloquear acesso ao FTP da sub-rede 192.168.1.128 à sub-rede 192.168.1.0:
`Access-list 100 deny tcp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq 20`
`Access-list 100 deny tcp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq 21`
2. Bloquear acesso ao TFTP considerando as mesmas redes do item 1:
`Access-list 100 deny udp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq 69`
3. Permitir as demais redes:
`Access-list 100 permit ip any any`

Ou podemos utilizar os comandos abaixo substituindo o número das portas pelos seus mnemônicos.

```
Access-list 100 deny tcp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq ftp
Access-list 100 deny tcp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq ftp-data
Access-list 100 deny udp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq tftp
Access-list 100 permit ip any any
```

Criada a lista 100 agora teremos que ativar na interface LAN do roteador:

```
Interface fast 0/0
Ip access-group 100 out
```

A lista foi aplicada na saída da interface LAN, ou seja, quando os pacotes de FTP e TFTP vindos da rede 192.168.1.128/26 tentarem sair pela interface serão bloqueados. As demais subredes serão permitidas.

Você pode verificar a ACL com o comando "show ip interfaces" e "show ip access-list 100".

8.12.3 Exemplo 3 – ACL Nomeada Estendida



Agora vamos repetir o exercício anterior utilizando ACL nomeada estendida. Uma ACL estendida é criada com o comando "ip access-list [extended | standard] nome". As regras serão criadas dentro do modo de configuração de ACL.

```
Lab_A(config)#ip access-list extended Exemplo3
Lab_A(config-ext-nacl)#deny tcp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq
ftp
Lab_A(config-ext-nacl)#deny tcp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq
ftp-data
Lab_A(config-ext-nacl)#deny udp 192.168.1.128 0.0.0.63 192.168.1.0 0.0.0.63 eq
tftp
Lab_A(config-ext-nacl)#permit ip any any
Lab_A(config-ext-nacl)#exit
Lab_A(config)#Interface fast 0/0
Lab_A(config-subif)#Ip access-group Exemplo3 out
Lab_A(config-subif)#end
```

8.12.4 Exemplo 4 - ACLs Avançadas de Infraestrutura



Uma ACL de Infraestrutura ou "Infrastructure ACL" tem a função de proteger os dispositivos de rede em geral e normalmente é aplicada nos pontos de entrada da rede, ou seja, nos roteadores de borda da Internet de um sistema autônomo (Edge Network).

São listas de acesso IPv4 e IPv6 (se houver IPv6 implementado) que visam bloquear (deny) acesso de fora aos dispositivos que fazem parte da infraestrutura da rede, por exemplo, bloquear acesso às interfaces dos roteadores, assim como bloquear fragmentos de pacotes, ataque de spoofing, endereços privativos (RFC 1918 e 3330).

Ao mesmo tempo essas ACLs devem permitir tráfego de trânsito, por exemplo, pacotes que são destinados a servidores e hosts internos permitidos, assim como permitir formação de vizinhança BGP nos próprios roteadores de borda e tráfego de gerenciamento (SSH, SNMP, ping, etc.).

Podemos dividir de forma abrangente o tráfego de um roteador em duas categorias, a primeira é aquele destinado ao próprio roteador, o qual o processador terá que tratar diretamente, e o segundo que é o tráfego que passa pelo roteador, que podemos chamar de tráfego de trânsito. A maioria das vezes o tráfego simplesmente passa ou é encaminhado pelo roteador, ou seja, em sua maioria é tráfego de trânsito.

Porém existe uma porcentagem do tráfego que o próprio roteador terá que tratar, por exemplo, protocolos de roteamento, acesso remoto via Telnet ou SSH e gerenciamento de rede via SNMP. Além disso, protocolos como o ICMP também são processados pela CPU do roteador.

O tráfego excessivo pode causar uso excessivo da CPU, resultando em perda de pacote e até a indisponibilidade total do roteador, caracterizando um ataque negação de serviço (denial-of-service - DoS), por isso a liberação de ping, por exemplo, deve ser feita de maneira correta para evitar que um simples flooding de ICMP possa colocar o roteador em risco.

Por isso filtrando tráfego destinado aos roteadores de infraestrutura na borda da rede muitos dos riscos a esses dispositivos são mitigados, pois os ataques são bloqueados no roteador de borda.

Não confunda o que vamos fazer aqui com técnicas de filtragem genéricas, pois a proteção da infra com ACL está restrita aos protocolos e origens dos equipamentos de infraestrutura.

Veja um exemplo de ACL de infraestrutura que será vinculada a interface serial 0/0 que está conectada à Internet.

```
ip access-list extended INFRA
!
remark Bloqueio de fragmentos
deny tcp any any fragments
deny udp any any fragments
deny icmp any any fragments
deny ip any any fragments
!
remark Bloquear RFC 1918 e registrar tentativas de spoofing
deny ip 10.0.0.0 0.255.255.255 any log
deny ip 192.168.0.0 0.0.255.255 any log
deny ip 172.16.0.0 0.15.255.255 any log
!
remark Permitindo BGP com o peer específico
permit tcp host < bgp-peer-vizinho > host < bgp-peer-interno > eq bgp
permit tcp host < bgp-peer-vizinho > eq bgp host < bgp-peer-interno >
remark Permitindo gerenciamento via SSH HTTPS SNMP e Ping
permit tcp < IPs-de-gerenciamento > any eq 22
permit tcp < IPs-de-gerenciamento > any eq 443
permit tcp < IPs-de-gerenciamento > any eq 161
permit icmp < IPs-de-gerenciamento > any echo
!
remark Bloquear trafego para redes internas de Infraestrutura
deny ip any < endereçamento-interno-de-infra >
!
remark Permitir trafego de transito
permit ip any any
exit
!
! Aplicar a ACL na interface de borda ou
! saída de Internet
!
interface Serial0/0
ip access-group INFRA in
```

A ACL estendida criada inicia bloqueando os fragmentos TCP, UDP, ICMP e IP, assim como endereços privativos da RFC 1918 com a opção de "log" incluída para monitorar as tentativas de spoofing.

Na sequência vem as permissões do protocolo de roteamento BGP e protocolos/ferramentas de gerenciamento de redes (SSH, HTTPS, SNMP e ping) sempre específicos para os vizinhos ou redes de gerenciamento.

Na sequência bloqueamos o acesso aos IPs internos de infraestrutura, os quais são as redes e endereços de interfaces utilizadas nos roteadores, switches e servidores que devem ser acessados apenas pela rede interna.

Por isso esse comando pode ser subdividido em vários dependendo de cada rede e sua estrutura de endereçamento.

Por último vem a liberação do restante do tráfego de trânsito e a aplicação da ACL estendida na interface de borda com a Internet.

Dica prática: ativar o "log" em uma ACL permite que você tenha uma visão do tráfego que está sendo bloqueado ou permitido na rede, porém ele pode fazer com que a CPU seja mais utilizada e acabe aumentando seu uso de maneira negativa, principalmente porque o log é feito via "process switching".

8.13 Editando ACLs Numeradas



As ACLs numeradas, tanto para padrão como estendida, em versões mais antigas do Cisco IOS não podiam ser editadas ou ter sua sequência de regras alteradas (reposicionamento das regras). Novas regras são sempre inseridas no final da lista, por isso para alterar a sequência das regras é necessário **apagar toda a ACL e recriá-la na ordem correta**.

Por exemplo, você criou a ACL abaixo e percebeu que a terceira linha não deveria estar declarada e deseja apagá-la, conforme exemplo abaixo.

```
Access-list 100 permit tcp host 198.18.1.3 any eq www
Access-list 100 deny ip host 198.18.1.3 any
Access-list 100 deny ip any any
Access-list 100 deny tcp any any eq www
Access-list 100 permit ip any any
```

Não tem como você digitar "no Access-list 100 deny ip any any", isso não irá funcionar. Será necessário digitar "no Access-list 100" para apagar toda a lista e recriá-la sem o comando indesejado.

```
No Access-list 100
Access-list 100 permit tcp host 198.18.1.3 any eq www
Access-list 100 deny ip host 198.18.1.3 any
Access-list 100 deny tcp any any eq www
Access-list 100 permit ip any any
```

Nos IOSs mais novos as ACLs padrões são criadas com índices e podem ser alteradas como vamos ver a seguir para as ACLs nomeadas. Apesar disso, na configuração global os índices não são exibidos, apenas com o comando "show ip access-lists".

```
Dltec-FW-GW#sho ip access-list 1
Standard IP access list 1
 10 permit 10.0.1.0, wildcard bits 0.0.0.255
 20 permit 192.168.1.0, wildcard bits 0.0.0.255 (106877 matches)
 30 permit 192.168.2.0, wildcard bits 0.0.0.255
Dltec-FW-GW#show run | section access-list 1
access-list 1 permit 10.0.1.0 0.0.0.255
access-list 1 permit 192.168.1.0 0.0.0.255
access-list 1 permit 192.168.2.0 0.0.0.255
```

Note que cada comando está vinculado a um índice, porém a configuração não mostra esses índices. Para fazer a alteração devemos entrar na ACL padrão como se estivéssemos entrando em uma ACL nomeada, veja abaixo.

```
Dltec-FW-GW(config)#ip access-list standard 1
Dltec-FW-GW(config-std-nacl)#
```

Para apagar e inserir comandos é só seguir os passos que vamos estudar a seguir para as ACLs nomeadas.

8.14 Editando ACLs Nomeadas



Para as ACLs nomeadas podemos apagar entradas únicas, ou seja, apagar linhas específicas, assim como inserir regras na posição que desejarmos. Isso porque as ACLs nomeadas têm cada regra ou statement referenciado com um **número de sequência**, o que nos permite apagar e inserir regras utilizando esse parâmetro. Veja o exemplo abaixo.

```
dltec#conf t
Enter configuration commands, one per line.  End with CNTL/Z.
dltec(config)#ip access-list extended Bloqweb
dltec(config-ext-nacl)# permit tcp host 198.18.1.3 any eq www
dltec(config-ext-nacl)# deny ip host 198.18.1.3 any
dltec(config-ext-nacl)# deny tcp any any eq www
dltec(config-ext-nacl)# permit ip any any
dltec(config-ext-nacl)#do show ip access-list Bloqweb
Extended IP access list Bloqweb
 10 permit tcp host 198.18.1.3 any eq www
 20 deny ip host 198.18.1.3 any
 30 deny tcp any any eq www
 40 permit ip any any
dltec(config-ext-nacl)#
```

Note que quando criamos a ACL nomeada estendida chamada **Bloqweb** o roteador vincula automaticamente um índice ou número de sequência a cada entrada variando de 10 em 10. Se quisermos agora apagar a segunda linha basta digitar “**no 20**” dentro do modo de configuração da ACL Bloqweb.

```
dltec(config-ext-nacl)#no 20
dltec(config-ext-nacl)#do show ip access-list Bloqweb
Extended IP access list Bloqweb
 10 permit tcp host 198.18.1.3 any eq www
 30 deny tcp any any eq www
 40 permit ip any any
dltec(config-ext-nacl)#
```

Note que a linha com o número de sequência 20 foi apagada, agora podemos criar uma regra com o número 20 para substituir a anterior.

```
dltec(config-ext-nacl)#20 permit tcp any any eq 555
dltec(config-ext-nacl)#do show ip access-list Bloqweb
Extended IP access list Bloqweb
 10 permit tcp host 198.18.1.3 any eq www
 20 permit tcp any any eq 555
 30 deny tcp any any eq www
 40 permit ip any any
dltec(config-ext-nacl)#
```

8.15 Pacotes Gerados pelo Próprio Roteador

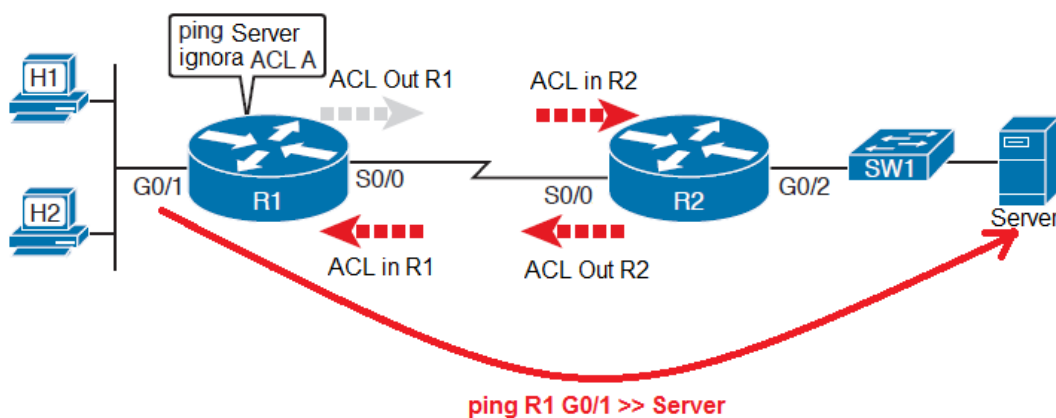


É importante saber uma regra que existe nas ACLs, a qual diz que os roteadores devem ignorar regras de saída (outbound ACL) de pacotes gerados por eles mesmos.

Essa lógica existe porque o roteador não deve descartar seu próprio tráfego, pois assim pacotes gerados pelos protocolos de roteamento, ping e traceroute poderiam afetar negativamente o tráfego do roteador.

Mas como essa exceção a lógica das ACLs de saída interfere na prática nossas regras de acesso?

Por exemplo, veja a figura a seguir onde vamos analisar três efeitos dessa lógica iniciando pelo roteador R1 pingando o servidor remoto. Vamos considerar que você inseriu uma ACL de saída (outbound) na interface s0/0 para que não pudesse ser realizado o ping a partir da rede LAN de R1 para a rede remota. Na hora de fazer o ping você utiliza a opção estendida e coloca o IP da LAN de R1 como origem dos pacotes para o ping em direção ao servidor. O que vai acontecer nesse caso? A ACL vai ou não filtrar esse pacote?



A resposta é NÃO, se você precisar fazer essa filtragem necessitará colocar a ACL na entrada ou saída de R2 ou então na entrada de R1, pois na saída de R1 a lógica da ACL de outbound deixará pacotes gerados pelo próprio roteador passarem pela interface.

Para testar essa regra você deveria fazer o ping a partir dos hosts H1 ou H2.

Outro efeito que você deve entender é sobre o "self-ping", ou seja, o administrador de redes pingando o próprio endereço IP.

O self-ping funciona de formar diferente em redes LAN (Ethernet) e WAN (seriais), por isso você deve entender o processo.

Nas interfaces seriais o pacote é realmente enviado para o vizinho e retornado para o roteador de origem, sendo que se houver uma ACL de saída (outbound) ela é ignorada pela mesma lógica explicada no exemplo anterior.

Caso o ping falhe você deve verificar as configurações dos Layers 1, 2 e 3, por exemplo, os routers deve estar com as interfaces seriais funcionando (up/up) e com o endereçamento IPv4 configurado corretamente.

Além disso, as ACLs de entrada (in) em R1 e R2, assim como a ACL de saída (out) de R2 devem permitir a respostas do ping (echo reply).

Note que o pacote não é processado em R1 na saída (out), porém o retorno é processado pela ACL de entrada normalmente, não importando se ele foi ou não gerado pelo próprio router R1.

No caso de interfaces LAN, por exemplo, um self ping em R1 a partir da G0/1, o pacote não é realmente enviado na rede como no exemplo da serial.

Ao invés disso ele é processado pela pilha TCP/IP como se fosse enviado e tivesse sido recebido pela própria interface, porém sem nunca ter sido realmente enviado na rede.

Nesse caso a regra de saída da ACL (out) é ignorada, porém a de entrada (in) não. Portanto um self-ping que não funciona significa que a interface pode não estar up/up, ter seu IP configurado errado ou ter uma ACL de entrada bloqueando a mensagem echo-reply do ICMP.

8.16 Resumo sobre ACL's Padrões e Estendidas



Vamos lembrar das regras básicas sobre a criação e funcionamento de uma ACL.

- ACLs são criadas em modo de configuração global e, em seguida, aplicadas em uma interface.
- Uma ACL pode filtrar o tráfego que passa através do roteador, em trânsito ou que vai para o roteador, dependendo de como ela é aplicada (em que interface e que direção – in/out).
- Apenas uma ACL por interface - por protocolo roteado, por direção - é permitida.
- O termo standard/padrão ou extended/estendida indica que informação pode ser utilizada para filtrar pacotes.
- ACLs são processadas de cima para baixo. Uma vez que um pacote passar em um teste da ACL, o processamento para ele e o pacote é permitido ou negado, portanto, as declarações ou statements mais específicas devem ir ao topo da lista, ou seja, o que tem maior probabilidade de ocorrer (dar match) deve ir primeiro.
- Todas as ACLs tem uma negação implícita "deny any" no final, portanto, cada lista deve ter pelo menos uma declaração de autorização (permit) para permitir o tráfego passar. Caso seja criada uma ACL somente com comandos de negação ou deny todo o tráfego na interface que ela for aplicada será bloqueado.
- Uma ACL padrão deve ser aplicada mais próximo ao destino do tráfego a ser bloqueado, pois ela somente verifica pacotes de origem. Já uma ACL estendida deve ser aplicada mais próxima à origem do tráfego a ser bloqueado, pois assim você evita tráfego desnecessário passando pela rede. Veja a figura a seguir.



- Quando novas entradas ou statements são adicionadas a uma ACL já criada, eles são sempre adicionados no final da lista, ou seja, se você adicionar um statement ele será o último comando a ser analisado. Por isso, recomenda-se quando necessário alterar uma ACL apagar a antiga e criar uma nova.
- Se você estiver usando Cisco IOS Versão 12.3 ou posterior, números de sequência podem ser utilizados para garantir que uma nova instrução seja adicionada no local correto.
- A ACL é processada de cima para baixo com base nos números de sequência das declarações (do mais baixo ao mais alto).
- Alguns pacotes gerados pelo roteador, como atualizações de tabela de roteamento, não estão sujeitos à filtragem por ACL no roteador de origem. Se a política de segurança requer filtrar esses tipos de pacotes, ACLs de entrada em roteadores vizinhos ou outros mecanismos de filtragem devem ser utilizados.

8.17 Listas de Controle de Acesso IPv6



Lembre-se que um endereço IPv6 tem 128 bits e é escrito em hexadecimal, não mais em decimal pontuado, portanto as redes de origem e destino nas ACLs serão diferentes. Já os protocolos de camadas superiores, tais como TCP e UDP continuam os mesmos, por exemplo, para bloquear acesso ao HTTP no IPv6 é só selecionar na ACL o protocolo TCP porta 80.

As ACLs IPv6 podem basicamente filtrar os seguintes itens:

- Endereços e/ou redes de origem e destino.
- Portas TCP e/ou UDP de origem e destino.
- Informações específicas no cabeçalho, tais como códigos IPv6, classe de tráfego, tipos de código do ICMPv6, etc.
- Filtrar pacotes com cabeçalhos de extensão com base na informação do "next header" (próximo cabeçalho) ou então que contenha simplesmente a opção "Next header".
- Utiliza prefixo contínuo (por exemplo, /36, /48, /64, etc.) para dar match nos endereços ao invés de máscaras curingas.
- O deny implícito também está presente no final da ACL, porém com a exceção de pacotes de neighbor solicitation (NS), neighbor advertisement (NA), Router Solicitation (RS) e Router Advertisement (RA) pois eles são implicitamente habilitados. Se você quiser bloquear tudo no final de uma ACL IPv6 você precisará incluir regras explícitas com deny para o NS/NA e RS/RA.
- Se uma ACL que não foi criada ou apagada em modo de configuração global for aplicada a uma interface nada ocorre, assim como estudamos para o IPv4.
- Não possui opção de ACL numerada, somente nomeada.

Note que a maior diferença é com o deny implícito que deixa passar pacotes de NS, utilizados para descobrir o MAC remoto em LANs (substituto do ARP request), e de RA que solicitam o prefixo do roteador local para o processo de autoconfiguração (SLAAC – Stateless Address Auto Configuration).

Você pode alterar esse padrão colocando um deny explícito, porém deve ter cuidado porque sem o NA/NS os vizinhos não são capazes de se comunicar.

Outro detalhe sobre as ACLs IPv6 é que não existe mais a opção "standard" e "extended" como existia na ACL IP nomeada, porém você pode fazer uma configuração parecida com o que era feito para a ACL IPv4 padrão escolhendo a opção "ipv6" e definindo origem e destino.

```
(config)#ipv6 access-list nome-da-ACL-IPv6
(config-ipv6-acl)#[permit | deny] ipv6 {prefixo-ipv6-de-origem/tamanho-do-prefixo | any |
host endereço-ipv6-de-origem} {prefixo-ipv6-de-destino/tamanho-do-prefixo | any | host
endereço-ipv6-de-destino} [log]
```

A ACL IPv6 estendida na realidade é a mesma ACL, porém com todas as opções possíveis.

```
[permit | deny] protocol {prefixo-ipv6-de-origem/tamanho-do-prefixo | any | host endereço-
ipv6-de-origem} [operator [port-number]] {prefixo-ipv6-de-destino/tamanho-do-prefixo | any
| host endereço-ipv6-de-destino} [operator [port-number]] [dest-option-type [doh-number |
doh-type]] [dscp value] [flow-label value] [fragments] [log] [log-input] [mobility]
[mobility-type [mh-number | mh-type]] [reflect name [timeout value]] [routing] [routing-
type routing-number] [sequence value] [time-range name]
```

Podemos escolher vários parâmetros e nos exemplos vamos focar nos que realmente podem ser cobrados no exame e mais utilizados na prática para um profissional CCNA.

8.17.1 Configurando uma ACL IPV6



Para configurar a ACL IPv6 utilizamos o mesmo princípio de criar as regras em modo de configuração global e depois aplicar a lista em uma interface, sub-interface ou na VTY. Veja abaixo um exemplo de navegação nas opções de criação das listas.

```
R1(config)#ipv6 access-list ?
WORD          User selected string identifying this access list
log-update    Control access list log updates
```

```
R1(config)#ipv6 access-list CCNA-DLteC
R1(config-ipv6-acl)#?
IPv6 Access List configuration commands:
default      Set a command to its defaults
deny         Specify packets to reject
evaluate     Evaluate an access list
exit         Exit from access-list configuration mode
no           Negate a command or set its defaults
permit       Specify packets to forward
```

```
remark    Access list entry comment
sequence  Sequence number for this entry
<cr>
```

```
R1(config-ipv6-acl)#deny ?
<0-255>    An IPv6 protocol number
X:X:X:X::X/<0-128> IPv6 source prefix x:x::y/<z>
ahp        Authentication Header Protocol
any        Any source prefix
esp        Encapsulation Security Payload
host       A single source host
icmp       Internet Control Message Protocol
ipv6       Any IPv6
pcp        Payload Compression Protocol
sctp       Streams Control Transmission Protocol
tcp        Transmission Control Protocol
udp        User Datagram Protocol
```

```
R1(config-ipv6-acl)#deny 2000::/64 ?
X:X:X:X::X/<0-128> IPv6 destination prefix x:x::y/<z>
any        Any destination prefix
host       A single destination host
```

```
R1(config-ipv6-acl)#deny 2000::/64 any
R1(config-ipv6-acl)#permit any any
```

No exemplo acima foi criada a lista de acesso com o nome **CCNA-Dltec**, a qual não permite pacotes com a rede de origem 2000::/64, porém todos os demais pacotes IPv6 são permitidos.

Para aplicar a lista na interface utilizamos o comando "**ipv6 traffic-filter**" com o nome da lista e o sentido do tráfego a ser filtrado (in ou out → igual ao que estudamos para IPv4). Veja a aplicação da lista acima na interface fast 0/0 do roteador.

```
R1(config-)#int f0/0
R1(config-if)#ipv6 traffic-filter CCNA-Dltec out
R1(config-if)#
```

Para aplicar a ACL IPv6 à VTY precisamos criar a lista em modo de configuração global e vinculá-la à line com o comando "**ipv6 access-class**". Veja exemplo abaixo.

```
R1(config)#ipv6 access-list cisco
R1(config-ipv6-acl)# permit tcp host 2001:100:0:4::30 any eq 22
R1(config-ipv6-acl)#!
R1(config-ipv6-acl)#line vty 0 4
R1(config-line)# ipv6 access-class cisco in
```

Com essa configuração apenas o host 2001:100:0:4::30 poderá acessar o roteador via SSH, não podendo fazer acesso via Telnet.

8.17.2 Exemplo de ACL IPv6



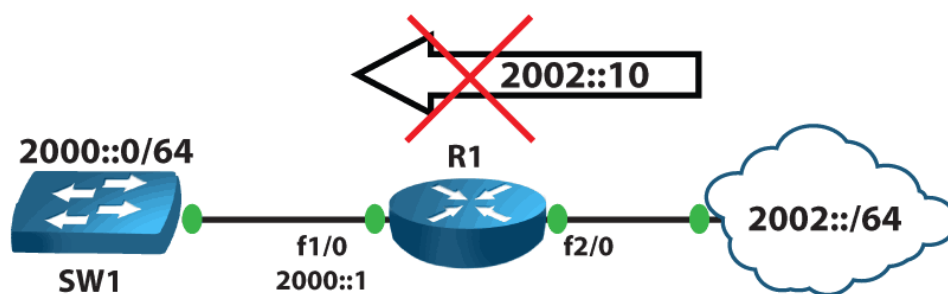
Vamos aproveitar o exemplo de ACL estendida do IPv4 e realizar as configurações com IPv6.

Agora você deve configurar o roteador R1, que tem a sub-rede 2000::/64 em sua LAN (Fast 1/0) que está entroncada com um Switch de acesso e possui várias sub-redes na mesma interface, para que a rede 2002::/64 seja bloqueada quando tentar acessar os serviços de FTP e TFTP em quaisquer micros e servidores dentro dessa sub-rede específica. Todas as demais sub-redes devem ser permitidas para todos os serviços.

O primeiro passo é verificar as portas e protocolos dos serviços a serem bloqueados:

- **FTP:** portas 20 e 21 do TCP
- **TFTP:** porta 69 do UDP

Note que os pacotes serão originados na sub-rede 2002::/64 e chegarão na rede de destino 2000::/64, ou seja, os micros da sub-rede 2002::/64 estão em um roteador remoto.



```
R2(config)#Ipv6 access-list bloq-2002
R2(config-ipv6-acl)# deny tcp 2002::/64 2000::/64 eq ftp
R2(config-ipv6-acl)# deny tcp 2002::/64 2000::/64 eq ftp-data
R2(config-ipv6-acl)# deny udp 2002::/64 2000::/64 eq tftp
R2(config-ipv6-acl)# permit ipv6 any any
R2(config-ipv6-acl)#exit
R2(config)#Interface fast 1/0
R2(config-if)# ipv6 traffic-filter bloq-2002 out
R2(config-if)#end
R2#
```

Para verificar as ACLs de IPV6 utilize os comandos **show running-config** e **show ipv6 access-list**.

```
R2#show running-config | begin ipv6 access-lis
```

```
ipv6 access-list blog-2002
  deny tcp 2002::/64 2000::/64 eq ftp
  deny tcp 2002::/64 2000::/64 eq ftp-data
  deny udp 2002::/64 2000::/64 eq tftp
  permit ipv6 any any
```

```
### Saídas Omitidas ###
```

```
R2#show running-config interface f0/0
```

```
Building configuration...
```

```
Current configuration : 106 bytes
```

```
!
```

```
interface FastEthernet1/0
```

```
  no ip address
```

```
  ipv6 enable
```

```
  ipv6 address 2000::1/64
```

```
  duplex full
```

```
  ipv6 traffic-filter blog-2002 out
```

```
end
```

```
R2#
```

```
R2#show ipv6 access-list
```

```
IPv6 access list blog-2002
```

```
  deny tcp 2002::/64 2000::/64 eq ftp sequence 10
```

```
  deny tcp 2002::/64 2000::/64 eq ftp-data sequence 20
```

```
  deny udp 2002::/64 2000::/64 eq tftp sequence 30
```

```
  permit ipv6 any any sequence 40
```

```
R2#
```

9 Segurança em Camada 2

9.1 Introdução



Ainda hoje é dada muita atenção para segurança do perímetro através do uso de firewall, IPS, IDS e mitigando ataques ao Layer 3 (camada de rede).

Porém as redes LANs e Campus, tipicamente Layer 2, precisam de tanta atenção quanto a borda de Internet, pois sabemos que muitos ataques se iniciam dentro das redes locais e são muito difíceis de mitigar.

Os ataques internos são realizados através da inserção de equipamentos intrusos (rogue devices) ou comprometendo um dispositivo legítimo da rede.

Equipamentos que não são da rede (piratas ou intrusos) podem ser inseridos para fins escusos ou simplesmente ampliar o número de portas físicas ou ter acesso sem fio.

Equipamentos como roteadores Wireless ou Access Points, switches de acesso ou Hubs são frequentemente utilizado por usuários para garantir acesso a um laptop pessoal, tablet ou smartphone.

Esse tipo de situação é tratável com o uso de técnicas disponíveis nos switches.

Temos tipicamente quatro tipos de ataques que podem ser realizados contra redes que utilizam switches (LANs ou Campus):

- **Ataques baseados em Endereços MAC:** MAC address-table flooding, CDP Flooding e DHCP Starvation.
- **Ataques às VLANs:** VLAN hopping e ataques a dispositivos na mesma VLAN.
- **Ataques de Spoofing (falsificações):** DHCP snooping, IP spoofing, MAC spoofing, Address Resolution Protocol (ARP) spoofing e ataques ao Spanning Tree.
- **Ataques contra os Switches:** manipulação do Cisco Discovery Protocol (CDP), ataques ao Telnet e Secure Shell (SSH).

Nesse capítulo vamos estudar alguns desses ataques e riscos de segurança que são foco do blueprint atualizado do CCNA, bem como utilizar alguns recursos do Cisco IOS para a família Catalyst que ajudam a prevenir e agir contra essas ameaças.

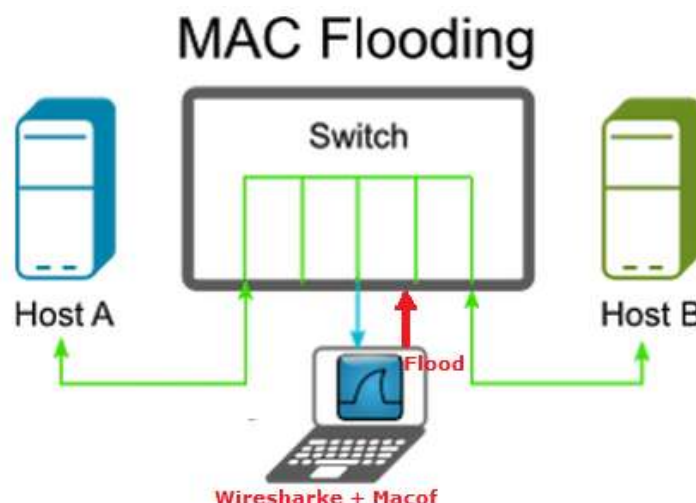
9.2 Mitigando Ataques Baseados no Endereço MAC



O ataque realizado utilizando o MAC mais comum é realizado através do flooding de endereços MAC causando o esgotamento da CAM table, a qual tem um valor máximo. Esse ataque é chamado "**MAC Flooding**".

Esse ataque pode ser mitigado utilizando os recursos de port security e autenticação baseada em porta (em inglês, Port-based Authentication).

No ataque de flooding de endereços MAC o atacante lota a Content Addressable Memory (CAM) do switch com endereços MAC falsos gerados aleatoriamente para transformar o switch em um HUB.



Mas porque isso acontece? As tabelas MAC têm uma capacidade máxima, por isso quando a tabela está cheia o switch não consegue mais aprender endereços legítimos e passa a fazer flooding em todas as interfaces, permitindo que o atacante capture e "espione" os quadros trafegados pelo switch utilizando um sniffer.

Além disso, o ataque tem outros efeitos colaterais, por exemplo, mais tráfego é gerado na LAN e sobrecarregando os links e switches (memória e processamento elevados).

Esse processo pode ser utilizado para gerar o mesmo efeito em switches vizinhos e possibilitar que o atacante capture e espione o tráfego deles, principalmente quando são utilizadas VLANs estendidas.

Depois que o ataque cessa, as entradas falsas na CAM são apagadas quando o timer "aging time" se esgota e tudo volta ao normal.

Já o atacante vai realizar sua lição de casa analisando o tráfego coletado atrás de informações relevantes, nomes de usuários, senhas em texto claro, etc.

Esse ataque desmistifica a frase de que "nos switches não tem como fazer sniffing tão facilmente como nos HUBs", o processo é mais simples que você pensa.

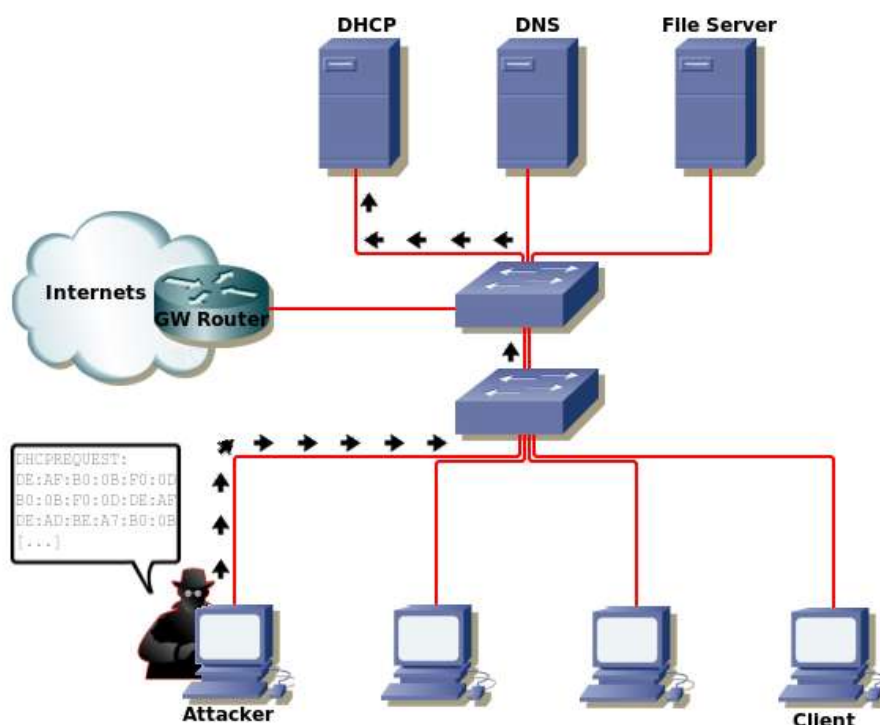
Softwares como Macof e Wireshark realizam essa tarefa com extrema facilidade.

Outra opção é o Dsniff do Linux que já tem integrado ao Macof e um sniffer.

Outros dois ataques que podem ser mitigados com o Port Security são o **DHCP Starvation** e o **CDP Flooding**.

O **DHCP Starvation** consiste em um host enviar vários pedidos de DHCP Discovery e alocar vários IPs para ele mesmo, esgotando os IPs do pool (escopo) verdadeiro do servidor DHCP.

Assim o atacante pode colocar seu próprio servidor DHCP e fazer um ataque de Man-In-The-Middle (MITM), fazendo com que todos os pacotes passem por ele antes de serem realmente encaminhados.



O **flooding de CDP** é bem parecido com o MAC Flooding, porém um host envia vários pacotes do CDP como se o switch ou roteador diretamente conectado tivesse vários vizinhos naquela porta.

Isso gera dois problemas, o primeiro é que a CPU pode subir a 99% “travando” o switch, já o segundo é que ao mesmo tempo é possível estourar a tabela MAC da VLAN em que o host está conectado para que seja possível o sniffing (espionagem dos pacotes).

Vamos a seguir estudar um dos recursos de segurança que ajudam a proteger contra os ataques citados anteriormente.

9.3 Ativando o Port Security



O objetivo do **port security** é **impedir** que **hosts não autorizados** acessem a rede, restringindo o número máximo de endereços MAC por porta do switch.

Caso haja uma violação da regra uma ação é tomada conforme configuração realizada.

Seguem alguns pontos importantes para reforçar a importância do uso do Port Security:

- Existem muitos ataques que são simples de executar na Camada 2.
- A necessidade de segurança na camada 2 tende a ser minimizada na maioria das empresas.
- Pode proteger contra diversos tipos de ataques, tais como inundações MAC (MAC Flooding) e dispositivos conectados em portas não permitidas, dentre outros.

Existem três tipos de configurações básicas do Port Security:

1. **Endereços MAC seguros estáticos (Static)** - Configurados manualmente dentro da configuração de interface. Esse endereço é armazenado na tabela de endereços e se outro computador for conectado a essa porta ela pode ser bloqueada, conforme configuração.
2. **Endereços MAC seguros dinâmicos (Dynamic)** - Estes são configurados dinamicamente, armazenados apenas na tabela de endereços na memória RAM e removidos na reinicialização do switch. Esse é o padrão ativado pelos switches.
3. **Endereços MAC seguro fixos (Sticky)** - Podem ser aprendidos dinamicamente ou configurados manualmente, são armazenados na tabela de endereços. Se os endereços estão salvos na NVRAM, quando o switch é reinicializado, a interface não tem necessidade de ser reconfigurada dinamicamente, mas para isso você deve especificar o MAC.

Abaixo seguem os passos para configuração da segurança de portas:

1. Colocar a porta em modo de acesso (**switchport mode access**);
2. Habilitar port security (**switchport port-security**);
3. Definir o limite de endereços MAC na porta (padrão 1 - **switchport port-security maximum**);
4. Especificar como o switch aprenderá os endereços MACs a serem protegidos (padrão dinâmico);
5. Definir ações em caso de violação (padrão shutdown).

Sobre o item 1 é preciso ter em mente que podemos ativar o port security em um trunk desde que ele seja configurado como estático com o comando "switchport mode trunk", além disso, somente portas L2 suportam o port security (comando switchport).

Com o comando "**switchport port-security**" o padrão de segurança é implementado com as seguintes características:

- Limite de MACs aprendidos por porta **1**.
- Modo de aprendizagem dos MACs **dinâmico** sem gravar o MAC aprendido na NVRAM, ou seja, com um reload o switch apaga o MAC da tabela e terá que aprender novamente.
- Ação em caso de violação **shutdown**, ou seja, derruba a porta e coloca em estado "error-disable" ou desabilitada por erro para indicar que a porta está em shutdown por um motivo diferente do tradicional.

```
Switch(config)#int fast 0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security ?
aging                Port-security aging commands
mac-address          Secure mac-address
maximum              Max secure addr
violation            Security Violation Mode
<cr>
Switch(config-if)#switchport port-security
Switch(config-if)#
```

Em modo de Interface no switch teremos as seguintes opções para configurar o Port Security, acompanhe abaixo.

```
Switch(config-if)#switchport port-security ?
aging          Port-security aging commands
mac-address    Secure mac-address
maximum        Max secure addrs
violation      Security Violation Mode
<cr>
```

Portanto, podemos alterar a maneira que os switches aprendem endereços MAC (**opção mac-address**), qual o limite de endereços que a porta pode aprender (**opção maximum**) e também qual ação o switch deve tomar se uma violação for detectada (**opção violation**), ou seja, se o máximo de MACs seguros permitidos for ultrapassado.

A opção **aging** define o tempo que um MAC seguro ficará mantido na tabela quando há aprendizado dinâmico, caso ele não seja detectado é apagado da tabela de MACs seguros, por padrão ele é infinito (valor time igual a zero). Veja abaixo.

```
SW-Dltec-Rack-01(config-if)#switchport port-security aging ?
static  Enable aging for configured secure addresses
time    Port-security aging time
type    Port-security aging type
```

```
SW-Dltec-Rack-01(config-if)#switchport port-security aging type ?
absolute  Absolute aging (default)
inactivity Aging based on inactivity time period
```

```
SW-Dltec-Rack-01(config-if)#switchport port-security aging time ?
<1-1440> Aging time in minutes. Enter a value between 1 and 1440
```

```
SW-Dltec-Rack-01(config-if)#switchport port-security aging type ?
absolute  Absolute aging (default)
inactivity Aging based on inactivity time period
```

A opção **static** ativa a configuração de aging para os MACs estáticos configurados manualmente (via comando `switchport port-security mac-address`).

A opção **time** define quanto tempo o MAC aprendido dinamicamente será armazenado entre 1 e 1440 minutos. O valor zero define o padrão que é infinito (`switchport port-security aging time 0`).

Já a opção **type** define se o tempo do aging será absoluto (**absolute** – padrão) ou por inatividade (**inactivity**), ou seja, se você configurar o aging para 5 minutos e do tipo absoluto, se o switch aprender um MAC dinâmico na porta ele será apagado após 5 minutos, não importando se ele teve atividade ou não (mesmo enviando quadros através da porta ou com tráfego).

Se você utilizar a opção **inactivity** o MAC é apagado somente após ele ficar o tempo especificado no comando "**time**" sem enviar nenhum quadro (sem tráfego) que ele será apagado.

Para alterar o padrão de aprendizado de dinâmico para **sticky** ou manual utilizamos o comando "**switchport port-security mac-address**" definindo a seguir o padrão a ser configurado.

A primeira opção de configuração que vamos estudar é através do parâmetro **"sticky"** (em português "pegajoso"), o comando fica **"switchport port-security mac-address sticky"**.

Esse parâmetro faz com que o switch **escreva na NVRAM** o endereço que ele aprendeu, com isso mesmo que você reinicialize o switch ele manterá em sua configuração o MAC que ele aprendeu quando você ativou o Port Security.

Com a opção "sticky" podemos definir um MAC estático, por exemplo, com o comando **switchport port-security mac-address sticky aaaa.bbbb.cccc**".

Essa opção permite definir um MAC específico para porta e mesmo assim ter um máximo de MACs seguros maior que um.

Você pode também definir manualmente o MAC digitando o endereço no formato H.H.H, por exemplo, **"switchport port-security mac-address aaaa.aaaa.aaaa"**.

Com esse comando o switch considera que o host com o MAC **aaaa.aaaa.aaaa** está conectado na porta e o máximo de MACs seguros para essa porta é definido para um automaticamente, ou seja, a contagem de MACs é incrementada.

Por exemplo, com os comandos **"switchport port-security"** e **"switchport port-security mac-address aaaa.bbbb.cccc"** em uma das portas do switch, se um computador com MAC diferente de **aaaa.bbbb.cccc** se conectar à porta ela será colocada em "error-disable" e será desabilitada, gerando uma mensagem de erro para a console e para um servidor SNMP, caso tenha sido configurado.

A configuração da violação tem três padrões de ação no port security, veja a saída do comando abaixo.

```
SW-Dltec(config-if)#switchport port-security violation ?
protect      Security violation protect mode
restrict     Security violation restrict mode
shutdown     Security violation shutdown mode
```

O padrão é o **shutdown**, o qual desabilita a porta e coloca ela em um estado chamado "error-disable" e gera um alarme para o gerenciamento via snmp trap e mensagem de syslog.

Se a violação estiver configurada como **"protect"** ou protegido, caso haja uma violação o switch bloqueia os quadros dos hosts com os MACs que ultrapassaram o máximo permitido no comando **"switchport port-security maximum"** e o switch continua operando normalmente para os MACs permitidos, sem gerar avisos.

Na opção **"restrict"** ou "restringir" o switch faz a mesma operação do protect, porém envia uma mensagem para o gerenciamento do switch avisando que o máximo de portas configurado foi excedido via snmp trap e mensagem de syslog.

Conforme já citado, o máximo de MACs seguros padrão do port security é 1, porém pode ser alterado com o comando **"switchport port-security maximum"**, por exemplo, se a porta precisa ter até 3 MACs seguros podemos utilizar o comando **"switchport port-security maximum 3"**.

9.3.1 Verificando o Port Security



No exemplo a seguir vamos analisar a configuração do port security para fazer com que no máximo 2 MACs sejam aprendidos dinamicamente e em caso de violação a porta seja colocada em shutdown.

```
Switch(config-if)#interface fast0/1
Switch(config-if)#switchport port-security
!
! comando habilita o port-security
!
Switch(config-if)#switchport port-security mac-address sticky
!
! comando para fazer o switch aprender dinamicamente o MAC do micro conectado
! na porta fast 0/1
!
Switch(config-if)#switchport port-security maximum 2
!
! define o número máximo de endereços permitidos em 2
! o valor 1 é o default
!
Switch(config-if)#switchport port-security violation shutdown
!
! A ação de violação foi definida para colocar a interface em shutdown,
! ou seja, caso um terceiro dispositivo tente se conectar nesta interface
! a porta será colocada em shutdown.
!
end
```

Para mostra informações sobre o Port Security podemos utilizar o comando "**show port-security**", conforme abaixo.

```
Switch#show port-security
Secure Port    MaxSecureAddr  CurrentAddr  SecurityViolation  Security Action
          (Count)         (Count)         (Count)
-----
Fa0/1          2                0                0                Shutdown
-----
Total Addresses in System (excluding one mac per port)    : 0
Max Addresses limit in System (excluding one mac per port) : 1024
```

No comando "**show port-security**" é possível as principais informações para realizar o troubleshooting em switches com essa função habilitada, veja o que significa cada campo:

- **Secure Port**: número da porta com o port security habilitado.
- **MaxSecureAddr**: máximo de MACs que podem ser aprendidos pela porta (nesse exemplo são 2).
- **CurrentAddr**: quantos endereços a porta aprendeu (nesse exemplo a porta ainda não aprendeu nenhum endereço).
- **SecurityViolation**: quantas violações de segurança aconteceram na porta (nesse exemplo nenhuma violação de segurança aconteceu).
- **Security Action**: qual a ação de segurança configurada na porta (nesse caso é shutdown).

Caso uma violação seja detectada com o modo de operação "shutdown" a porta entra em "error disable". Para voltar a porta em operação é preciso tirar o computador que causou a violação e em modo de interface dar "shut" e depois "no shut" respectivamente.

O comando "**show port-security interface fast 0/x**" mostra informações mais detalhadas do port security, veja um exemplo abaixo onde estão mostradas informações referentes à porta 19 do switch (fast 0/19). Com esse comando temos todas as informações do comando anterior, porém com o detalhamento específico da porta 0/19.

```
SW-DltecC#show port-security interface fast0/19
Port Security           : Enabled -> Indica se o port security está habilitado
Port Status             : Secure-up -> Indica se a porta está protegida
Violation Mode          : Shutdown -> Tipo de ação de violação configurada
Aging Time              : 0 mins -> Aging time dos MACs dinâmicos
Aging Type              : Absolute -> Tipo de temporizador de aging
SecureStatic Address Aging : Disabled -> Indica se existe MAC estático seguro
Maximum MAC Addresses   : 1 -> Número máximo de MACs aprendidos
Total MAC Addresses     : 1 -> Número de MACs aprendidos
Configured MAC Addresses : 0 -> Número de MACs estáticos configurados
Sticky MAC Addresses    : 0 -> Número de MACs sticky gravados na NVRAM
Last Source Address:Vlan : 001d.7060.d31b:30 -> Último MAC aprendido
Security Violation Count : 0 -> Quantidade de violações ocorridas
```

SW-DltecC#

Perceba acima que no campo "**Last Source Address:Vlan**" é mostrado o último MAC aprendido com a VLAN a qual ele pertence, nesse exemplo é o **001d.7060.d31b** que está na VLAN 30.

Outro detalhe interessante é que se estivermos utilizando os modos de violação **shutdown ou restrict** o campo de contagem de violações (**Security Violation Count**) será incrementado, mas no caso do **protect** esse campo não é incrementado.

9.3.2 Como Tratar Portas Restritas, Protegidas e em Error Disable



Se uma porta ultrapassou o número de MACs permitidos quando utilizamos as opções **restrict** ou **protect** você precisará limpar o endereço MAC aprendido para o host específico possa utilizar aquela porta do switch. Para limpar os endereços MAC específicos ou o cachê completo de endereços aprendidos pela porta utilizamos o comando:

Switch#clear port-security dynamic [address mac-addr | interface type mod/num]

Se a opção **"shutdown"** está configurada como ação de violação a porta será desativada e entrará em **error-disable**. Para verificar se existem portas nessa condição podemos utilizar o comando **"show interfaces status err-disable"**, se aparecer o motivo no campo Reason **"psecure-violation"** é sinal de que houve a violação de segurança.

Você pode confirmar com os comandos **show** estudados anteriormente. Nessa condição a porta pode ser reestabelecida automaticamente via configuração prévia ou então você pode desativar e reativar a porta para reabilitá-la.

```
Switch(config)#interface tipo mod/num
Switch(config-if)#shutdown
Switch(config-if)#no shutdown
```

Se o número de MACs conectados à porta continuar excedendo o máximo ela voltará a **error-disable**, nesse caso você precisará analisar o que está acontecendo e porque existem hosts em excesso conectados a ela.

Lembre-se que é possível também configurar o processo automático de volta da porta com o comando estudado no capítulo-2: **"Switch(config)#errdisable recovery cause psecure-violation"**. Assim a porta em **error disable** pelo Port Security vai automaticamente tentar voltar ao normal sem intervenção da equipe de suporte de redes em 5 minutos (300 segundos) por padrão, diminuindo a sobrecarga de trabalho.

9.4 Configurando o DHCP Snooping



O DHCP fornece aos clientes informações como gateway e servidor DNS, portanto se um atacante conseguir colocar um servidor DHCP próprio na rede e responder à requisições de clientes ele pode passar o endereço de sua própria máquina como gateway e também responder às consultas de DNS pelos clientes que eventualmente caiam nessa armadilha.

Após inserir um servidor DHCP falso, o atacante é capaz de fazer ataques do tipo “man-in-the-middle”, pois todo tráfego “off-net” (para outras sub-redes) passarão por ele.

Além disso, ele pode configurar um servidor DNS falso em seu computador e hospedar páginas falsificadas (clonadas) para capturar usuários e senhas dos clientes de rede sem que eles percebam nada.

Esse tipo de ataque pode colocar não só os dados corporativos em risco, mas também os dados pessoais dos usuários de rede que podem eventualmente utilizar os recursos para acessar páginas de Internet Banking ou acessar contas de e-mail, redes sociais e demais recursos pessoais de Internet que são liberados pela empresa.

O **DHCP snooping** é o recurso para mitigar esse tipo de ataque.

Com o DHCP snooping apenas portas de uplink conectadas a um servidor DHCP autorizado são permitidas a enviar todos os tipos de mensagem DHCP, essas portas são chamadas de “**trusted ports**” ou portas confiáveis.

As demais portas do switch são “**untrusted**” ou não confiáveis e podem apenas enviar “DHCP requests” e mensagens típicas de clientes, por isso se uma mensagem de “DHCP offer”, por exemplo, for encontrada em uma porta “untrusted” ela é desligada (shutdown).

As configurações do DHCP snooping são realizadas em modo de configuração global e as portas confiáveis ou “trusted ports” são configuradas individualmente em modo de configuração de interface. Veja os comandos abaixo.

1. Ative o DHCP Snooping em modo de configuração global.

```
Switch(config)#ip dhcp snooping
```

2. Identifique as VLANs que o DHCP snooping deve atuar. Podemos definir por VLAN ou por faixas de VLANs, aí o primeiro número de VLAN é o inicial e na sequência entramos com o valor final da faixa.

```
Switch(config)#ip dhcp snooping vlan num-vlan [num-vlan-final-da-faixa]
```

3. Entre na interface confiável e a configure como trusted.

```
Switch(config-if)#ip dhcp snooping trust
```

4. Você pode definir opcionalmente a taxa de requisições DHCP por segundo que pode ser recebido nas interfaces untrusted, por padrão esse valor é ilimitado e pode ser configurado de 1 a 1024 pacotes por segundo.

```
Switch(config-if)#ip dhcp snooping limit rate pacotes-por-seg
```

Para verificar as configurações utilize o comando abaixo.

```
Switch#show ip dhcp snooping [binding]
```

Outra opção é configurar o switch para enviar a opção DHCP número 82. Essa opção é utilizada para enviar informações do DHCP Relay definidas na RFC 3046.

Com essa configuração quando uma requisição DHCP é recebida em uma porta untrusted o switch insere seu endereço MAC e o port-ID no campo de opção 82 do DHCP.

Assim quando o servidor DHCP remoto responder ele repassa essa mesma informação para o switch poder identificar exatamente o cliente que enviou essa solicitação.

Para desativar essa configuração da opção 82 digite o comando abaixo em modo de configuração global.

```
Switch(config)#no ip dhcp snooping information option
```

Uma dica é que se o DHCP parar de fornecer IPs é bem provável que você precisará digitar o comando anterior.

9.4.1 Exemplo de Configuração do DHCP Snooping



Nesse exemplo as interfaces Fast Ethernet 1/0/3 até 1/0/6 são portas de acesso alocadas na VLAN 10 e consideradas untrusted. Essas portas precisam ter a taxa de pacotes DHCP limitada a 5 pacotes por segundo. O DHCP server está conectado à porta de uplink Gigabit Ethernet 1/0/1. Veja a configuração abaixo.

```
Switch(config)#ip dhcp snooping
Switch(config)#ip dhcp snooping vlan 10
Switch(config)#interface range fastethernet 1/0/3 - 6
Switch(config-if-range)#ip dhcp snooping limit rate 5
Switch(config-if-range)#interface gigabitethernet 1/0/1
Switch(config-if)#ip dhcp snooping trust
```

A seguir veja a saída do comando "show ip dhcp snooping".

```
Switch#show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
10
DHCP snooping is operational on following VLANs:
10
DHCP snooping is configured on the following L3 Interfaces:

Insertion of option 82 is enabled
  circuit-id default format: vlan-mod-port
  remote-id: 000f.f72c.c600 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:
```

Interface	Trusted	Allow option	Rate limit (pps)
FastEthernet1/0/3	no	no	5
Custom circuit-ids:			
FastEthernet1/0/4	no	no	5
Custom circuit-ids:			
FastEthernet1/0/5	no	no	5
Custom circuit-ids:			
FastEthernet1/0/6	no	no	5
Custom circuit-ids:			
GigabitEthernet1/0/1	yes	yes	unlimited
Custom circuit-ids:			

```
Switch#
```

9.4.2 DHCP Snooping Database Agent



Para manter a tabela de MACs e IPs aprendidos pelo DHCP snooping mesmo que os switches reiniciem você pode utilizar um DHCP snooping database agent, ou seja, um agente que guarde a tabela de vínculos criada fora do switch.

Sem o agente os vínculos criados pelo DHCP snooping serão perdidos quando o switch sofrer um reload.

Abaixo segue um exemplo de configuração do DHCP snooping database age como verificar a base de dados externa.

```
Switch# configure terminal
Switch(config)# ip dhcp snooping database tftp://10.1.1.1/
Switch(config)# end
Switch# show ip dhcp snooping database detail
Agent URL : tftp://10.1.1.1/
Write delay Timer : 300 seconds
Abort Timer : 300 seconds

Agent Running : No
Delay Timer Expiry : 7 (00:00:07)
Abort Timer Expiry : Not Running

Last Succeeded Time : None
Last Failed Time : 17:14:25 UTC Sat Jul 7 2001
Last Failed Reason : Unable to access URL.

Total Attempts      :          21   Startup Failures :          0
Successful Transfers :          0   Failed Transfers :         21
Successful Reads    :          0   Failed Reads    :          0
Successful Writes   :          0   Failed Writes   :         21
Media Failures      :          0

First successful access: Read

Last ignored bindings counters :
Binding Collisions   :          0   Expired leases    :          0
Invalid interfaces   :          0   Unsupported vlans :          0
```

```
Parse failures      :      0
Last Ignored Time : None
```

```
Total ignored bindings counters:
```

```
Binding Collisions :      0   Expired leases      :      0
Invalid interfaces :      0   Unsupported vlans :      0
Parse failures     :      0
```

```
Switch#
```

9.4.3 Restrições ao Ativar o DHCP Snooping



Abaixo seguem algumas restrições nas configurações quando o DHCP snooping é ativado:

- O banco de dados do DHCP snooping armazena pelo menos 8.000 entradas (bindings).
- Quando o DHCP snooping está ativado os seguintes comandos do IOS DHCP não ficarão mais disponíveis:
 - ip dhcp relay information check
 - ip dhcp relay information policy
 - ip dhcp relay information trust-all
 - ip dhcp relay information option
 - ip dhcp relay information trusted

Se você digitar um desses comandos o switch vai retornar uma mensagem de erro e a configuração não será aplicada.

9.5 Configurando o DAI – Dynamic ARP Inspection



No ataque de **ARP spoofing** um atacante envia mensagens de "**gratuitous ARP**" (ARPs gratuitos – enviados sem ninguém solicitar) com o endereço IP do default gateway local vinculado ao seu próprio endereço MAC.

Esse ataque é também conhecido como **ARP Poisoning**.

Os equipamentos da rede local que recebem essas mensagens sobrescrevem a informação do gateway que está correta com o endereço MAC falsificado em sua tabela ARP.

Com isso todo tráfego off-net ao invés de ser enviado para o gateway é enviado para o computador do atacante, possibilitando um ataque de "Man-in-the-Middle" (MITM).

Esse ataque pode ser utilizado para outros endereços de rede também além do gateway, por exemplo, o atacante pode enviar ARPs gratuitos vinculando o endereço de um servidor interno ao seu MAC para que os clientes ao invés de acessar o serviço legítimo acabam caindo em uma armadilha e acessando o computador do atacante que possui um "clone" da aplicação, por exemplo.

Para não ser detectado o atacante copia ou altera os pacotes e encaminha para o destino correto, fazendo com que o host comprometido nem suspeite que sofreu um ataque ou teve seu tráfego desviado.

O **Dynamic ARP Inspection (DAI)** atua em conjunto com o DHCP snooping para mitigar o ARP spoofing.

O DAI também define portas trusted e untrusted, ou seja, confiáveis e não confiáveis respectivamente.

Nas portas configuradas como untrusted as mensagens ARP são interceptadas e o endereço IP/MAC é comparado com o banco de dados de informações do DHCP snooping, se as informações batem o tráfego é encaminhado, senão o switch faz a filtragem.

9.5.1 Ativando o DAI



Devemos configurar as portas de acesso como untrusted e as portas que conectam outros switches de distribuição ou a um roteador devem ser portas configuradas como trusted.

Para ativar o DAI podemos fazer por VLAN específica ou para uma faixa de VLANs, na sequência devemos definir as interfaces trusted. Veja os comandos abaixo.

```
Switch(config)#ip arp inspection vlan faixa-de-vlans
```

Por padrão todas as portas do switch são consideradas não confiáveis, por isso precisamos definir as portas que conectam outros switches ou o roteador que será o gateway como trusted.

```
Switch(config)#interface tipo mód/num  
Switch(config-if)#ip arp inspection trust
```

Para os hosts configurados estaticamente e não via DHCP você deverá listá-los em uma ARP ACL permitindo o tráfego, pois eles não serão encontrados na base do DHCP Snooping, veja a configuração abaixo.

```
Switch(config)#arp access-list nome-da-ACL  
Switch(config-acl)#permit ip host end-IP-do-Host mac host MAC-do-host [log]  
Switch(config-acl)#exit
```

Na sequência aplique a ARP access list ao DAI conforme comando abaixo.

```
Switch(config)#ip arp inspection filter nome-da-ACL vlan faixa-de-VLANs [static]
```

Quando uma requisição ARP é recebida ela é verificada se existe alguma entrada na ARP ACL e se não tem o switch verifica se tem alguma entrada na tabela do DHCP Snooping. A opção "static" faz com que se não exista entrada na ACL o switch não verifique mais o banco de dados do DHCP Snooping, gerando um "deny implícito" no final da ACL.

Outra configuração possível é estender as validações no DAÍ, pois por padrão ele valida o MAC e IP de origem dentro da mensagem do ARP (ARP Reply), porém não valida o MAC do quadro ethernet onde a mensagem do ARP está encapsulada. Para fazer essa verificação extra utilize o comando abaixo.

```
Switch(config)#ip arp inspection validate {[src-mac] [dst-mac] [ip]}
```

É preciso configurar pelo menos uma das opções listadas abaixo:

- **src-mac:** verifica se o MAC de origem do quadro Ethernet é igual ao MAC contido no ARP reply.
- **dst-mac:** verifica se o MAC de destino do quadro Ethernet é igual ao endereço MAC de destino da mensagem de ARP reply.
- **Ip:** verifica o endereço IP de quem enviou o ARP request e também se o endereço de quem enviou a requisição é o mesmo contido nos ARP replies.

Para verificar as informações do DAÍ utilize o “**show ip arp inspection**”.

9.5.2 Exemplo de Configuração do DAI



Nesse exemplo vamos fazer com que todas as portas do switch de acesso configuradas na VLAN 10 sejam untrusted a não ser a interface gig1/0/1 que é o uplink conectado aos switches de distribuição. Além disso, vamos configurar um mapeamento estático do servidor **192.168.1.10** com MAC **0006.10ba.baca**. Veja as configurações abaixo.

```
Switch(config)#ip arp inspection vlan 10
Switch(config)#arp access-list CCNA-DAI
Switch(config-acl)#permit ip host 192.168.1.10 mac host 0006.10ba.baca
Switch(config-acl)#exit
Switch(config)#ip arp inspection filter CCNA-DAI vlan 10
Switch(config)#interface gigabitethernet 1/0/1
Switch(config-if)#ip arp inspection trust
Switch(config-if)#end
Switch#
Switch#sho ip arp inspection
```

```
Source Mac Validation      : Disabled
Destination Mac Validation : Disabled
IP Address Validation      : Disabled
```

Vlan	Configuration	Operation	ACL Match	Static ACL
10	Enabled	Inactive	CCNA-DAI	No

Vlan	ACL Logging	DHCP Logging	Probe Logging

```

10      Deny          Deny          Off
Vlan    Forwarded    Dropped    DHCP Drops    ACL Drops
-----
10      0            0            0            0

Vlan    DHCP Permits    ACL Permits    Probe Permits    Source MAC Failures
-----
10      0              0              0              0

Vlan    Dest MAC Failures    IP Validation Failures    Invalid Protocol Data
-----
Vlan    Dest MAC Failures    IP Validation Failures    Invalid Protocol Data
-----
10      0                    0                    0
Switch#

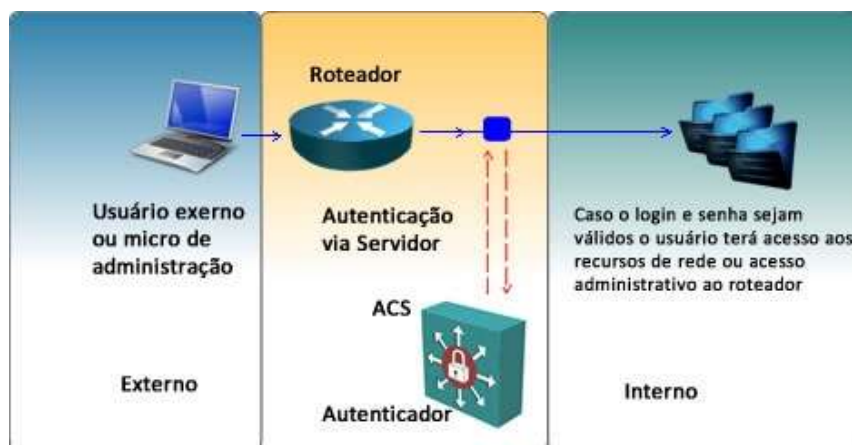
```

10 Conceitos de AAA (Authentication, Authorization, and Accounting)

10.1 Introdução



O **AAA (Authentication, Authorization, and Accounting)** oferece uma forma para a autenticação de usuários em servidores ou dispositivos de conectividade (router, switch, etc), além de controlar o nível de acesso destes usuários para os recursos desejados e gravar os comandos realizados para futuras auditorias. Veja imagem abaixo com um esquema do processo de autenticação via servidor externo AAA.



Para que isto seja possível, o AAA participa em três etapas durante este processo:

1. **Autenticação de usuários:** Com o AAA, é possível centralizar o gerenciamento de todas as contas de usuários e respectivas senhas, facilitando bastante o trabalho do administrador da rede. O administrador da rede poderá especificar diversos mecanismos para a autenticação de usuários, entre eles **RADIUS**, **TACACS+** ou **Kerberos** e, para que isto ocorra, a ordem de execução destes componentes deverá ser informada e devidamente associada para uma interface ou mais interfaces do equipamento de rede. Por exemplo, um usuário que necessita configurar uma rota em um roteador Cisco poderá informar o seu username e password para o acesso ao equipamento.
2. **Autorização para a execução de comandos:** Após a autenticação do usuário, o AAA precisa informar ao roteador sobre os comandos que o referido usuário poderá executar

no terminal. É possível limitar a quantidade de comandos disponíveis para a execução das seguintes formas: por usuário, perfil ou grupo de usuários.

3. **Auditar os acessos ao equipamento:** O AAA enviará dados sobre cada comando executado pelo usuário durante uma sessão com o roteador. Com este recurso, poderemos identificar e controlar todas as atividades de configuração e monitoramento efetuadas no roteador. Por exemplo, o administrador de rede pode analisar o que o usuário dltecuser fez durante sua sessão e quando ele executou os comandos.

Mais especificamente em roteadores e switches Cisco o AAA pode utilizar um banco de dados local ou servidor externo para autenticação e autorização, porém normalmente o que é configurado na prática é o AAA com servidores externos TACACS+ ou RADIUS e o banco de dados local é utilizado como "fallback", ou seja, caso haja um problema com a comunicação entre o roteador e o servidor ele pode utilizar um usuário do banco de dados local para fazer o login, por exemplo.

10.2 Protocolos TACAS+ e RADIUS

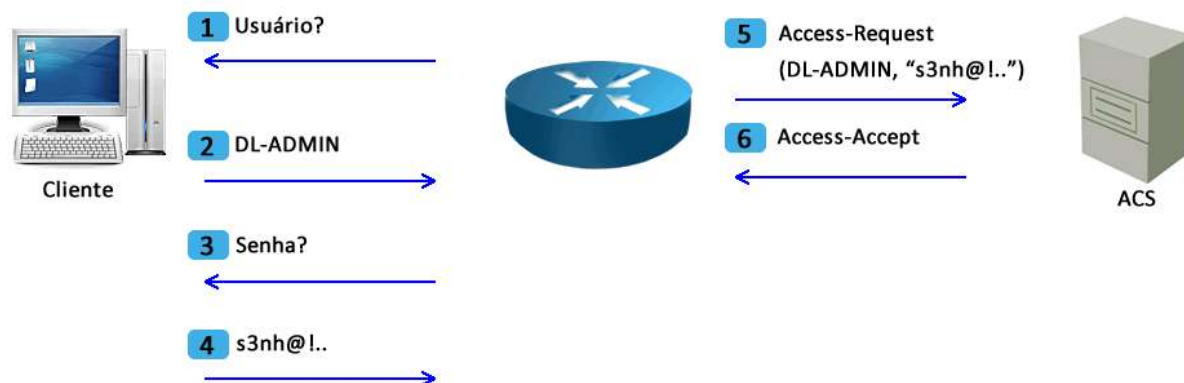


O protocolo RADIUS (Remote Authentication Dial-In User Service) hoje faz parte dos padrões da IETF e pode funcionar juntamente com outros serviços. O RADIUS tem uma porta para autenticação/autorização (UDP 1645 ou UDP 1812) e outra para contabilidade (accounting - UDP 1646 ou UDP 1813).

O processo de autenticação do RADIUS utiliza um servidor que tem contato com o cliente, um servidor RADIUS e um banco de dados onde os dados dos usuários são armazenados. A autenticação é feita por meio de uma mensagem que o cliente RADIUS envia para o servidor RADIUS contendo login e senha.

Quando o servidor recebe a mensagem, ele valida o cliente e verifica o login, senha e outros parâmetros que vêm com a mensagem. Em caso de uma autenticação válida, o servidor envia ao cliente uma mensagem permitindo o acesso bem como as ações permitidas pelo nível de acesso.

Na figura a seguir você pode verificar as etapas de autenticação para acesso remoto em um roteador utilizando o RADIUS.



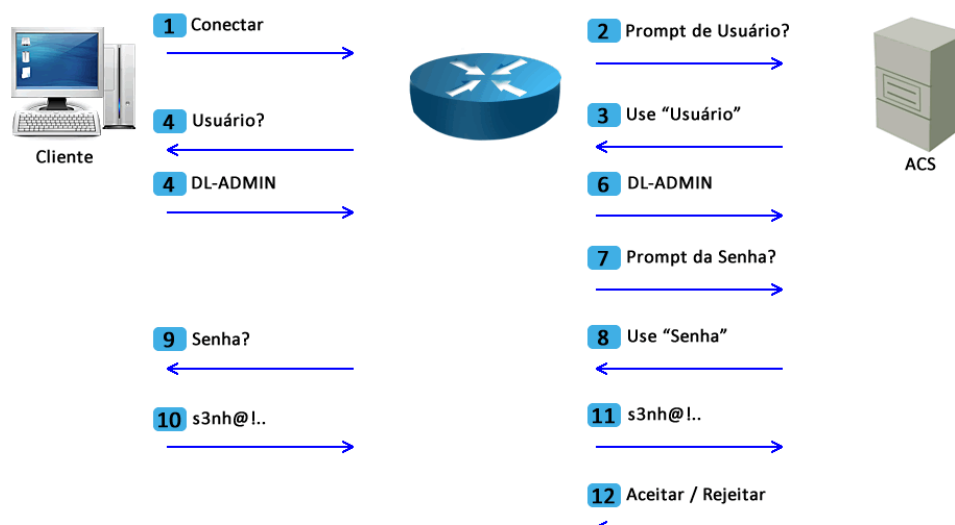
O protocolo TACACS+ é proprietário da Cisco sendo suportado pela grande maioria dos roteadores da Cisco. É um melhoramento do protocolo aberto TACACS.

O TACACS+ também é um protocolo que veio após o RADIUS e, portanto, apresenta algumas vantagens em relação a este. O TACACS+ usa conexões TCP (mais segura) enquanto o RADIUS faz transporte via UDP (menos seguro).

Do ponto de vista da segurança a diferença entre os protocolos de transporte utilizados é fundamental. O RADIUS precisa trabalhar com um número maior de variáveis para suprir a falta de serviços do UDP. Como TACACS+ usa TCP, que é orientado a conexão, esses detalhes não são preocupação do protocolo TACACS+. Usando TCP é mais fácil descobrir quando um servidor está off-line e quando ele está simplesmente lento.

O TACACS+ criptografa todo o corpo do pacote e faz a separação entre autenticação e autorização e contabilização. Com essa separação é possível criar soluções de autorização separadas. O TACACS+ utiliza o protocolo TCP na porta 49 para transmitir suas informações de maneira segura. Além disso, o TACACS+ tem suporte multiprotocolo.

Na figura a seguir você pode verificar o mesmo processo para acesso remoto em um roteador utilizando agora o TACACS+ como protocolo de autenticação.



Portanto, ambos TACACS + e RADIUS são protocolos de autenticação, porém cada um suporta diferentes recursos e funcionalidades.

Escolher entre o TACACS + ou RADIUS depende das necessidades da organização. Por exemplo, um grande provedor de acesso pode selecionar RADIUS porque suporta um billing detalhado (contabilidade) necessárias para o faturamento dos usuários.

Já uma organização com vários grupos de usuários pode preferir utilizar o TACACS +, porque possibilita a implementação de políticas de autorização que pode ser aplicada por usuário ou por grupo. Veja na tabela a seguir um resumo da comparação entre o TACACS+ e o RADIUS.

Funcionalidade	TACACS+	RADIUS
Suporte AAA	Separa os três serviços AAA.	Combina autenticação e autorização e separa a contabilidade.
Protocolo de Transporte	TCP	UDP
Pergunta/Resposta	Bidirecional	Unidirecional (somente do Servidor RADIUS para o cliente)
Integridade dos dados	Todo o pacote TACACS+ criptografado	Somente a senha do usuário é criptografada

11 Segurança em Redes Sem Fio

11.1 Introdução



Devido à característica básica de uma rede sem fio: "a de **irradiar o sinal através do espaço aberto**", ela naturalmente enfrenta maiores riscos de segurança que uma rede cabeada.

Como o sinal pode irradiar para fora dos domínios físicos da empresa ou residência, atacantes externos podem capturar o sinal e conseguir invadir a rede com fins maliciosos.

Os principais tipos de ameaças às redes sem fio são:

- **War drivers:** O termo "war driving" se aplica à prática de usar equipamentos com antenas de alto ganho e software para captar os pacotes de identificação da rede e registrar sua localização. Os war drivers fazem anotações sobre o protocolo usado, se há criptografia ativa, qual o SSID e outras informações que possam facilitar um futuro ataque. Além disso, eles podem também fazer acesso à Internet a partir dessas redes, seja para fins pessoais maliciosos ou não.



-

11.2 WEP e Wi-Fi Protected Access 1, 2 e 3



Protocolo original de autenticação e criptografia definido pelo IEEE 802.11, o qual utiliza chave que varia de 40 e 128 bits (opcional) chama-se WEP ou Wired Equivalent Privacy.

Os principais problemas do WEP é que ele utiliza chaves pré-compartilhadas de maneira estática, ou seja, as chaves são sempre as mesmas.

Dessa forma, se os administradores de rede não alterarem essas chaves constantemente, elas podem ser descobertas por hackers.

O outro problema é que a chave de criptografia de 40 bits é fácil de ser quebrada com qualquer software cracker, tal como o AirSnort.

Em 2001 a IEEE começou o desenvolvimento do padrão IEEE 802.11i com intuito de prover maior segurança em redes Wireless e resolver os problemas de segurança gerados pelo WEP.

Em 2002 a Wi-Fi Alliance optou por usar o que já estava pronto desse padrão, nesse momento ainda não estava completo o IEEE 802.11i.

Assim em 2003 surgiu o WPA que representa o pré-IEEE 802.11i.

A proposta do WPA2, o qual foi lançado em 2004, era substituir o WEP e outras características derivadas do padrão antigo, além de suportar os recursos adicionais de segurança não disponíveis no WPA.

Note que apesar do WPA e WPA2 terem sido um caso onde foi necessário a implementação de um protocolo para corrigir as falhas de um protocolo anterior (no caso o WEP), o WPA3 não deve ser encarado da mesma forma.

O WPA3 vem como um novo protocolo ou serviço, mas como a arquitetura de um guarda-chuva, abrigando e melhorando todas as capacidades que já existem no WPA2.

A seguir temos uma tabela comparativa entre os quatro protocolos: WEP, WPA, WPA2 e WPA3.

	WEP	WPA	WPA2	WPA3
Descrição	Wired Equivalent Privacy	Wi-Fi Protected Access versão 1	Wi-Fi Protected Access versão 2	Wi-Fi Protected Access versão 3
Criptografia	RC4	TKIP+RC4	CCMP/AES	GCMP-256
Autenticação	WEP Open WEP Shared	WPA PSK WPA Enterprise	WPA2 Personal WPA2 Enterprise	WPA2 Personal WPA2 Enterprise
Integridade dos Dados	CRC-32	MIC (Message Integrity Check)	Cipher block Chaining Message Authentication Code (com base no AES)	256-bit Broadcast/Multicast Integrity Protocol Galois Message Authentication Code (BIP-GMAC-256)
Gerenciamento das Chaves de Criptografia	Nenhuma	Handshake de 4 vias	Handshake de 4 vias	Elliptic Curve Diffie-Hellman (ECDH) exchange + Elliptic Curve Digital Signature Algorithm (ECDSA)

11.2.1 Visão Geral do WEP



Apesar de não ser parte dos requisitos atuais do CCNA vamos começar a estudar os padrões de segurança pelo WEP por questões didáticas e de comparação.

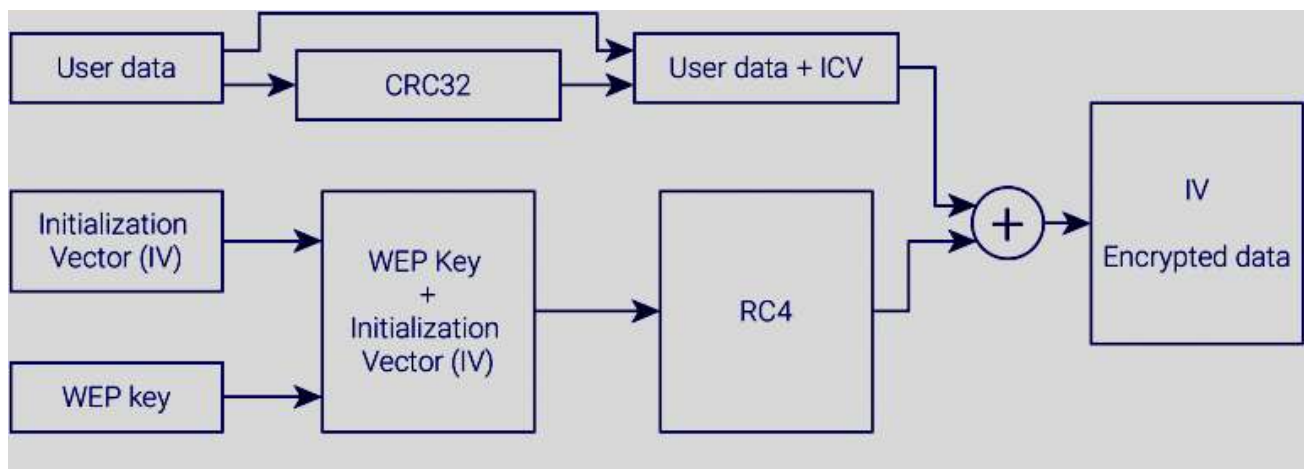
Quando o Wi-Fi foi introduzido em 1997, havia apenas um algoritmo destinado à segurança que era o WEP ou Wired Equivalent Privacy.

Sua intenção era fornecer confidencialidade similar a uma transmissão com fio.

Os algoritmos de segurança usados no Wi-Fi visam garantir a integridade e criptografia dos dados.

A integridade garante ao usuário que a mensagem não foi manipulada, já a criptografia impede que outros usuários "espionem" o conteúdo da mensagem.

Na figura abaixo você pode ver o fluxo de dados na criptografia WEP.



No WEP a integridade é feita com um check de redundância cíclica de 32 bits (CRC-32).

O vetor de verificação de integridade (Integrity Check Vector - ICV) é anexado aos dados do usuário e encaminhado para criptografia.

É aqui que surge a primeira falha do WEP, pois a intenção do CRC32 era detectar erros durante a transmissão, porém esse método não é muito confiável para verificação de integridade da mensagem.

Note que o RC4 é usado para criptografia.

O RC4 é um algoritmo de criptografia de fluxo, que usa um par de chave WEP (uma senha) e um Vetor de inicialização (IV - Initialization Vector) como semente (seed).

A chave WEP pode ter 40 ou 104 bits e o vetor de inicialização (IV) tem sempre 24 bits. Isso torna a semente de 64 ou 128 bits.

O vetor de inicialização é anexado à mensagem criptografada e seu objetivo é evitar o uso da mesma semente para criptografar mensagens diferentes.

O problema do WEP é que em poucos minutos tantos pacotes podem ser capturados que a colisão IV atinge uma probabilidade de 50%. Isso torna a chave WEP fácil de ser comprometida.

É altamente recomendável não usar mais o WEP sob nenhuma circunstância.

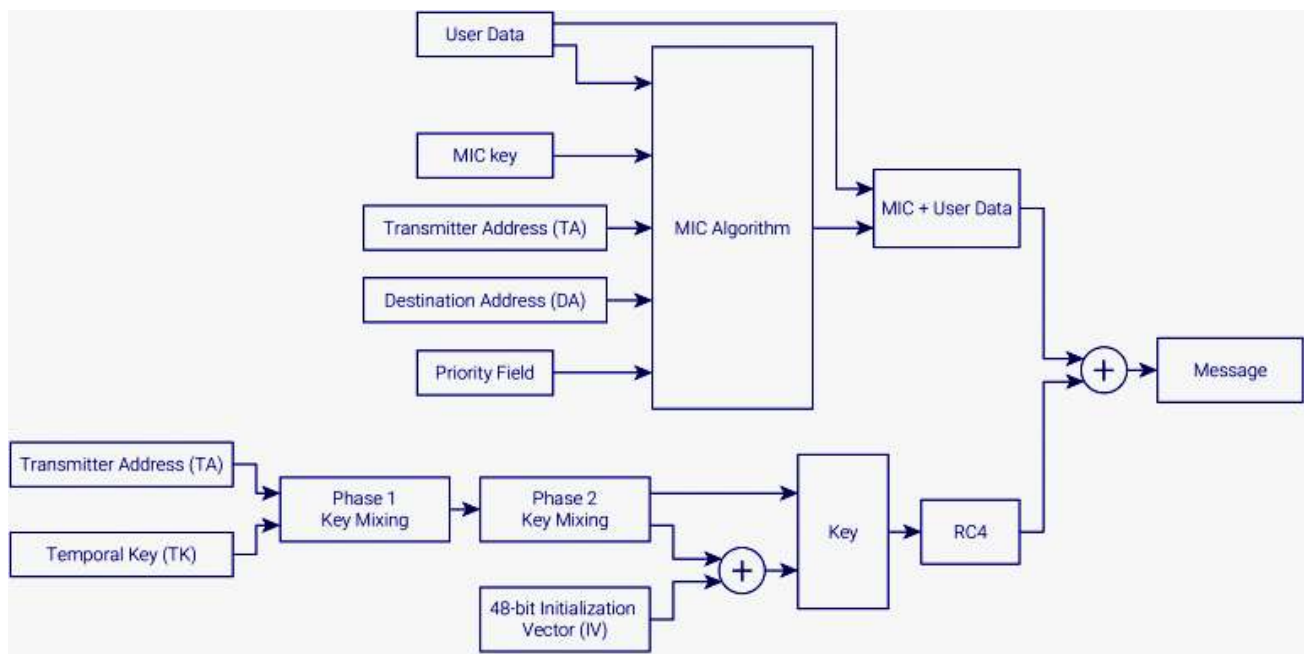
11.2.2 Funcionamento do WPA



O WPA foi implementado como parte dos recursos do 802.11i e baseado no mesmo hardware do WEP, portanto, apenas a atualização do firmware foi necessária para melhorar o aspecto de segurança.

Como havia duas falhas principais no WEP, o WPA tratou de ambas: chaves estáticas e gerenciamento de chaves.

Vamos ver a figura abaixo com o funcionamento do WPA.



A criptografia ainda era baseada em RC4, pois era uma implementação de hardware e não podia ser atualizada, mas a criptografia foi estendida para 48 bits.

Além disso, uma chave principal (senha que você insere no ponto de acesso e na estação) não é mais passada diretamente, mas sim combinada e a chave de criptografia é derivada da chave principal. Isso torna a chave principal mais difícil de ser comprometida.

A mensagem de saída é, como no caso do WEP, operação xou dos dados do usuário e fluxo pseudo-aleatório do RC4, mas desta vez a chave está muito melhor protegida e a colisão é menos provável.

O WPA também melhorou a integridade da mensagem. Ele introduziu o algoritmo Message Integrity Check (MIC), que por design era mais adequado para essa tarefa do que o CRC32 usado no WEP.

O algoritmo é baseado não apenas nos dados, mas também na entrada adicional, como endereço do transmissor, endereço de destino, etc., por isso é muito mais difícil forjar a mensagem com o vetor MIC correto.

É importante lembrar que o WPA protege apenas contra aqueles que não têm uma chave.

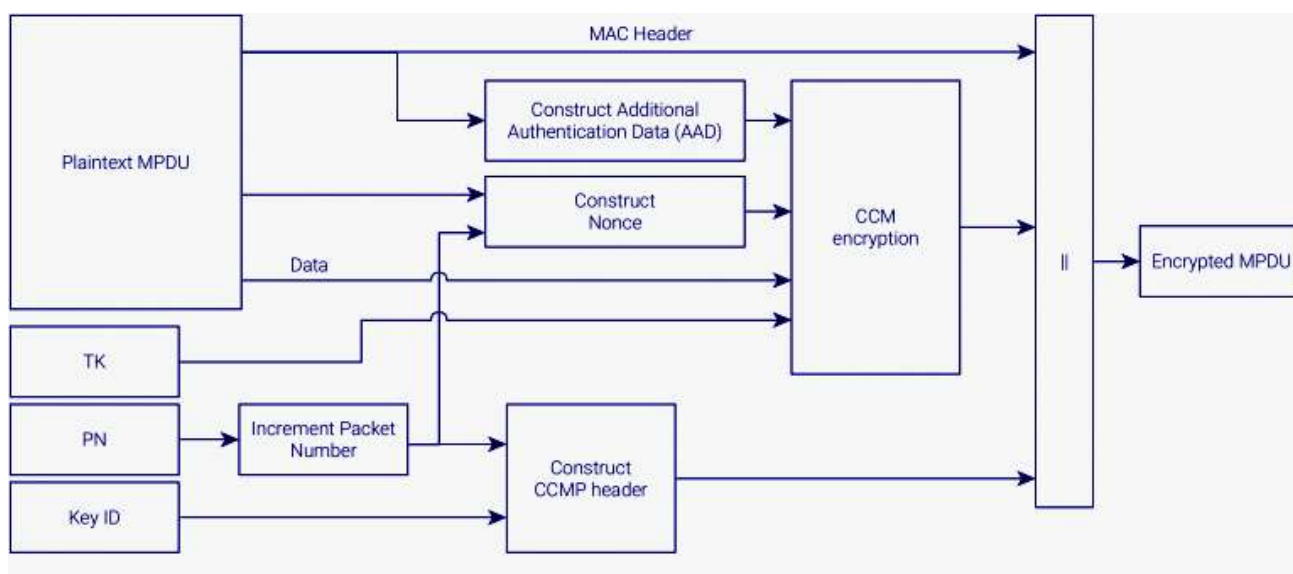
Se um usuário mal-intencionado estiver conectado legitimamente a alguma rede protegida com WPA, ele pode capturar pacotes destinados a outras pessoas e descriptografá-los.

11.2.3 Funcionamento do WPA2



O WPA2 implementa todos os recursos obrigatórios do 802.11i, fornecendo uma melhoria significativa de segurança em relação ao WEP e WPA.

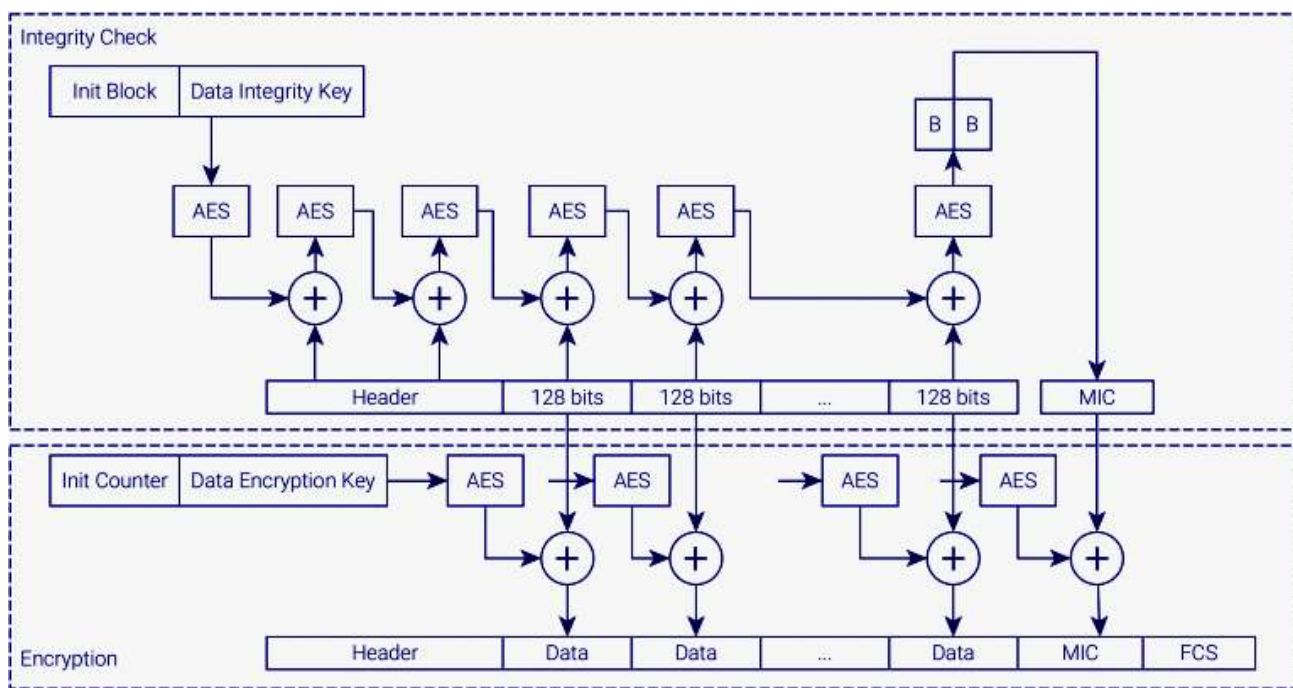
A mudança arquitetônica mais importante é o algoritmo de criptografia de dados, pois o WPA2 utiliza o Chaining Message Authentication Code Protocol (CCMP) em conjunto com o Advanced Encryption Standard (AES).



Como você pode ver na figura anterior, o WPA2 difere do WPA na forma como a mensagem criptografada e a integridade são calculadas.

Tanto no WEP como no WPA havia cadeia de cálculo de integridade e cadeia de criptografia facilmente distinguíveis.

Já no WPA2 a criptografia e a verificação de integridade são realizadas em um único bloco lógico chamado CCM. Vamos dar uma olhada no esquema detalhado a seguir deste bloco para saber como a integridade e a criptografia são realizadas no WPA2.



Tanto a verificação de integridade quanto a criptografia são baseadas no algoritmo Advanced Encryption Standard (AES), o qual é baseado em bloco, ou seja, operando em blocos de 128 bits.

A mensagem de entrada é dividida em partes de 128 bits e usada junto com os resultados anteriores como uma entrada para o algoritmo AES.

A mensagem inteira, incluindo o cabeçalho, é levada em consideração para a verificação de integridade, enquanto apenas o payload é criptografado.

O cabeçalho deve ser transmitido na sua forma original (sem criptografia) para permitir a detecção e decodificação de quadros.

11.2.4 Funcionamento do WPA3



No início do ano de 2018 a Wi-Fi Alliance anunciou que o WPA3 será lançado no próximo recurso, cujo é simplificar a segurança, permitir autenticação mais robusta e aumentar a força criptográfica.

O WPA3 vem em duas variantes: **WPA3-Personal** e **WPA3-Enterprise**, assim como o WPA2.

No WPA3-Personal, a chave pré-compartilhada pessoal (PSK) não está mais em uso e a autenticação simultânea de iguais (SAE) passa a ser utilizada em seu lugar.

Este método é baseado na troca de chaves e é mais resistente a ataques de dicionário offline, onde os dados previamente registrados podem ser usados para adivinhar a senha.

Este mecanismo permite proteger os dados mesmo que a senha seja fraca, ou seja, curta ou usando frases populares.

O WPA3-Enterprise é baseado no WPA2, mas fornece uma série de melhorias:

- A criptografia autenticada é fornecida pelo protocolo Galois / Counter Mode de 256 bits (GCMP-256)
- A derivação da chave usa o modo de autenticação de mensagens hash de 384 bits (HMAC) com algoritmo de hash seguro (SHA)
- O estabelecimento de chaves usa a troca da curva elíptica Diffie-Hellman (ECDH) e o algoritmo de assinatura digital da curva elíptica (ECDSA)
- Proteção de quadro baseada em 256-bit Broadcast/Multicast Integrity Protocol Galois Message Authentication Code (BIP-GMAC-256)

A Wi-Fi Alliance também anunciou o **Wi-Fi Enhanced Open**, que é uma resposta a um problema com redes abertas, por exemplo, em aeroportos, shoppings ou cafés.

Hoje você pode acessar essas redes gratuitamente, muitas vezes usando algum portal, mas o tráfego no link wireless não é criptografado. O Wi-Fi Enhanced Open fornecerá criptografia de dados não autenticada com base em **Opportunistic Wireless Encryption (OWE)**.

11.2.5 PSK, Personal e Enterprise



Se você notou temos alguns termos utilizados aqui que são:

- WPA PSK versus Enterprise
- WPA2/2 Personal versus Enterprise

As opções PSK e Personal tem a mesma referência que é de ser utilizada em ambientes domésticos ou então pequenas empresas, ou seja, normalmente os clientes compartilharão uma chave pré-definida ou pré-compartilhada que é definida no Access Point ou na Controladora sem fio (WLC - Wireless LAN Controller).

Uma vez que você sabe essa chave ela é a mesma para TODOS os usuários da rede sem fio!

Para melhorar esse aspecto em redes corporativas é possível inserir um passo a mais no vínculo entre o cliente e um Access Point através do protocolo 802.1X.

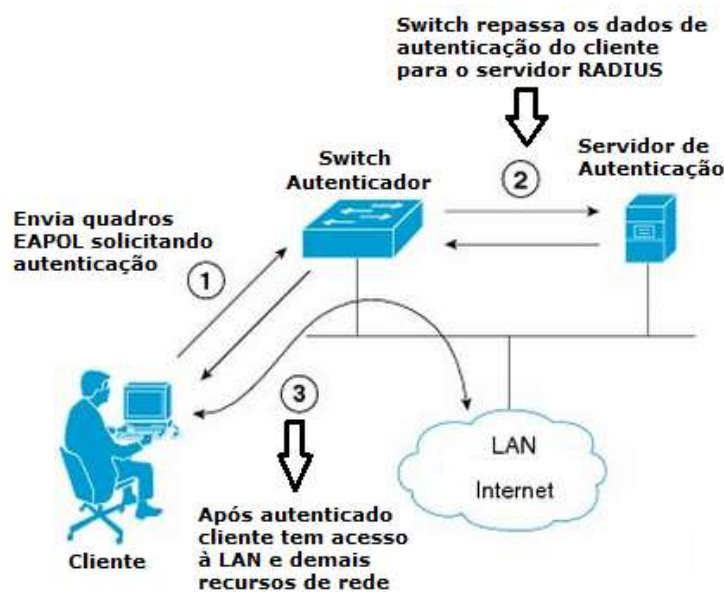
O padrão aberto IEEE 802.1x combinado com o AAA possibilita implementar autenticação por porta de switch ou então em redes sem fio (tanto nos APs autônomos como em redes com WLCs) para os computadores (chamados de clientes ou clients) antes que eles possam acessar a LAN.

O processo exige que o computador tenha um cliente 802.1X instalado, caso ele tenha e o switch não tem o 802.1X ativado em suas portas o computador abandona o processo e acessa a rede normalmente.

Por outro lado, quando o switch ou o Access Point tem o 802.1X ativado e o computador não tem um cliente instalado ele não vai conseguir acessar a rede e ficará bloqueado.

Quando um computador se conecta a um switch ou AP configurado com autenticação 802.1x os seguintes passos ocorrem até que ele possa acessar a rede:

1. A porta entra em um estado não autorizado (unauthorized state), permitindo apenas tráfego **802.1x** EAP através da LAN (**EAPOL** - Extensible Authentication Protocol over LANs).
2. O cliente se conecta à porta e na sequência o switch solicita autenticação ou o cliente envia quadros EAPOL para iniciar o processo de autenticação.
3. O switch envia as informações sobre a autenticação recebidas do cliente para um servidor RADIUS, o qual fará a verificação dos dados para autenticar ou não o acesso através daquela porta do switch.
4. Se a autenticação teve sucesso a porta passa para o estado de autorizada (authorized state) e o tráfego pode ser enviado normalmente pela LAN.



Se o servidor não reconhecer as informações de autenticação a porta não sobe e volta ao estado de não autorizada.

Após a autenticação o switch pode manter a conexão permanente ou o administrador pode configurar um tempo máximo de conexão, forçando ao cliente reautenticar de tempos em tempos. Todo esse processo ocorre em camada-2.

O switch atua no 802.1x como autenticador (authenticator) do cliente que é chamado de "Supplicant" (suplicante).

A autenticação é feita pelo servidor de autenticação (Authentication Server).

11.3 Configurando uma WLAN com WPA2 PSK via GUI



Esse tópico foi coberto no Curso "**ACESSO À REDE CABEADA E SEM FIO**" no capítulo "**Configuração de uma WLAN Via Web GUI**".

Recomendamos que você faça a revisão desse item caso tenha dúvida na resolução do simulado constante na trilha do curso CCNA 200-301.

12 Conclusão do Curso

12.1 Conclusão

Bem pessoal, chegamos ao final de mais um curso!

É muito importante que nesse ponto do curso você tenha domínio dos seguintes itens:

- Os principais conceitos de segurança, tais como ameaças, vulnerabilidades, exploits e mitigação
- Elementos de um programa de segurança, tais como user awareness, treinamento e controle do acesso físico
- Configurar o controle de acesso aos dispositivos através de senhas locais
- Políticas de segurança de senhas e seus elementos, assim como métodos alternativos (multifactor authentication, certificados digitais e biometria)
- VPNs site-to-site e de acesso remoto
- Configurar e verificar Listas de Controle de Acesso (Access Control Lists ou ACLs)
- Configurar recursos de segurança em camada-2 (DHCP snooping, dynamic ARP inspection e port security)
- Funcionamento do AAA (authentication, authorization e accounting)
- Descrever o funcionamento dos protocolos de segurança em redes sem fio: WPA, WPA2 e WPA3
- Configurar uma WLAN utilizando WPA2 PSK através da interface GUI

Lembre-se que esse curso conta também com vídeo aulas, questionários e laboratórios extras que estão dentro da trilha do CCNA para quem está se preparando para a prova de certificação ou então quer ter os conhecimentos de um profissional nível associado exigido pela Cisco.